Student Material – Professional Series

EC-Council

Official Curricula

EC-Council C|EH v13

Certified Ethical Hacker

Ethical Hacking and Countermeasures

Version 13

EC-Council

Copyright © 2024 by EC-Council. All rights reserved. Except as permitted under the Copyright Act of 1976, no part of this publication may be reproduced or distributed in any form or by any means, or stored in a database or retrieval system, without the prior written permission of the publisher, with the exception that the program listings may be entered, stored, and executed in a computer system, but may not be reproduced for publication without the prior written permission of the publisher, except in the case of brief quotations embodied in critical reviews and certain other noncommercial uses permitted by copyright law. For permission requests, write to EC-Council, addressed "Attention: EC-Council," at the address below:

EC-Council New Mexico
101C Sun Ave NE
Albuquerque, NM 87109

Information contained in this publication has been obtained by EC-Council from sources believed to be reliable. EC-Council takes reasonable measures to ensure that the content is current and accurate; however, because of the possibility of human or mechanical error, we do not guarantee the accuracy, adequacy, or completeness of any information and are not responsible for any errors or omissions nor for the accuracy of the results obtained from use of such information.

The courseware is a result of extensive research and contributions from subject-matter experts from all over the world. Due credits for all such contributions and references are given in the courseware in the research endnotes. We are committed to protecting intellectual property rights. If you are a copyright owner (an exclusive licensee or their agent) and you believe that any part of the courseware constitutes an infringement of copyright, or a breach of an agreed license or contract, you may notify us at **legal@eccouncil.org**. In the event of a justified complaint, EC-Council will remove the material in question and make necessary rectifications.

The courseware may contain references to other information resources and security solutions, but such references should not be considered as an endorsement of or recommendation by EC-Council.

Readers are encouraged to report errors, omissions, and inaccuracies to EC-Council at **legal@eccouncil.org**. If you have any issues, please contact us at **support@eccouncil.org**.

NOTICE TO THE READER

EC-Council does not warrant or guarantee any of the products, methodologies, or frameworks described herein nor does it perform any independent analysis in connection with any of the product information contained herein. EC-Council does not assume, and expressly disclaims, any obligation to obtain and include information other than that provided to it by the manufacturer. The reader is expressly warned to consider and adopt all safety precautions that might be indicated by the activities described herein and to avoid all potential hazards. By following the instruction contained herein, the reader willingly assumes all risks in connection with such instructions. EC-Council makes no representations or warranties of any kind, including but not limited to the warranties of fitness for particular purpose or merchantability, nor are any such representations implied with respect to the material set forth herein, and EC-Council takes no responsibility with respect to such material. EC-Council shall not be liable for any special, consequential, or exemplary damages resulting, in whole or in part, from the reader's use of or reliance upon this material.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Foreword

Since you are reading this CEHv13 courseware, you most likely realize the importance of information systems security. However, we would like to put forth our motive behind compiling a resource such as this one and what you can gain from this course.

You might find yourself asking what sets this course apart from the others out there. The truth is that no single courseware can address all the issues of information security in a detailed manner. Moreover, the rate at which exploits, tools, and methods are being discovered by the security community makes it difficult for one program to cover all the necessary facets of information security. This doesn't mean that this course is inadequate in any way as we have worked to cover all major domains in such a manner that the reader will be able to appreciate the way security has evolved over time as well as gain insight in to the fundamental workings relevant to each domain. It is a blend of academic and practical wisdom supplemented with tools that the reader can readily access in order to obtain a hands-on experience.

The emphasis throughout the courseware is on gaining practical know-how, which explains the stress on free and accessible tools. You will read about some of the most widespread attacks seen, the popular tools used by attackers, and how attacks have been carried out using ordinary resources.

You may also want to know what to expect once you have completed the course. This courseware is a resource material. Any penetration tester can tell you that there is no one straight methodology or sequence of steps that you can follow while auditing a client site. There is no one template that will meet all your needs. Your testing strategy will vary with the client, the basic information about the system or situation, and the resources at your disposal. However, for each stage you choose – be it enumeration, firewall, penetration of other domains - you will find something in this courseware that you can definitely use.

Finally, this is not the end! This courseware is to be considered a constant work-in-progress because we will be adding value to this courseware over time. You may find some aspects extremely detailed, while others may have less detail. We are constantly asking ourselves if the content helps explain the core point of the lesson, and we constant calibrate our material with that in mind. We would love to hear your viewpoints and suggestions so please send us your feedback to help in our quest to constantly improve our courseware.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

About the EC-Council CEH Program

If you want to stop hackers from invading your network, first you've got to invade their minds.

Computers around the world are systematically being victimized by rampant hacking. This hacking is not only widespread, but is being executed so flawlessly that the attackers compromise a system, steal everything of value and completely erase their tracks.

The goal of the ethical hacker is to help the organization take preemptive measures against malicious attacks by attacking the system himself; all the while staying within legal limits. This philosophy stems from the proven practice of trying to catch a thief, by thinking like a thief. As technology advances and organization depend on technology increasingly, information assets have evolved into critical components of survival.

If hacking involves creativity and thinking 'out-of-the-box', then vulnerability testing and security audits will not ensure the security proofing of an organization. To ensure that organizations have adequately protected their information assets, they must adopt the approach of 'defense in depth'. In other words, they must penetrate their networks and assess the security posture for vulnerabilities and exposure.

The Ethical Hacker is an individual who is usually employed with the organization and who can be trusted to undertake an attempt to penetrate networks and/or computer systems using the same methods as a Hacker. Hacking is a felony in some countries. When it is done by request and under a contract between an Ethical Hacker and an organization, it is legal. The most important point is that an Ethical Hacker has authorization to probe the target.

The CEH Program certifies individuals in the specific network security discipline of Ethical Hacking from a vendor-neutral perspective. The Certified Ethical Hacker certification will fortify the application knowledge of security officers, auditors, security professionals, site administrators, and anyone who is concerned about the integrity of the network infrastructure. A Certified Ethical Hacker is a skilled professional who understands and knows how to look for the weaknesses and vulnerabilities in target systems and uses the same knowledge and tools as a malicious hacker.

To achieve the Certified Ethical Hacker Certification, you must pass the CEH exam 312-50.

Please visit **https://www.eccouncil.org/train-certify/certified-ethical-hacker-ceh/** for more information.

Course Prerequisites

It is highly recommended that candidates pursuing this course have a fundamental understanding of operating systems, file systems, computer networks, TCP/IP protocols, information security controls, basic network troubleshooting, data leakage, data backup, and risk management.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

About EC-Council

The International Council of Electronic Commerce Consultants, better known as EC-Council, was founded in late 2001 to address the need for well-educated and certified information security and e-business practitioners. EC-Council is a global, member-based organization composed of industry and subject matter experts working together to set the standards and raise the bar in information security certification and education.

EC-Council first developed the Certified Ethical Hacker (C|EH) program with the goal of teaching the methodologies, tools, and techniques used by hackers. Leveraging the collective knowledge of hundreds of subject-matter experts, the CEH program has rapidly gained popularity around the world and is now delivered in more than 145 countries by more than 950 authorized training centers. It is considered as the benchmark for many government entities and major corporations around the globe.

EC-Council, through its impressive network of professionals and huge industry following, has also developed a range of other leading programs in information security and e-business. EC-Council certifications are viewed as the essential certifications needed when standard configuration and security policy courses fall short. Providing a true, hands-on, tactical approach to security, individuals armed with the knowledge disseminated by EC-Council programs are tightening security networks around the world and beating hackers at their own game.

Other EC-Council Programs

Security Awareness: Certified Secure Computer User

C|SCU
Certified | Secure Computer User

The purpose of the CSCU training program is to provide students with the necessary knowledge and skills to protect their information assets. This class will immerse students in an interactive learning environment where they will acquire fundamental understanding of various computer and network security threats such as identity theft, credit card fraud, online banking phishing scams, viruses and backdoors, email hoaxes, sexual predators and other online threats, loss of confidential information, hacking attacks, and social engineering. More importantly, the skills learnt from the class help students take the necessary steps to mitigate their security exposure.

Cyber Security: Certified Cybersecurity Technician

C|CT
Certified | Cybersecurity Technician

The Certified Cybersecurity Technician (CCT) program covers the fundamental concepts of cybersecurity. It equips students with the skills required to identify the increasing network security threats that reflect on the organization's security posture and implement general security controls to protect the underlying IT infrastructure from unauthorized access, alteration, destruction, or disclosure.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

This program gives a holistic overview of the key components of cybersecurity. The course is designed for those interested in learning the various fundamentals of cybersecurity and aspire to pursue a career in cybersecurity.

Network Defense: Certified Network Defender

Students enrolled in the Certified Network Defender course will gain a detailed understanding of network defense and develop their hands-on expertise to perform in real-life network defense situations. They will gain the depth of technical knowledge required to actively design a secure network within your organization. This course provides a fundamental understanding of the true nature of data transfer, network technologies, and software technologies so that students may understand how networks operate, how automation software behaves, and how to analyze networks and their defense.

Students will learn how to protect, detect, and respond to the network attacks as well as learning about network defense fundamentals, the application of network security controls, protocols, perimeter appliances, secure IDS, VPN, and firewall configuration. Students will also learn the intricacies of network traffic signature, analysis, and vulnerability scanning, which will help in designing improved network security policies and successful incident response plans. These skills will help organizations foster resiliency and operational continuity during attacks.

Network Defense: Certified Cloud Security Engineer

Certified Cloud Security Engineer (CCSE) course includes both vendor neutral and vendor specific cloud security concepts. Vendor neutral concepts include universally applicable general cloud security best practices, technology, frameworks, and principles that help individuals to strengthen their fundamentals. Vendor specific concepts help individuals to gain the practical skills required when they actually start working with a specific cloud platform. Thus, this course helps individuals in strengthening their fundamental cloud security knowledge and gain practical knowledge of security practices, tools, and techniques used to configure widely used public cloud providers such as AWS, AZURE, and GCP.

Penetration Testing: Certified Penetration Testing Professional

CPENT certification requires you to demonstrate the application of advanced penetration testing techniques such as advanced Windows attacks, IOT systems attacks, advanced binaries exploitation, exploits writing, bypassing a filtered network, Operational Technology (OT) pen testing, accessing hidden networks with pivoting and double pivoting, privilege escalation, and evading defense mechanisms.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

EC-Council's CPENT standardizes the knowledge base for penetration testing professionals by incorporating best practices followed by experienced experts in the field. The objective of the CPENT is to ensure that each professional follows a strict code of ethics, is exposed to the best practices in the domain of penetration testing and aware of all the compliance requirements required by the industry.

Unlike a normal security certification, the CPENT credential provides an assurance that security professionals possess skills to analyze the security posture of a network exhaustively and recommend corrective measures authoritatively. For many years EC-Council has been certifying IT Security Professionals around the globe to ensure these professionals are proficient in network security defense mechanisms. EC-Council's credentials vouch for their professionalism and expertise thereby making these professionals more sought after by organizations and consulting firms globally.

Computer Forensics: Computer Hacking Forensic Investigator

Computer Hacking Forensic Investigator (CHFI) is a comprehensive course covering major forensic investigation scenarios. It enables students to acquire crucial hands-on experience with various forensic investigation techniques. Students learn how to utilize standard forensic tools to successfully carry out a computer forensic investigation, preparing them to better aid in the prosecution of perpetrators.

EC-Council's CHFI certifies individuals in the specific security discipline of computer forensics from a vendor-neutral perspective. The CHFI certification bolsters the applied knowledge of law enforcement personnel, system administrators, security officers, defense and military personnel, legal professionals, bankers, security professionals, and anyone who is concerned about the integrity of network infrastructures.

Incident Handling: EC-Council Certified Incident Handler

EC-Council's Certified Incident Handler (E|CIH) program has been designed and developed in collaboration with cybersecurity and incident handling and response practitioners across the globe. It is a comprehensive specialist-level program that imparts knowledge and skills that organizations need to effectively handle post breach consequences by reducing the impact of the incident, from both a financial and a reputational perspective.

E|CIH is a method-driven program that uses a holistic approach to cover vast concepts concerning organizational incident handling and response from preparing and planning the incident handling response process to recovering organizational assets after a security incident. These concepts are essential for handling and responding to security incidents to protect organizations from future threats or attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Management: Certified Chief Information Security Officer

The Certified Chief Information Security Officer (CCISO) program was developed by EC-Council to fill a knowledge gap in the information security industry. Most information security certifications focus on specific tools or practitioner capabilities. When the CCISO program was developed, no certification existed to recognize the knowledge, skills, and aptitudes required for an experienced information security professional to perform the duties of a CISO effectively and competently. In fact, at that time, many questions existed about what a CISO really was and the value this role adds to an organization.

The CCISO Body of Knowledge helps to define the role of the CISO and clearly outline the contributions this person makes in an organization. EC-Council enhances this information through training opportunities conducted as instructor-led or self-study modules to ensure candidates have a complete understanding of the role. EC-Council evaluates the knowledge of CCISO candidates with a rigorous exam that tests their competence across five domains with which a seasoned security leader should be familiar.

Application Security: Certified Application Security Engineer

The Certified Application Security Engineer (CASE) credential is developed in partnership with large application and software development experts globally. The CASE credential tests the critical security skills and knowledge required throughout a typical software development life cycle (SDLC), focusing on the importance of the implementation of secure methodologies and practices in today's insecure operating environment.

The CASE certified training program is developed concurrently to prepare software professionals with the necessary capabilities that are expected by employers and academia globally. It is designed to be a hands-on, comprehensive application security course that will help software professionals create secure applications. The training program encompasses security activities involved in all phases of the Software Development Lifecycle (SDLC): planning, creating, testing, and deploying an application.

Unlike other application security trainings, CASE goes beyond just the guidelines on secure coding practices and includes secure requirement gathering, robust application design, and handling security issues in post development phases of application development. This makes CASE one of the most comprehensive certifications on the market today. It is desired by software application engineers, analysts, testers globally, and respected by hiring authorities.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Incident Handling: Certified Threat Intelligence Analyst

Certified Threat Intelligence Analyst (C|TIA) is designed and developed in collaboration with cybersecurity and threat intelligence experts across the globe to help organizations identify and mitigate business risks by converting unknown internal and external threats into known threats. It is a comprehensive, specialist-level program that teaches a structured approach for building effective threat intelligence.

In the ever-changing threat landscape, C|TIA is an essential Threat Intelligence training program for those who deal with cyber threats on a daily basis. Organizations today demand a professional-level cybersecurity threat intelligence analyst who can extract the intelligence from data by implementing various advanced strategies. Such professional-level Threat Intelligence training programs can only be achieved when the core of the curricula maps with and is compliant to government and industry published threat intelligence frameworks.

Incident Handling: Certified SOC Analyst

The Certified SOC Analyst (CSA) program is the first step to joining a security operations center (SOC). It is engineered for current and aspiring Tier I and Tier II SOC analysts to achieve proficiency in performing entry-level and intermediate-level operations.

CSA is a training and credentialing program that helps the candidate acquire trending and in-demand technical skills through instruction by some of the most experienced trainers in the industry. The program focuses on creating new career opportunities through extensive, meticulous knowledge with enhanced level capabilities for dynamically contributing to a SOC team. Being an intense 3-day program, it thoroughly covers the fundamentals of SOC operations, before relaying the knowledge of log management and correlation, SIEM deployment, advanced incident detection, and incident response. Additionally, the candidate will learn to manage various SOC processes and collaborate with CSIRT at the time of need.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

CEH Exam Information

CEH Exam Details	
Exam Title	**Certified Ethical Hacker (CEH)**
Exam Code	**312-50**
Availability	**EC-Council Exam Portal** (please visit **https://www.eccexam.com**) **VUE** (please visit **https://home.pearsonvue.com/eccouncil**)
Duration	**4 Hours**
Questions	**125**
Passing Score	Please refer **https://cert.eccouncil.org/faq.html**

Please visit **https://cert.eccouncil.org/certified-ethical-hacker.html** for more information.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Table of Contents

Module 01: Introduction to Ethical Hacking **01**

Information Security Overview 04

Hacking Concepts and Hacker Classes 18

Ethical Hacking Concepts 26

Hacking Methodologies and Frameworks 45

Information Security Controls 67

Information Security Laws and Standards 98

Module 02: Footprinting and Reconnaissance **121**

Footprinting Concepts 124

Footprinting through Search Engines 131

Footprinting through Internet Research Services 157

Footprinting through Social Networking Sites 197

Whois Footprinting 212

DNS Footprinting 219

Network and Email Footprinting 230

Footprinting through Social Engineering 247

Footprinting Tasks using Advanced Tools and AI 254

Footprinting Countermeasures 275

Module 03: Scanning Networks **279**

Network Scanning Concepts 282

Host Discovery 300

Port and Service Discovery 318

OS Discovery 357

Scanning Beyond IDS and Firewall 378

Network Scanning Countermeasures 408

Module 04: Enumeration **423**

Enumeration Concepts 426

NetBIOS Enumeration 434

SNMP and LDAP Enumeration 447

NTP and NFS Enumeration 467

SMTP and DNS Enumeration 478

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Other Enumeration Techniques 511
Enumeration Countermeasures 534

Module 05: Vulnerability Analysis **543**
Vulnerability Assessment Concepts 547
Vulnerability Assessment Tools 581
Vulnerability Assessment Reports 614

Module 06: System Hacking **621**
Gaining Access 624
Escalating Privileges 762
Maintaining Access 824
Clearing Logs 945

Module 07: Malware Threats **997**
Malware and APT Concepts 1000
Fileless Malware Concepts 1093
AI-based Malware Concepts 1111
Malware Analysis 1126
Malware Countermeasures 1245

Module 08: Sniffing **1265**
Sniffing Concepts 1268
Sniffing Techniques 1284
Sniffing Tools 1356
Sniffing Countermeasures 1365

Module 09: Social Engineering **1377**
Social Engineering Concepts 1380
Human-based Social Engineering Techniques 1389
Computer-based Social Engineering Techniques 1401
Mobile-based Social Engineering Techniques 1436
Social Engineering Countermeasures 1444

Module 10: Denial-of-Service **1463**
DoS/DDoS Concepts 1466
DoS/DDoS Attack Techniques 1484

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

DoS/DDoS Attack Countermeasures 1515

Module 11: Session Hijacking **1543**
Session Hijacking Concepts 1546
Application-Level Session Hijacking 1558
Network-Level Session Hijacking 1581
Session Hijacking Countermeasures 1597

Module 12: Evading IDS, Firewalls, and Honeypots **1621**
IDS, IPS, and Firewall Concepts 1624
IDS, IPS, and Firewall Solutions 1653
Evading IDS/Firewalls 1667
Evading NAC and Endpoint Security 1723
Honeypot Concepts and Detecting Honeypots 1763
IDS/Firewall Evasion Countermeasures 1777

Module 13: Hacking Web Servers **1787**
Web Server Concepts 1790
Web Server Attacks 1812
Web Server Attack Methodology 1838
Web Server Attack Countermeasures 1885

Module 14: Hacking Web Applications **1917**
Web Application Concepts 1921
Web Application Threats 1930
Web Application Hacking Methodology 2017
Web API and Webhooks 2154
Web Application Security 2205

Module 15: SQL Injection **2285**
SQL Injection Concepts 2288
Types of SQL Injection 2297
SQL Injection Methodology 2311
Evasion Techniques 2400
SQL Injection Countermeasures 2416

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Module 16: Hacking Wireless Networks **2439**
Wireless Concepts 2442
Wireless Encryption 2456
Wireless Threats 2475
Wireless Hacking Methodology 2486
Wireless Attack Countermeasures 2562

Module 17: Hacking Mobile Platforms **2579**
Mobile Platform Attack Vectors 2582
Hacking Android OS 2620
Hacking iOS 2682
Mobile Device Management 2719
Mobile Security Guidelines and Tools 2732

Module 18: IoT and OT Hacking **2765**
IoT Concepts and Attacks 2770
IoT Hacking Methodology 2830
IoT Attack Countermeasures 2883
OT Concepts and Attacks 2905
OT Hacking Methodology 2964
OT Attack Countermeasures 3003

Module 19: Cloud Computing **3023**
Cloud Computing Concepts 3027
Cloud Computing Threats 3083
Cloud Hacking 3148
AWS Hacking 3170
Microsoft Azure Hacking 3244
Google Cloud Hacking 3275
Container Hacking 3292
Cloud Security 3310

Module 20: Cryptography **3365**
Cryptography Concepts and Encryption Algorithms 3368
Applications of Cryptography 3414
Cryptanalysis Methods and Cryptography Attacks 3462
Cryptography Attack Countermeasures 3503

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Glossary 3513
References 3547
Appendix A - Ethical Hacking Essential Concepts - I 3623
Appendix B - Ethical Hacking Essential Concepts - II 3743
Appendix C - Hacking AI Technologies 3833

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

This page is intentionally left blank.

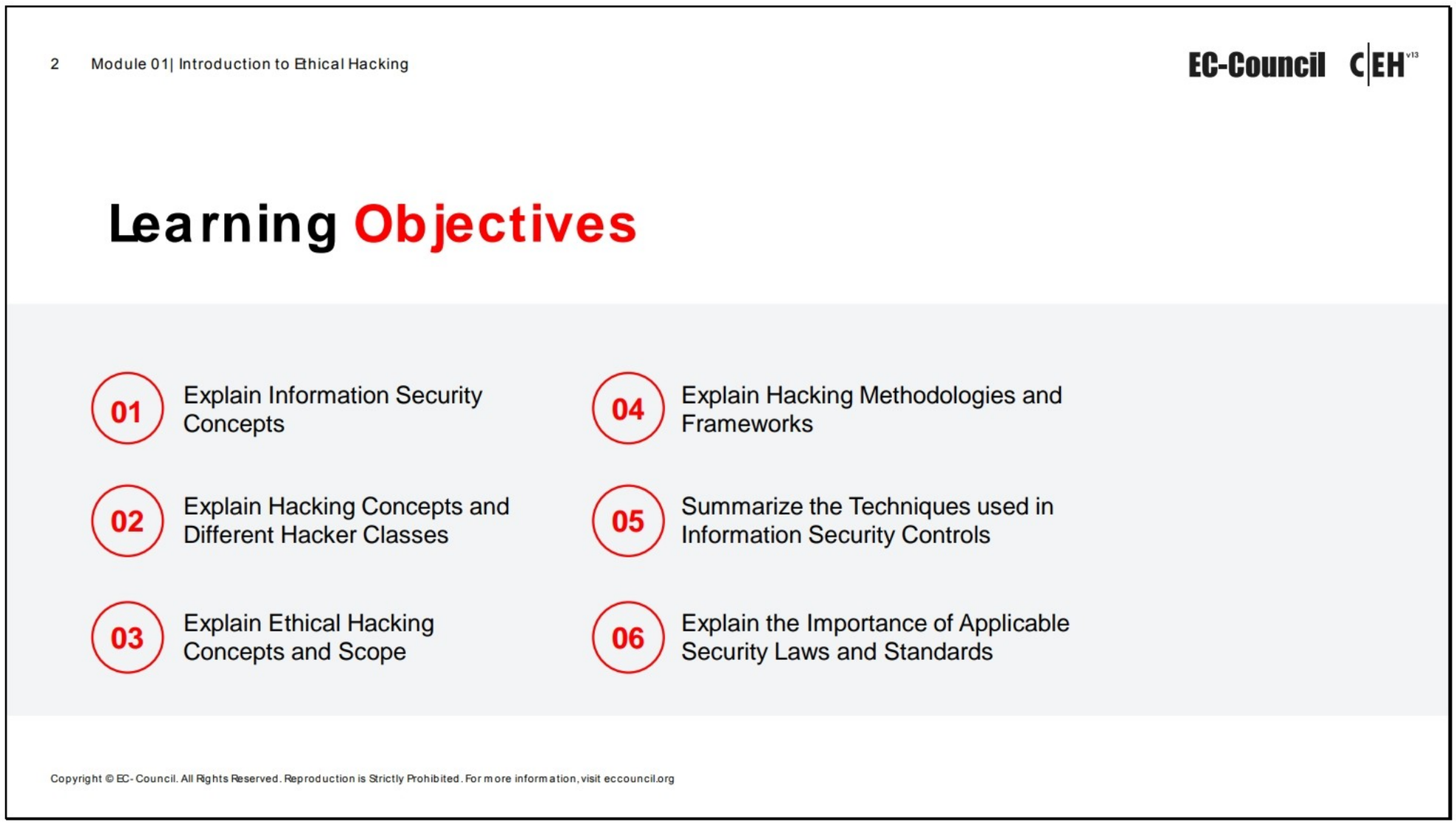
Module 01

Introduction to Ethical Hacking

EC-Council
Official Curricula

EC-Council C|EH v13 Certified Ethical Hacker

This page is intentionally left blank.



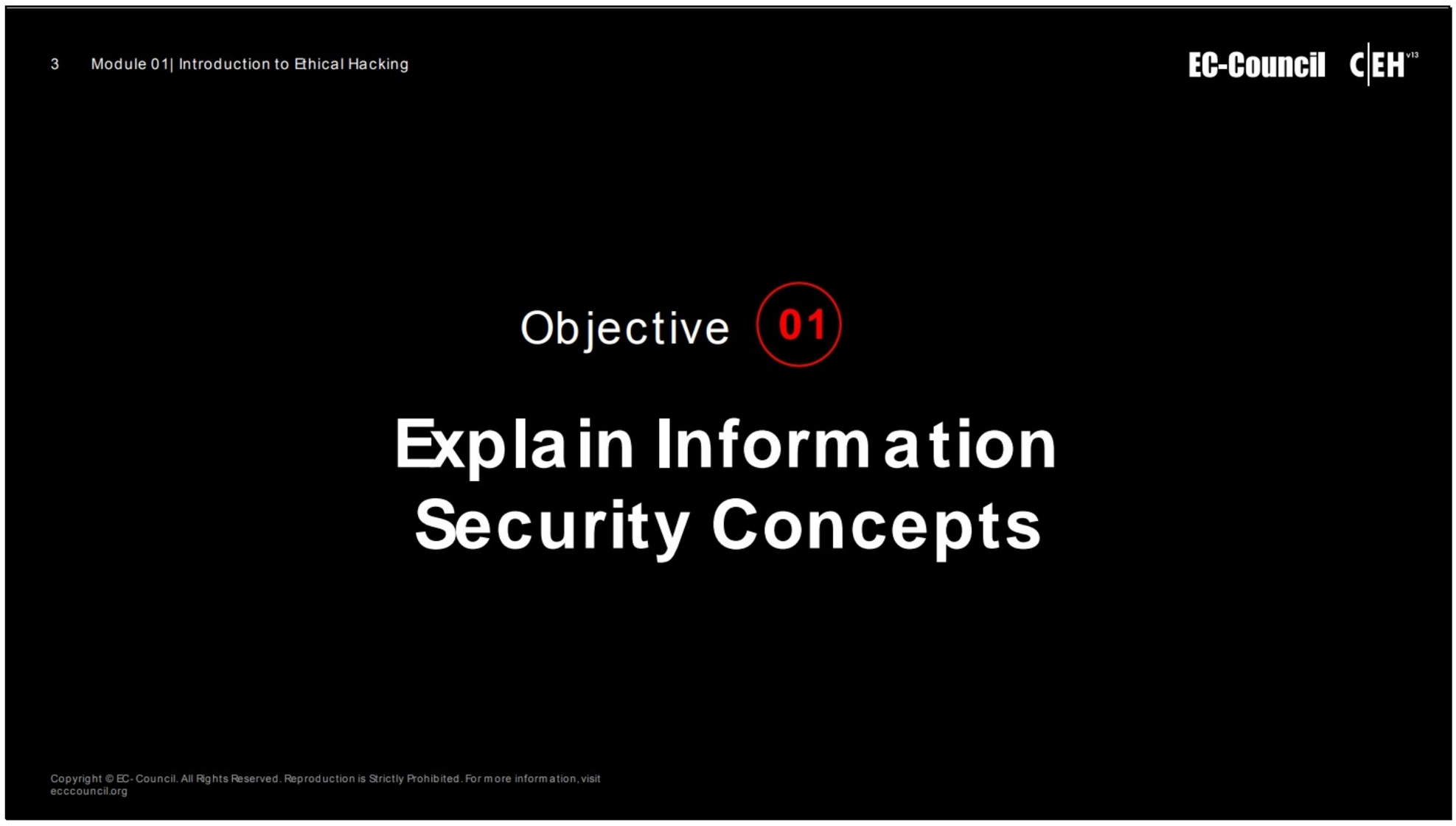
Learning Objectives

Attackers break into systems for various reasons and purposes. Therefore, it is important to understand how malicious hackers attack and exploit systems and the probable reasons behind these attacks. As Sun Tzu states in the Art of War, "If you know yourself but not the enemy, for every victory gained, you will also suffer a defeat." System administrators and security professionals must guard their infrastructure against exploits by knowing the enemy—malicious hackers who seek to use the same infrastructure for illegal activities.

At the end of this module, you will be able to:

- Describe the elements of information security
- Explain information security attacks and information warfare
- Describe hacking concepts and hacker classes
- Explain ethical hacking concepts and AI-driven ethical hacking
- Describe various hacking methodologies and frameworks
- Understand information security controls (information assurance, defense-in-depth, risk management, cyber threat intelligence, threat modeling, incident management process, and artificial intelligence (AI)/machine learning (ML))
- Understand various information security acts and laws

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

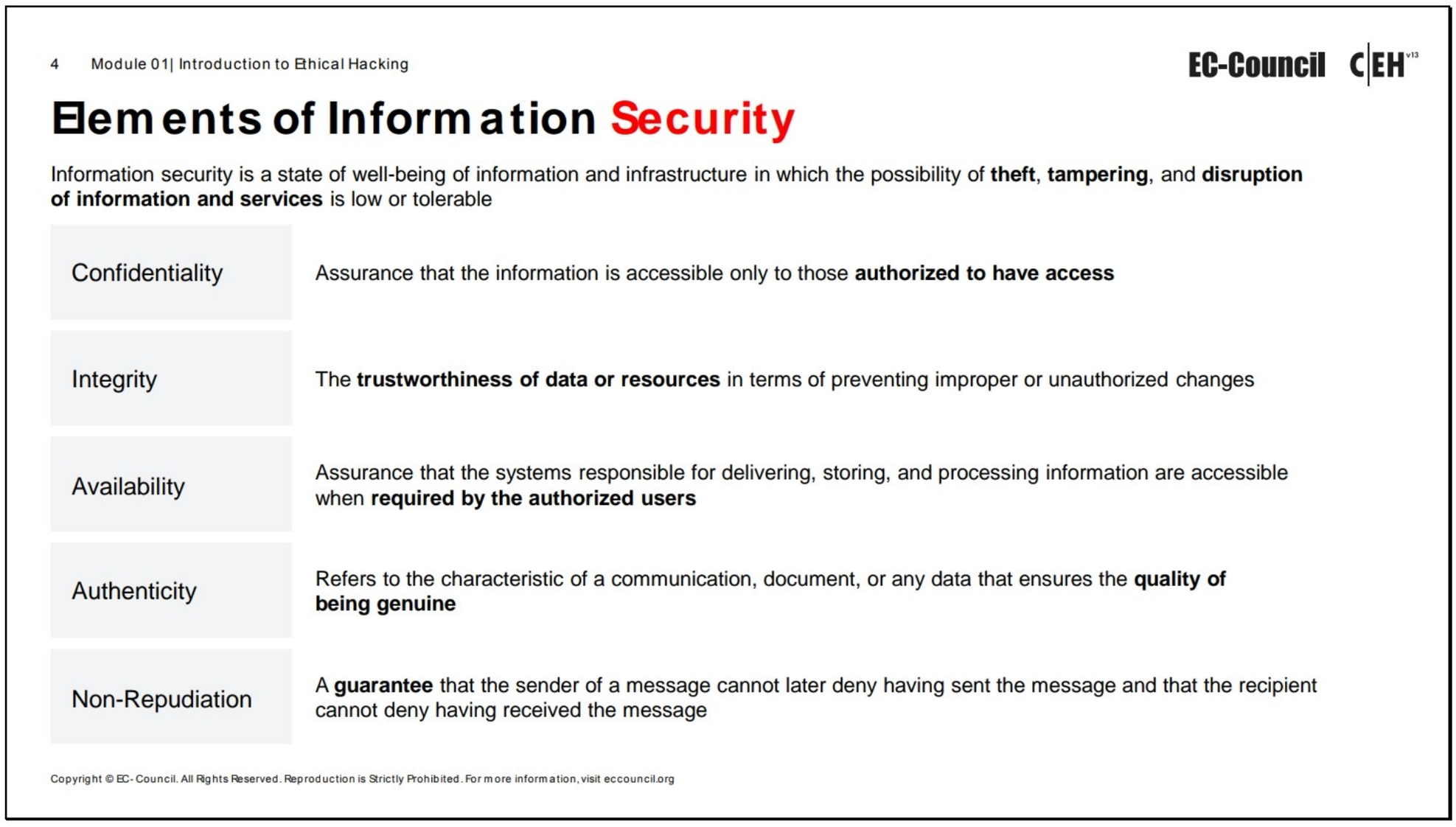


Information Security Concepts

Information security refers to the protection or safeguarding of information and information systems that use, store, and transmit information from unauthorized access, disclosure, alteration, and destruction. Information is a critical asset that organizations must secure. If sensitive information falls into the wrong hands, then the respective organization may suffer huge losses in terms of finances, brand reputation, customers, or in other ways. To provide an understanding of how to secure such critical information resources, this module starts with an overview of information security.

This section introduces the elements of information security, classification of attacks, and information warfare.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Elements of Information Security

Information security is "the state of the well-being of information and infrastructure in which the possibility of theft, tampering, or disruption of information and services is kept low or tolerable." It relies on five major elements: confidentiality, integrity, availability, authenticity, and non-repudiation.

- **Confidentiality**

  Confidentiality is the assurance that the information is accessible only to authorized. Confidentiality breaches may occur due to improper data handling or a hacking attempt. Confidentiality controls include data classification, data encryption, and proper disposal of equipment (such as DVDs, USB drives, and Blu-ray discs).

- **Integrity**

  Integrity is the trustworthiness of data or resources in the prevention of improper and unauthorized changes—the assurance that information is sufficiently accurate for its purpose. Measures to maintain data integrity may include a checksum (a number produced by a mathematical function to verify that a given block of data is not changed) and access control (which ensures that only authorized people can update, add, or delete data).

- **Availability**

  Availability is the assurance that the systems responsible for delivering, storing, and processing information are accessible when required by authorized users. Measures to maintain data availability can include disk arrays for redundant systems and clustered machines, antivirus software to combat malware, and distributed denial-of-service (DDoS) prevention systems.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

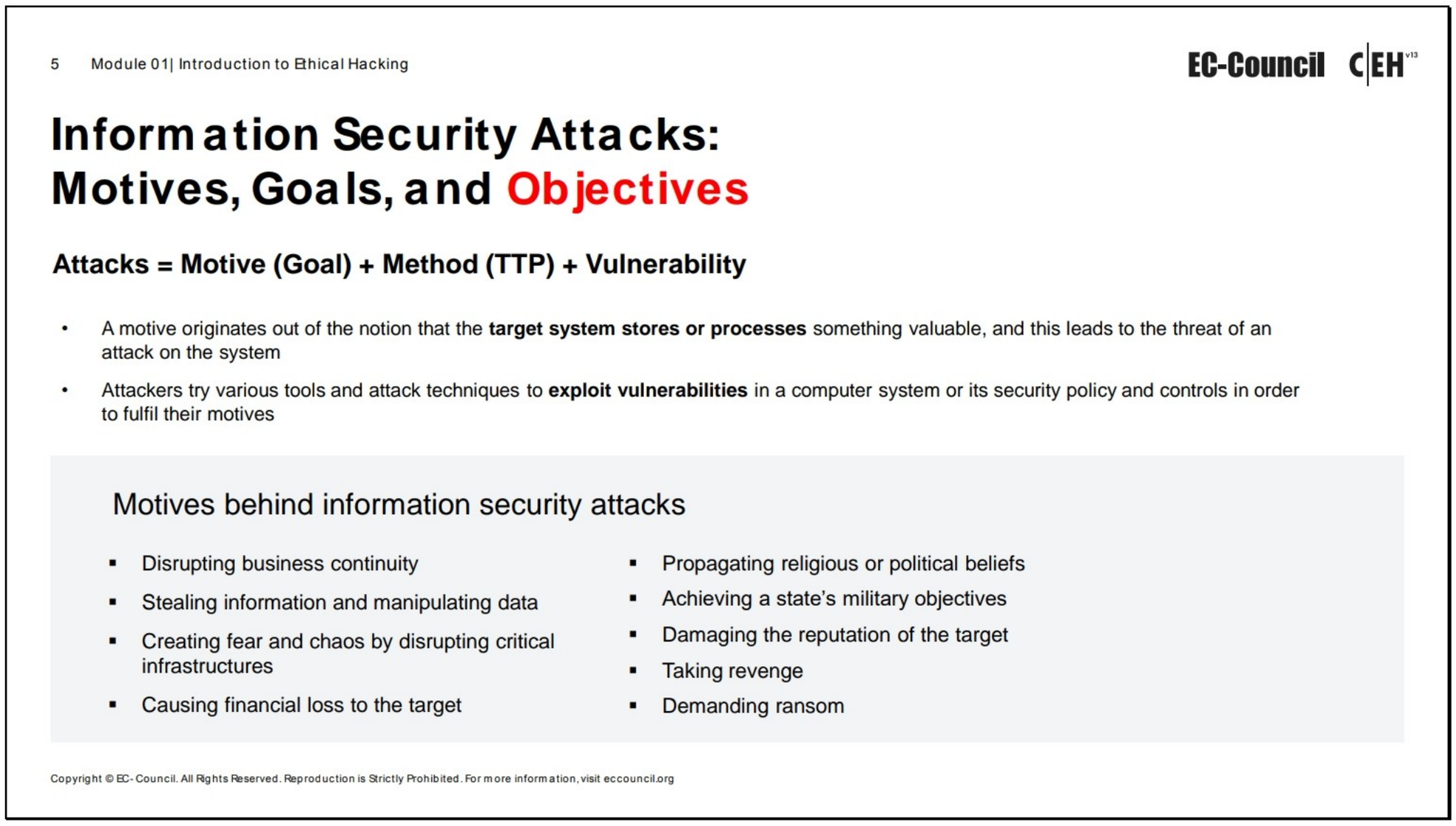
- **Authenticity**

  Authenticity refers to the characteristic of communication, documents, or any data that ensures the quality of being genuine or uncorrupted. The major role of authentication is to confirm that a user is genuine. Controls such as biometrics, smart cards, and digital certificates ensure the authenticity of data, transactions, communications, and documents.

- **Non-Repudiation**

  Non-repudiation is a way to guarantee that the sender of a message cannot later deny having sent the message and that the recipient cannot deny having received the message. Individuals and organizations use digital signatures to ensure non-repudiation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Information Security Attacks: Motives, Goals, and Objectives

An attack is an action that is performed with the intent to breach an IT system's security by exploiting its vulnerabilities. An attack involves an attempt to obtain, edit, remove, destroy, implant, or reveal information without authorized access. It also refers to malicious software or commands that exploit vulnerabilities to cause unanticipated behavior in legitimate software or hardware. Therefore, an attack can be conceptualized as combination of a motive, with a method to perform the attack, which exploits one or more vulnerabilities in the system.

Attacks = Motive (Goal) + Method (TTP) + Vulnerability

Motives (Goals)

Attackers generally have motives (goals), and objectives behind their information security attacks. A motive originates out of the notion that a target system stores or processes something valuable, which leads to the threat of an attack on the system. The purpose of the attack may be to disrupt the target organization's business operations, to steal valuable information for the sake of curiosity, or even to exact revenge. Therefore, these motives or goals depend on the attacker's state of mind, their reason for carrying out such an activity, as well as their resources and capabilities. Once the attacker determines their goal, they can employ various tools, attack techniques, and methods to exploit vulnerabilities in a computer system or security policy and controls.

Motives behind information security attacks

- Disrupt business continuity
- Perform information theft
- Manipulating data

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Create fear and chaos by disrupting critical infrastructures
- Bring financial loss to the target
- Propagate religious or political beliefs
- Achieve a state's military objectives
- Damage the reputation of the target
- Take revenge
- Demand ransom

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

EC-Council CEH v13

Tactics, Techniques, and Procedures (TTPs)

- Attackers attempt various attack techniques to **exploit vulnerabilities** in a computer system or security policy and controls to achieve their motives
- The term Tactics, Techniques, and Procedures (TTPs) refers to the **patterns of activities and methods** associated with specific threat actors or groups of threat actors

Tactics

- "Tactics" is defined as the **strategy** adopted by an attacker to perform the attack from the beginning to the end

Techniques

- "Techniques" is defined as **technical methods used by an attacker** to achieve intermediate results during the attack

Procedures

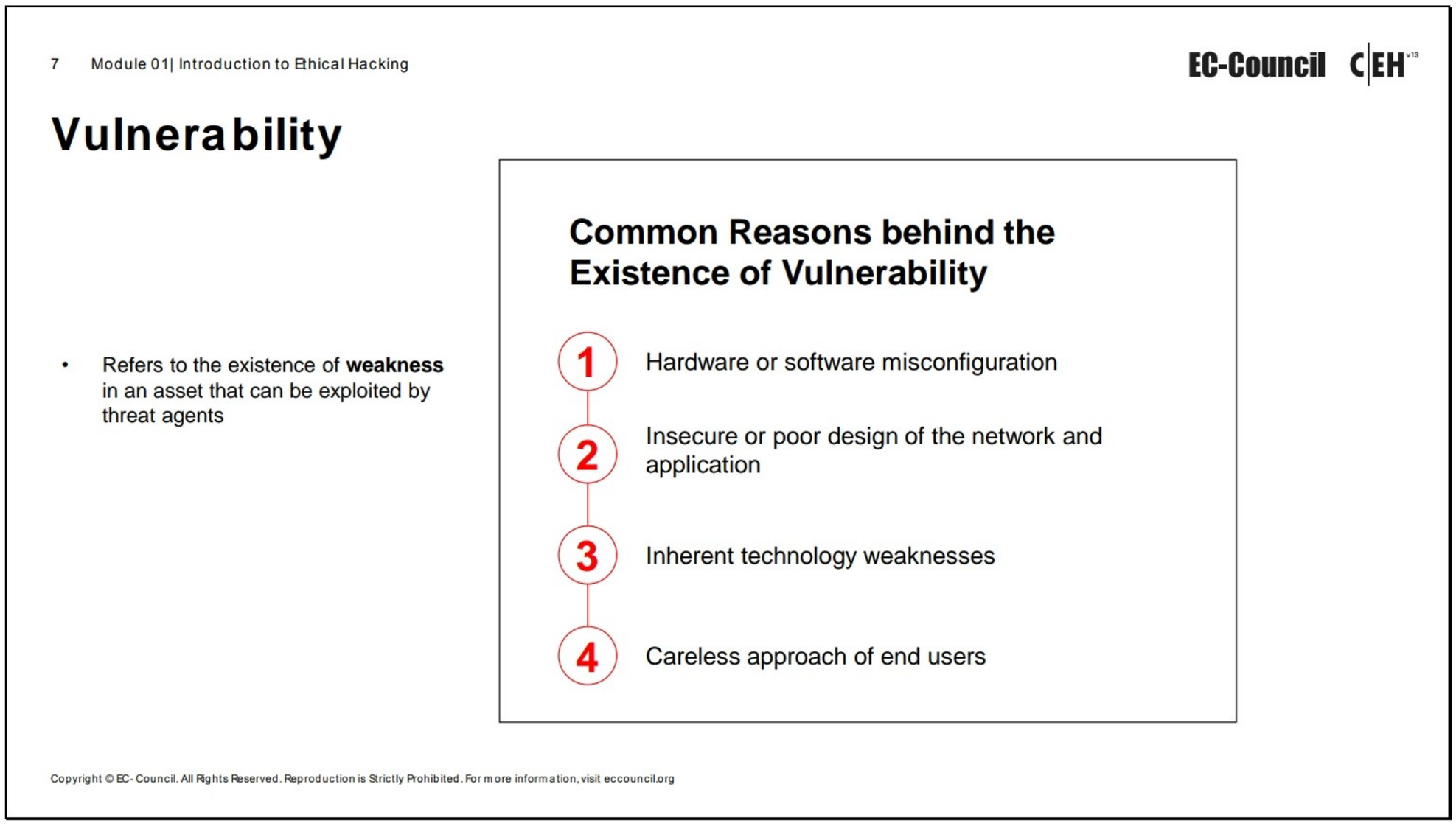
- "Procedure" is defined as a **systematic approach** adopted by threat actors **to launch an attack**

Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Tactics, Techniques, and Procedures (TTPs)

The terms "tactics, techniques, and procedures" refer to the patterns of activities and methods associated with specific threat actors or groups of threat actors. TTPs are helpful in analyzing threats and profiling threat actors and can further be used to strengthen the security infrastructure of an organization. The word "tactics" is defined as a strategy followed by an attacker to perform the attack from the beginning to the end. The word "techniques" is defined as the technical methods used by an attacker to achieve intermediate results during the attack. Finally, the word "procedures" is defined as a systematic approach followed by the threat actors to launch an attack. In order to understand and defend against the threat actors, it is important to understand the TTPs used by adversaries. Understanding the tactics of an attacker helps to predict and detect evolving threats in the early stages. Understanding the techniques used by attackers helps to identify vulnerabilities and implement defensive measures in advance. Lastly, analyzing the procedures used by the attackers helps to identify what the attacker is looking for within the target organization's infrastructure.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Vulnerability

A vulnerability refers to a weakness in the design or implementation of a system that can be exploited to compromise the security of the system. It is frequently a security loophole that enables an attacker to enter the system by bypassing user authentication. There are generally two main causes for vulnerable systems in a network, software or hardware misconfiguration and poor programming practices. Attackers exploit these vulnerabilities to perform various types of attacks on organizational resources.

Common Reasons for the Existence of Vulnerabilities

- **Hardware or software misconfiguration**

  The insecure configuration of the hardware or software in a network can lead to security loopholes. For example, a misconfiguration or the use of an unencrypted protocol may lead to network intrusions, resulting in the leakage of sensitive information. While a misconfiguration of hardware may allow attackers to obtain access to the network or system, a misconfiguration of software may allow attackers to obtain access to applications and data.

- **Insecure or poor design of network and application**

  An improper and insecure design of a network may make it susceptible to various threats and potential data loss. For example, if firewalls, IDS, and virtual private network (VPN) technologies are not implemented securely, they can expose the network to numerous threats.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Inherent technology weaknesses**

  If the hardware or software is not capable of defending the network against certain types of attacks, the network will be vulnerable to those attacks. Certain hardware, applications, or web browsers tend to be prone to attacks such as DoS or man-in-the-middle attacks. For example, systems running old versions of web browsers are prone to distributed attacks. If systems are not updated, a small Trojan attack can force the user to scan and clean the entire storage in the machine, which often leads to data loss.

- **End-user carelessness**

  End-user carelessness considerably impacts network security. Human behavior is fairly susceptible to various types of attacks and can be exploited to effect serious outcomes, including data loss and information leakage. Intruders can obtain sensitive information through various social engineering techniques. The sharing of account information or login credentials by users with potentially malicious entities can lead to the loss of data or exploitation of the information. Connecting systems to an insecure network can also lead to attacks from third parties.

- **Intentional end-user acts**

  Ex-employees who continue to have access to shared drives can misuse them by revealing the company's sensitive information. Such an act is called an intentional end-user act and can lead to heavy data and financial losses for the company.

Examples of Vulnerabilities

The following tables summarize examples of technological and configuration vulnerabilities:

Technological Vulnerabilities	Description
TCP/IP protocol vulnerabilities	▪ HTTP, FTP, ICMP, SNMP, SMTP are inherently insecure
Operating System vulnerabilities	▪ An OS can be vulnerable because: ○ It is inherently insecure ○ It is not patched with the latest updates
Network Device Vulnerabilities	▪ Various network devices such as routers, firewall, and switches can be vulnerable due to: ○ Lack of password protection ○ Lack of authentication ○ Insecure routing protocols ○ Firewall vulnerabilities

Table 1.1: Technological Vulnerabilities

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Configuration Vulnerabilities	Description
User account vulnerabilities	▪ Originating from the insecure transmission of user account details such as usernames and passwords, over the network
System account vulnerabilities	▪ Originating from setting of weak passwords for system accounts
Internet service misconfiguration	▪ Misconfiguring internet services can pose serious security risks. For example, enabling JavaScript and misconfiguring IIS, Apache, FTP, and Terminal services, can create security vulnerabilities in the network
Default password and settings	▪ Leaving the network devices/products with their default passwords and settings
Network device misconfiguration	▪ Misconfiguring the network device

Table 1.2: Configuration Vulnerabilities

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Classification of Attacks

Passive Attacks	• Passive attacks do not tamper with the data and involve intercepting and **monitoring network traffic** and data flow on the target network • Examples include sniffing and eavesdropping
Active Attacks	• Active attacks tamper with the data in transit or **disrupt the communication** or services between the systems to bypass or break into secured systems • Examples include DoS, Man-in-the-Middle, session hijacking, and SQL injection
Close-in Attacks	• Close-in attacks are performed when the attacker is in close physical proximity with the target system or network in order to gather, modify, or **disrupt access** to information • Examples include social engineering such as eavesdropping, shoulder surfing, and dumpster diving
Insider Attacks	• Insider attacks involve using privileged access to **violate rules** or intentionally cause a threat to the organization's information or information systems • Examples include theft of physical devices and planting keyloggers, backdoors, and malware
Distribution Attacks	• Distribution attacks occur when attackers **tamper with hardware** or **software** prior to installation • Attackers tamper with the hardware or software at its source or in transit

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Classification of Attacks

According to IATF, security attacks are classified into five categories: passive, active, close-in, insider, and distribution.

- **Passive Attacks**

  Passive attacks involve intercepting and monitoring network traffic and data flow on the target network and do not tamper with the data. Attackers perform reconnaissance on network activities using sniffers. These attacks are very difficult to detect as the attacker has no active interaction with the target system or network. Passive attacks allow attackers to capture the data or files being transmitted in the network without the consent of the user. For example, an attacker can obtain information such as unencrypted data in transit, clear-text credentials, or other sensitive information that is useful in performing active attacks.

  Examples of passive attacks:

  - Footprinting
  - Sniffing and eavesdropping
  - Network traffic analysis
  - Decryption of weakly encrypted traffic

- **Active Attacks**

  Active attacks tamper with the data in transit or disrupt communication or services between the systems to bypass or break into secured systems. Attackers launch attacks on the target system or network by sending traffic actively that can be detected. These

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

attacks are performed on the target network to exploit the information in transit. They penetrate or infect the target's internal network and gain access to a remote system to compromise the internal network.

Examples of active attacks:

- Denial-of-service (DoS) attack
- Bypassing protection mechanisms
- Malware attacks (such as viruses, worms, ransomware)
- Modification of information
- Spoofing attacks
- Replay attacks
- Password-based attacks
- Session hijacking
- Man-in-the-Middle attack
- DNS and ARP poisoning
- Compromised-key attack
- Firewall and IDS attack
- Profiling
- Arbitrary code execution
- Privilege escalation
- Backdoor access
- Cryptography attacks
- SQL injection
- XSS attacks
- Directory traversal attacks
- Exploitation of application and OS software

- **Close-in Attacks**

  Close-in attacks are performed when the attacker is in close physical proximity with the target system or network. The main goal of performing this type of attack is to gather or modify information or disrupt its access. For example, an attacker might shoulder surf user credentials. Attackers gain close proximity through surreptitious entry, open access, or both.

  Examples of close-in attacks:

  - Social engineering (Eavesdropping, shoulder surfing, dumpster diving, and other methods)

- **Insider Attacks**

  Insider attacks are performed by trusted persons who have physical access to the critical assets of the target. An insider attack involves using privileged access to violate rules or intentionally cause a threat to the organization's information or information systems. Insiders can easily bypass security rules, corrupt valuable resources, and access sensitive information. They misuse the organization's assets to directly affect the confidentiality, integrity, and availability of information systems. These attacks impact the organization's business operations, reputation, and profit. It is difficult to figure out an insider attack.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Examples of insider attacks:

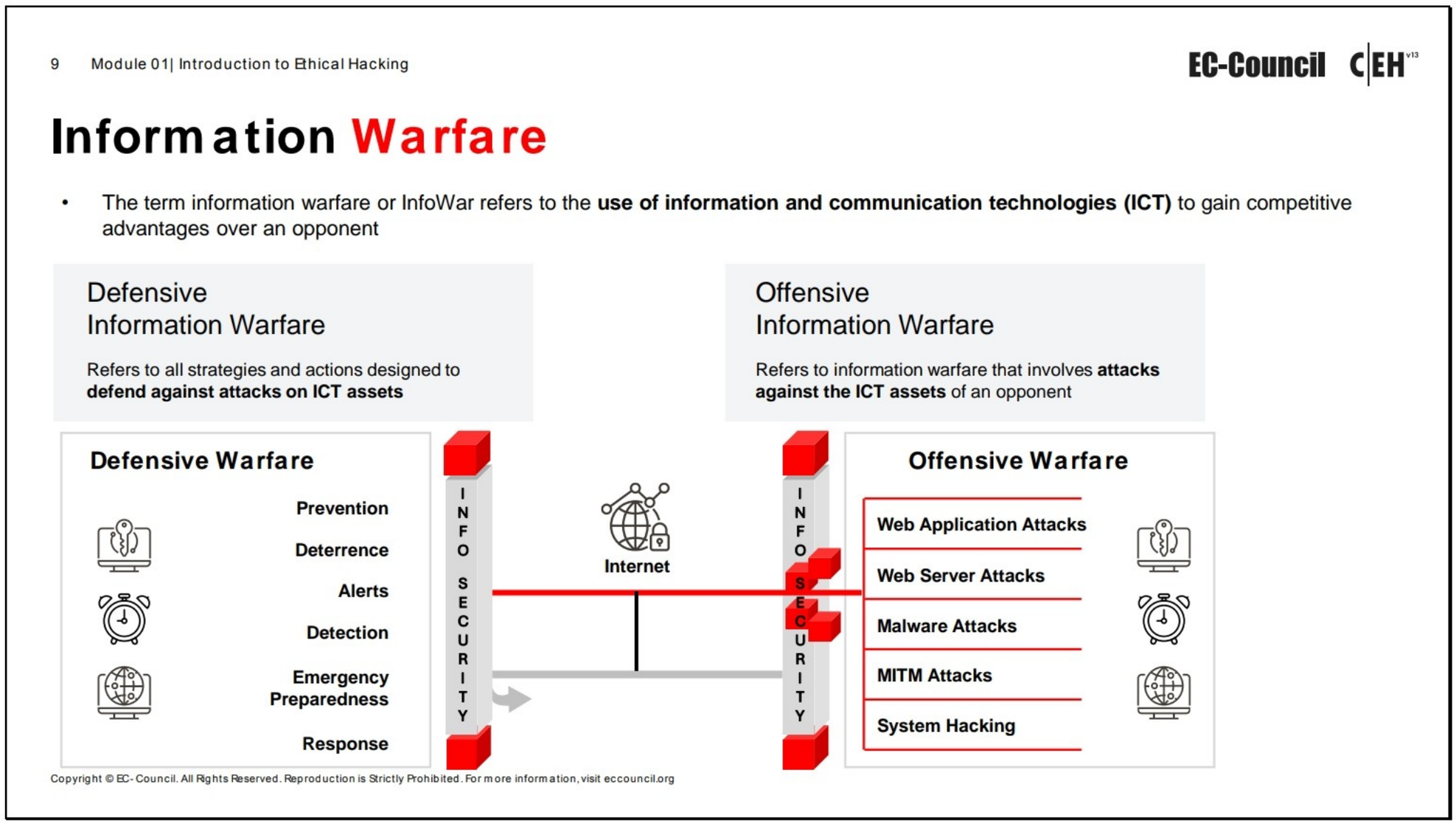
- Eavesdropping and wiretapping
- Theft of physical devices
- Social engineering
- Data theft and spoliation
- Pod slurping
- Planting keyloggers, backdoors, or malware

- **Distribution Attacks**

Distribution attacks occur when attackers tamper with hardware or software prior to installation. Attackers tamper the hardware or software at its source or when it is in transit. Examples of distribution attacks include backdoors created by software or hardware vendors at the time of manufacture. Attackers leverage these backdoors to gain unauthorized access to the target information, systems, or network.

- Modification of software or hardware during production
- Modification of software or hardware during distribution

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Information Warfare

Source: *https://iwar.org.uk*

The term information warfare or InfoWar refers to the use of information and communication technologies (ICT) for competitive advantages over an opponent. Examples of information warfare weapons include viruses, worms, Trojan horses, logic bombs, trap doors, nanomachines and microbes, electronic jamming, and penetration exploits and tools.

Martin Libicki divided information warfare into the following categories:

- **Command and control warfare (C2 warfare)**: In the computer security industry, C2 warfare refers to the impact an attacker possesses over a compromised system or network that they control.
- **Intelligence-based warfare**: Intelligence-based warfare is a sensor-based technology that directly corrupts technological systems. According to Libicki, "intelligence-based warfare" is warfare that consists of the design, protection, and denial of systems that seek sufficient knowledge to dominate the battlespace.
- **Electronic warfare**: According to Libicki, electronic warfare uses radio-electronic and cryptographic techniques to degrade communication. Radio electronic techniques attack the physical means of sending information, whereas cryptographic techniques use bits and bytes to disrupt the means of sending information.
- **Psychological warfare**: Psychological warfare is the use of various techniques such as propaganda and terror to demoralize one's adversary in an attempt to succeed in battle.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Hacker warfare**: According to Libicki, the purpose of this type of warfare can vary from the shutdown of systems, data errors, theft of information, theft of services, system monitoring, false messaging, and access to data. Hackers generally use viruses, logic bombs, Trojan horses, and sniffers to perform these attacks.
- **Economic warfare**: Libicki notes that economic information warfare can affect the economy of a business or nation by blocking the flow of information. This could be especially devastating to organizations that do a lot of business in the digital world.
- **Cyberwarfare**: Libicki defines cyber warfare as the use of information systems against the virtual personas of individuals or groups. It is the broadest of all information warfare. It includes information terrorism, semantic attacks (similar to Hacker warfare, but instead of harming a system, it takes over the system while maintaining the perception that it is operating correctly), and simula-warfare (simulated war, for example, acquiring weapons for mere demonstration rather than actual use).

Each form of information warfare mentioned above consists of both defensive and offensive strategies.

- **Defensive Information Warfare**: Involves all strategies and actions to defend against attacks on ICT assets.
- **Offensive Information Warfare**: Involves attacks against the ICT assets of an opponent.

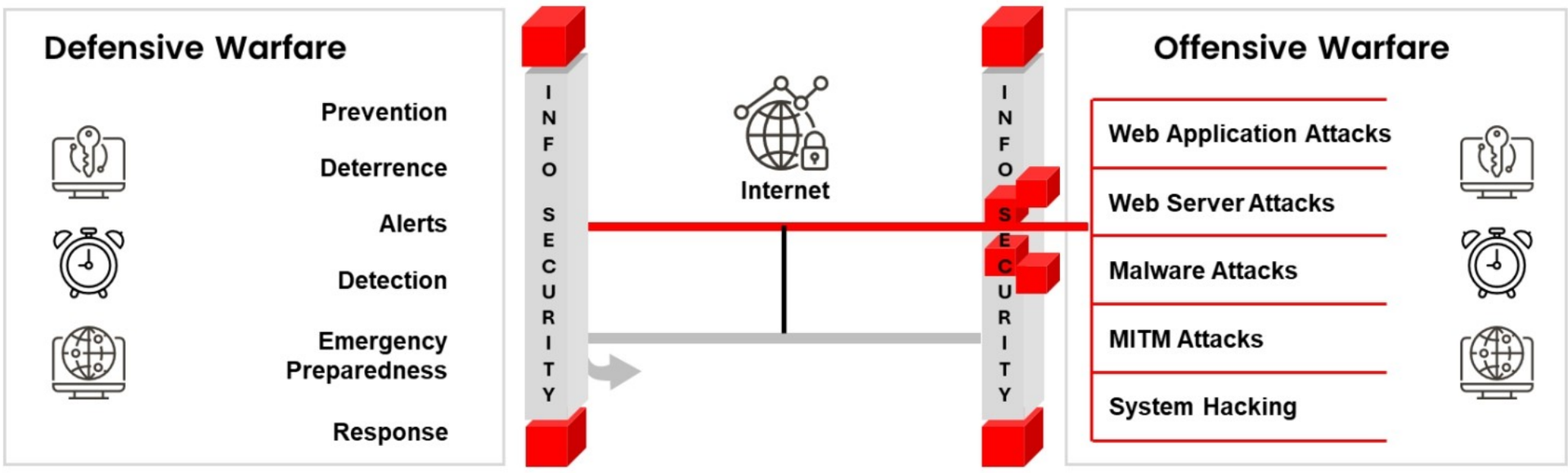
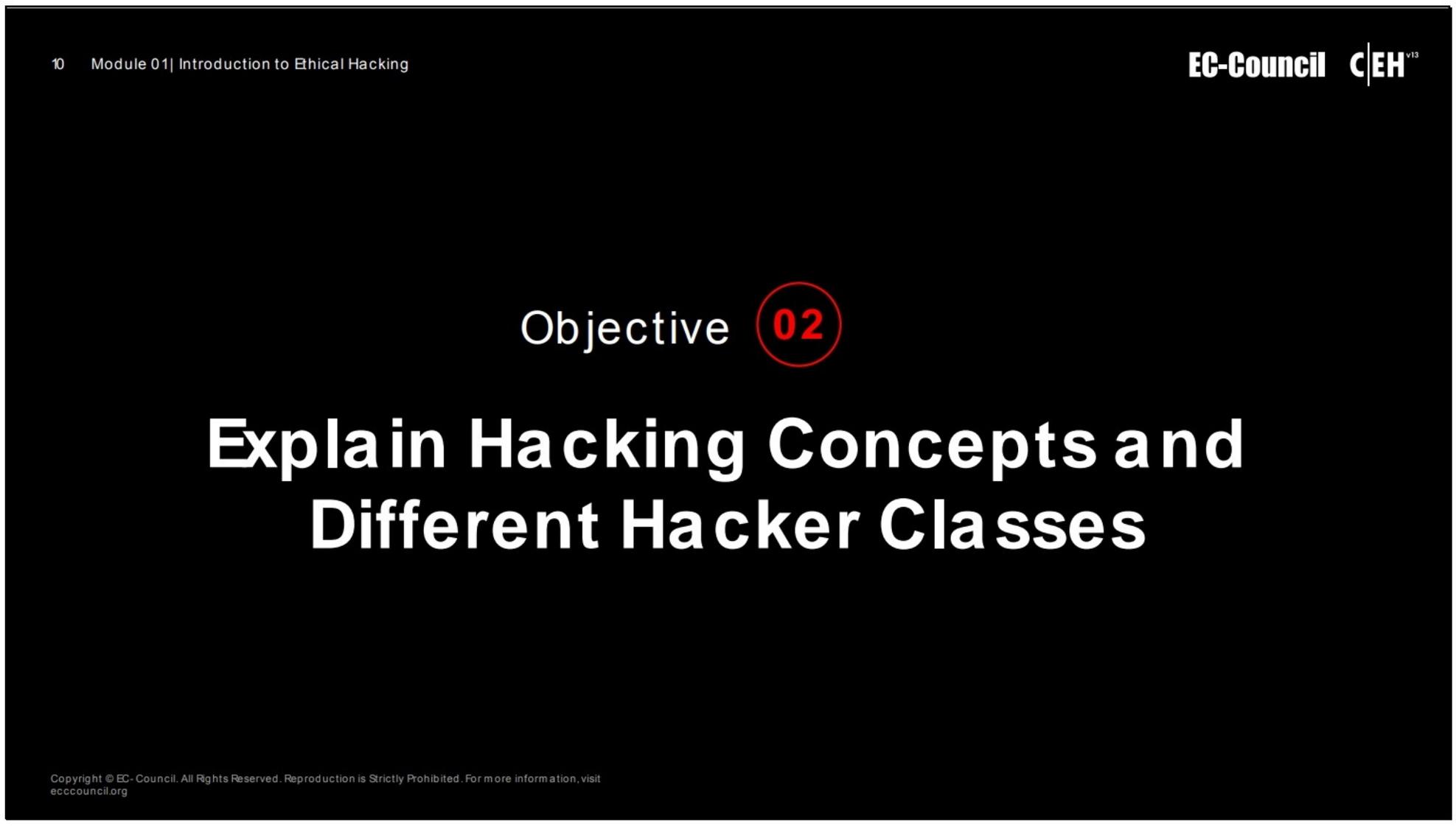


Figure 1.1: Block Diagram of Information Warfare

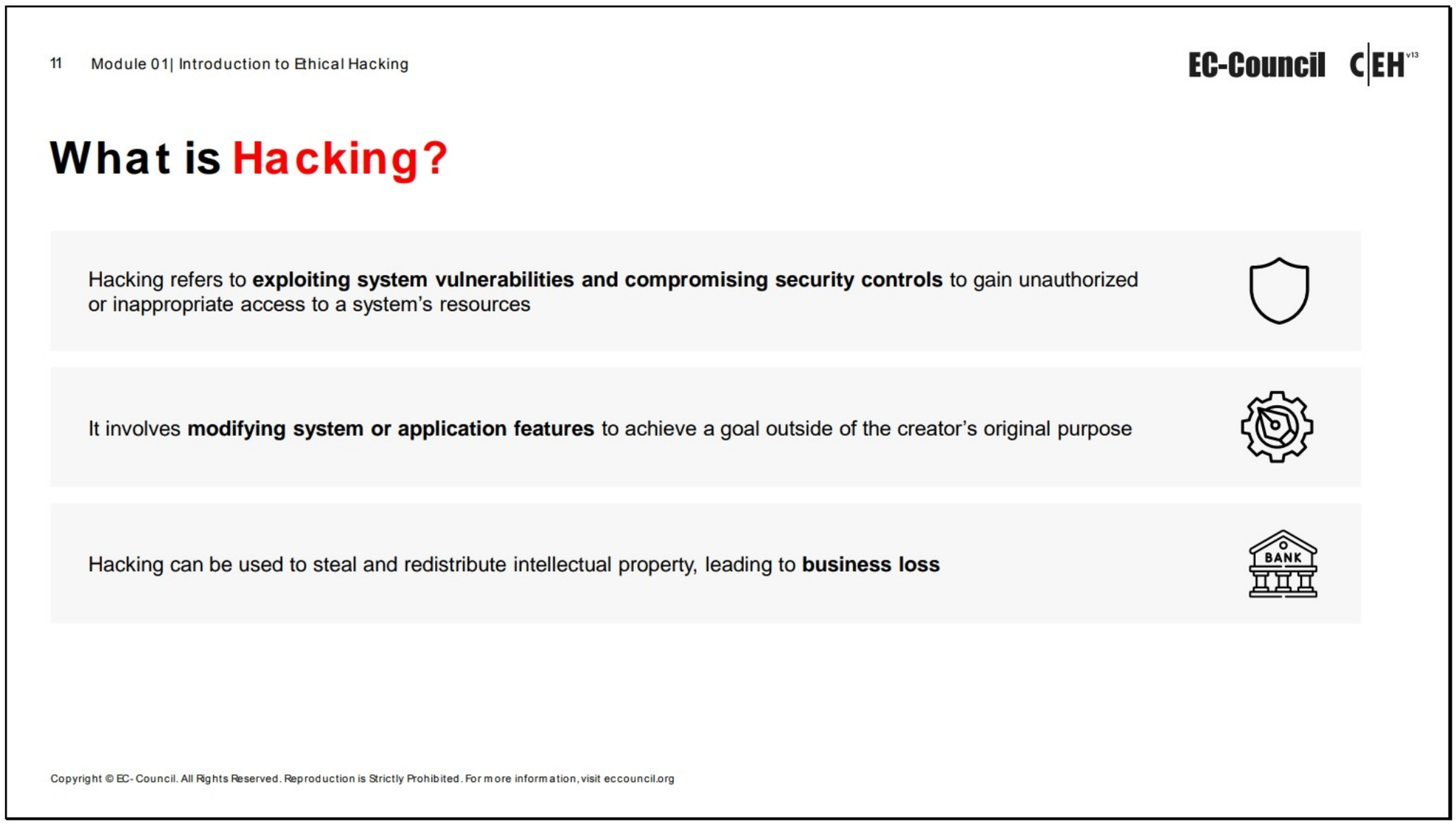
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Hacking Concepts

This section deals with basic concepts of hacking: what is hacking, who is a hacker, and hacker classes.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



What is Hacking?

Hacking in the field of computer security refers to exploiting system vulnerabilities and compromising security controls to gain unauthorized or inappropriate access to system resources. It involves a modifying system or application features to achieve a goal outside its creator's original purpose. Hacking can be done to steal, pilfer, or redistribute intellectual property, thus leading to business loss.

Hacking on computer networks is generally done using scripts or other network programming. Network hacking techniques include creating viruses and worms, performing denial-of-service (DoS) attacks, establishing unauthorized remote access connections to a device using trojans or backdoors, creating botnets, packet sniffing, phishing, and password cracking. The motive behind hacking could be to steal critical information or services, for thrill, intellectual challenge, curiosity, experiment, knowledge, financial gain, prestige, power, peer recognition, vengeance and vindictiveness, among other reasons.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Who is a Hacker?

01

An intelligent individual with **excellent computer skills** who can create and explore computer software and hardware

02

For some hackers, **hacking is a hobby** to see how many computers or networks they can compromise

03

Some hackers' intentions can either be to gain knowledge or to **probe and do illegal things**

Some hack with **malicious intent** such as to steal business data, credit card information, social security numbers, email passwords, and other sensitive data

Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Who is a Hacker?

A hacker is a person who breaks into a system or network without authorization to destroy, steal sensitive data, or perform malicious attacks. A hacker is an intelligent individual with excellent computer skills, along with the ability to create and explore the computer's software and hardware. Usually, a hacker is a skilled engineer or programmer with enough knowledge to discover vulnerabilities in a target system. They generally have subject expertise and enjoy learning the details of various programming languages and computer systems.

For some hackers, hacking is a hobby to see how many computers or networks they can compromise. Their intention can either be to gain knowledge or to poke around to do illegal things. Some hack with malicious intent behind their escapades, like stealing business data, credit card information, social security numbers, and email passwords.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Hacker and their Motivations

Hacker Classes	Background	Motivations	Cyber Activity	Potential Targets
Script Kiddies	Inexperienced, often young individuals using pre-made scripts or tools without understanding them	Thrill, recognition, fun	Running simple attacks like DDoS, defacing websites	Small websites, online games, forums
White Hat Hackers	Professionals in cybersecurity	Improving security, salary, reputation	Conducting penetration tests, vulnerability assessments	Corporations, government agencies
Black Hat Hackers	Individuals with extraordinary computing skills	Financial gain, data theft, causing harm	Malware creation, phishing, ransomware, data breaches	Financial institutions, individuals, enterprises
Gray Hat Hackers	Skilled hackers operating between ethical and unethical lines	Recognition, curiosity, financial gain	Vulnerability discovery without permission, sometimes reported	Various, including high-profile organizations
Hacktivists	Politically or socially motivated individuals or groups	Promoting a cause, social justice	DDoS attacks, defacing websites, data leaks	Government sites, corporations, political groups
State-Sponsored Hackers	Highly trained professionals working for government agencies	National security, espionage, political objectives	Cyber espionage, infrastructure sabotage, data theft	Other nations' government agencies, corporations

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Hacker and their Motivations (Cont'd)

Hacker Classes	Background	Motivations	Cyber Activity	Potential Targets
Cyber Terrorists	Extremists using cyber attacks to promote political or religious beliefs	Spreading fear, political or ideological goals	Cyber attacks on critical infrastructure, spreading propaganda	Critical infrastructure, public services
Corporate Spies (Industrial Spies)	Individuals hired by companies to gather intelligence on competitors	Financial gain, competitive advantage	Industrial espionage, data theft, spying	Competitor companies
Blue Hat Hackers	Security professionals hired temporarily to test systems before product release	Improving product security, reputation	Conducting security audits, penetration testing	Technology companies, software firms
Red Hat Hackers	Vigilantes targeting black hat hackers using aggressive methods	Cyber justice, disrupting malicious activities	Hacking black hat infrastructure, disabling malicious networks	Cybercriminal groups, black hat hackers
Green Hat Hackers	Newcomers eager to learn hacking skills, often participating in online forums and communities	Learning, curiosity, recognition	Learning hacking techniques, experimenting with simple attacks	Various, typically low-risk targets

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Hacker and their Motivations

Hackers usually fall into one of the following categories, according to their activities:

- **Script Kiddies**: Script kiddies are unskilled hackers who compromise systems by running scripts, tools, and software developed by real hackers. They usually focus on the quantity rather than the quality of the attacks that they initiate. They do not have a

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

specific target or goal in performing the attack and simply aim to gain popularity or prove their technical skills.

- **White Hat Hackers**: White hats or penetration testers are individuals who use their hacking skills for defensive purposes. These days, almost every organization has security analysts who are knowledgeable about hacking countermeasures, which can secure its network and information systems against malicious attacks. They have permission from the system owner.
- **Black Hat Hackers**: Black hats are individuals who use their extraordinary computing skills for illegal or malicious purposes. This category of hacker is often involved in criminal activities. They are also known as crackers.
- **Gray Hat Hackers**: Gray hats are the individuals who work both offensively and defensively at various times. Gray hats might help hackers to find various vulnerabilities in a system or network and, at the same time, help vendors to improve products (software or hardware) by checking limitations and making them more secure.
- **Hacktivists**: Hacktivism is a form of activism in which hackers break into government or corporate computer systems as an act of protest. Hacktivists use hacking to increase awareness of their social or political agendas, as well as to boost their own reputations in both online and offline arenas. They promote a political agenda especially by using hacking to deface or disable websites. In some incidents, hacktivists may also obtain and reveal confidential information to the public. Common hacktivist targets include government agencies, financial institutions, multinational corporations, and any other entity that they perceive as a threat. Irrespective of hacktivists' intentions, the gaining of unauthorized access is a crime.
- **State-Sponsored Hackers**: State-sponsored hackers are skilled individuals having expertise in hacking and are employed by the government to penetrate, gain top-secret information from, and damage the information systems of other government or military organizations. The main aim of these threat actors is to detect vulnerabilities in and exploit a nation's infrastructure and gather intelligence or sensitive information.
- **Cyber Terrorists**: Cyber terrorists are individuals with a wide range of skills, motivated by religious or political beliefs, to create fear of large-scale disruption of computer networks.
- **Corporate Spies (Industrial Spies)**: Industrial spies are individuals who perform corporate espionage by illegally spying on competitor organizations. They focus on stealing critical information such as blueprints, formulas, product designs, and trade secrets. These threat actors use advanced persistent threats (APTs) to penetrate a network and can also stay undetected for years. In some cases, they may use social engineering techniques to steal sensitive information such as development plans and marketing strategies of the target company, which can result in financial loss to that company.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Blue Hat Hackers:** Blue hats are contract-based cybersecurity professionals hired by organizations to evaluate systems or software for vulnerabilities. They conduct security assessments, penetration testing, and vulnerability analyses to ensure that weaknesses are addressed before malicious actors could exploit them.
- **Red Hat Hackers:** Red hats adopt aggressive tactics, such as black hat hackers, with the intent of neutralizing threats before damaging resources. They not only identify and report vulnerabilities but also take active measures to destroy black-hat activities, often going beyond mere defense to prevent security breaches. Their approach is more proactive, similar to white hat hackers, but they do not follow ethical rules to take down black hat hackers.
- **Green Hat Hackers:** Green hat hackers are individuals motivated by the desire to become skilled professionals in the field of cybersecurity. They often spend time studying and practicing ethical hacking aiming to contribute to security efforts rather than causing harm.
- **Suicide Hackers**: Suicide hackers are individuals who aim to bring down critical infrastructure for a "cause" and are not worried about facing jail terms or any other kind of punishment. Suicide hackers are similar to suicide bombers who sacrifice their life for an attack and are thus not concerned with the consequences of their actions.
- **Hacker Teams:** A hacker team is a consortium of skilled hackers having their own resources and funding. They work together in synergy for researching state-of-the-art technologies. These threat actors can also detect vulnerabilities, develop advanced tools, and execute attacks with proper planning.
- **Insiders:** An insider is any employee (trusted person) who has access to critical assets of an organization. An insider threat involves the use of privileged access to violate rules or intentionally cause harm to the organization's information or information systems. Insiders can easily bypass security rules, corrupt valuable resources, and access sensitive information. Generally, insider threats arise from disgruntled employees, terminated employees, and undertrained staff members.
- **Criminal Syndicates:** Criminal syndicates are groups of individuals or communities that are involved in organized, planned, and prolonged criminal activities. They exploit victims from distinct jurisdictions on the Internet, making them difficult to locate. The main aim of these threat actors is to illegally embezzle money by performing sophisticated cyber-attacks and money-laundering activities.
- **Organized Hackers:** Organized hackers are a group of hackers working together in criminal activities. Such groups are well organized in a hierarchical structure consisting of leaders and workers. The group can also have multiple layers of management. These hackers are miscreants or hardened criminals who do not use their own devices; rather, they use rented devices or botnets and crimeware services to perform various cyber-attacks to pilfer money from victims and sell their information to the highest bidder. They can also swindle intellectual property, trade secrets, and marketing plans; covertly penetrate the target network; and remain undetected for long periods.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Here is a table that lists different types of hackers, their backgrounds, motivations, gains, cyber/hacking activities, and potential targets:

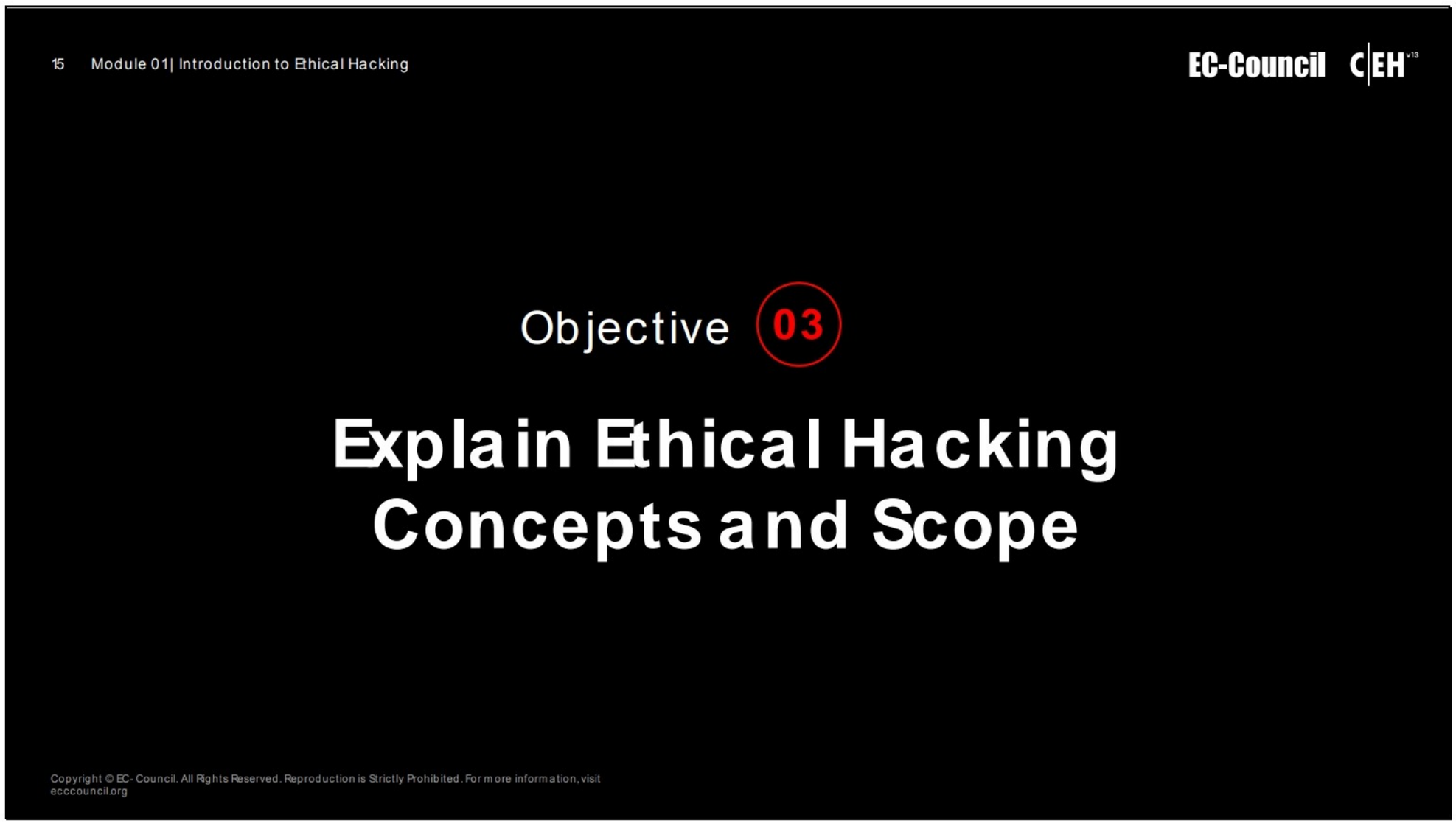
Hacker Classes	Background	Motivations	Cyber Activity	Potential Targets
Script Kiddies	Inexperienced, often young individuals using pre-made scripts or tools without understanding them	Thrill, recognition, fun	Running simple attacks like DDoS, defacing websites	Small websites, online games, forums
White Hat Hackers	Professionals in cybersecurity	Improving security, salary, reputation	Conducting penetration tests, vulnerability assessments	Corporations, government agencies
Black Hat Hackers	Individuals with extraordinary computing skills	Financial gain, data theft, causing harm	Malware creation, phishing, ransomware, data breaches	Financial institutions, individuals, enterprises
Gray Hat Hackers	Skilled hackers operating between ethical and unethical lines	Recognition, curiosity, financial gain	Vulnerability discovery without permission, sometimes reported	Various, including high-profile organizations
Hacktivists	Politically or socially motivated individuals or groups	Promoting a cause, social justice	DDoS attacks, defacing websites, data leaks	Government sites, corporations, political groups
State-Sponsored Hackers	Highly trained professionals working for government agencies	National security, espionage, political objectives	Cyber espionage, infrastructure sabotage, data theft	Other nations' government agencies, corporations
Cyber Terrorists	Extremists using cyber attacks to promote political or religious beliefs	Spreading fear, political or ideological goals	Cyber attacks on critical infrastructure, spreading propaganda	Critical infrastructure, public services
Corporate Spies (Industrial Spies)	Individuals hired by companies to gather intelligence on competitors	Financial gain, competitive advantage	Industrial espionage, data theft, spying	Competitor companies

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Blue Hat Hackers	Security professionals hired temporarily to test systems before product release	Improving product security, reputation	Conducting security audits, penetration testing	Technology companies, software firms
Red Hat Hackers	Vigilantes targeting black hat hackers using aggressive methods	Cyber justice, disrupting malicious activities	Hacking black hat infrastructure, disabling malicious networks	Cybercriminal groups, black hat hackers
Green Hat Hackers	Newcomers eager to learn hacking skills, often participating in online forums and communities	Learning, curiosity, recognition	Learning hacking techniques, experimenting with simple attacks	Various, typically low-risk targets

Table 1.3: Types of hackers

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Ethical Hacking Concepts

An ethical hacker follows processes similar to those of a malicious hacker. The steps to gain and maintain access to a computer system are similar irrespective of the hacker's intentions.

This section provides an overview of ethical hacking, why ethical hacking is necessary, the scope and limitations of ethical hacking, and the skills of an ethical hacker.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

What is Ethical Hacking?

Ethical hacking is the practice of employing computer and network skills in order to assist organizations in testing their network security for possible loopholes and vulnerabilities. White Hats (also known as security analysts or ethical hackers) are the individuals or experts who perform ethical hacking. Nowadays, most organizations (such as private companies, universities, and government organizations) are hiring White Hats to assist them in enhancing their cybersecurity. They perform hacking in ethical ways, with the permission of the network or system owner and without the intention to cause harm. Ethical hackers report all vulnerabilities to the system and network owner for remediation, thereby increasing the security of an organization's information system. Ethical hacking involves the use of hacking tools, tricks, and techniques typically used by an attacker to verify the existence of exploitable vulnerabilities in system security.

Today, the term hacking is closely associated with illegal and unethical activities. There is continuing debate as to whether hacking can be ethical or not, given the fact that unauthorized access to any system is a crime. Consider the following definitions:

- The noun "hacker" refers to a person who enjoys learning the details of computer systems and stretching their capabilities.
- The verb "to hack" describes the rapid development of new programs or the reverse engineering of existing software to make it better or more efficient in new and innovative ways.
- The terms "cracker" and "attacker" refer to persons who employ their hacking skills for offensive purposes.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

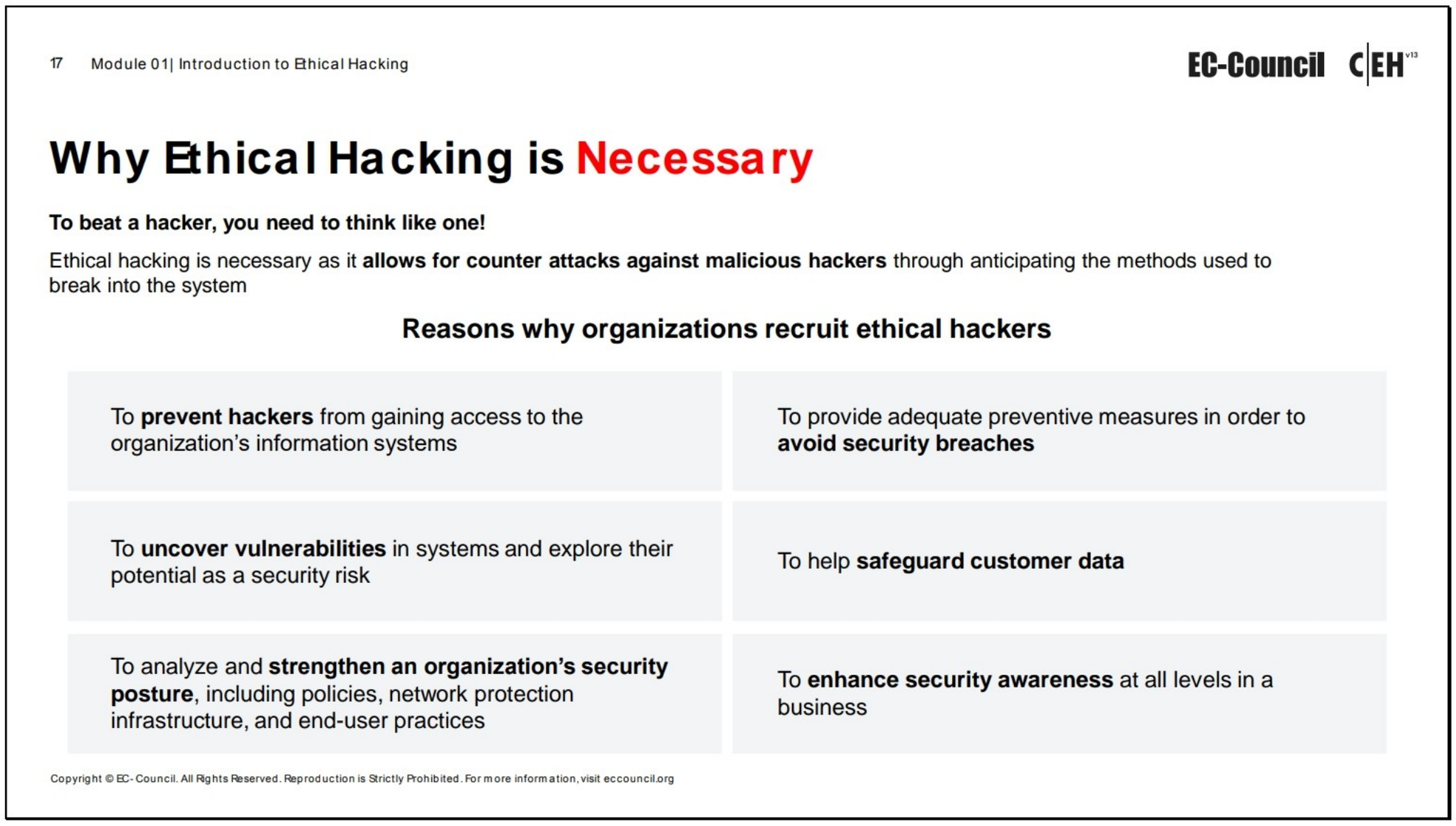
- The term "ethical hacker" refers to security professionals who employ their hacking skills for defensive purposes.

Most companies employ IT professionals to audit their systems for known vulnerabilities. Although this is a beneficial practice, crackers are usually more interested in using newer, lesser-known vulnerabilities, and so these by-the-numbers system audits do not suffice. A company needs someone who can think like a cracker, keep up with the newest vulnerabilities and exploits, and recognize potential vulnerabilities where others cannot. This is the role of the ethical hacker.

Ethical hackers usually employ the same tools and techniques as hackers, with the important exception that they do not damage the system. They evaluate system security, update the administrators regarding any discovered vulnerabilities, and recommend procedures for patching those vulnerabilities.

The important distinction between ethical hackers and crackers is consent. Crackers attempt to gain unauthorized access to systems, while ethical hackers are always completely open and transparent about what they are doing and how they are doing it. Ethical hacking is, therefore, always legal.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Why Ethical Hacking is Necessary

As technology is growing at a faster pace, so is the growth in the risks associated with it. To beat a hacker, it is necessary to think like one!

Ethical hacking is necessary as it allows to counter attacks from malicious hackers by anticipating methods used by them to break into a system. Ethical hacking helps to predict various possible vulnerabilities well in advance and rectify them without incurring any kind of outside attack. As hacking involves creative thinking, vulnerability testing, and security audits alone cannot ensure that the network is secure. To achieve security, organizations must implement a "defense-in-depth" strategy by penetrating their networks to estimate and expose vulnerabilities.

Reasons why organizations recruit ethical hackers

- To prevent hackers from gaining access to the organization's information systems
- To uncover vulnerabilities in systems and explore their potential as a risk
- To analyze and strengthen an organization's security posture, including policies, network protection infrastructure, and end-user practices
- To provide adequate preventive measures in order to avoid security breaches
- To help safeguard the customer data
- To enhance security awareness at all levels in a business

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

An ethical hacker's evaluation of a client's information system security seeks to answer three basic questions:

1. **What can an attacker see on the target system?**

   Normal security checks by system administrators will often overlook vulnerabilities. The ethical hacker has to think about what an attacker might see during the reconnaissance and scanning phases of an attack.

2. **What can an intruder do with that information?**

   The ethical hacker must discern the intent and purpose behind attacks to determine appropriate countermeasures. During the gaining-access and maintaining-access phases of an attack, the ethical hacker needs to be one step ahead of the hacker in order to provide adequate protection.

3. **Are the attackers' attempts being noticed on the target systems?**

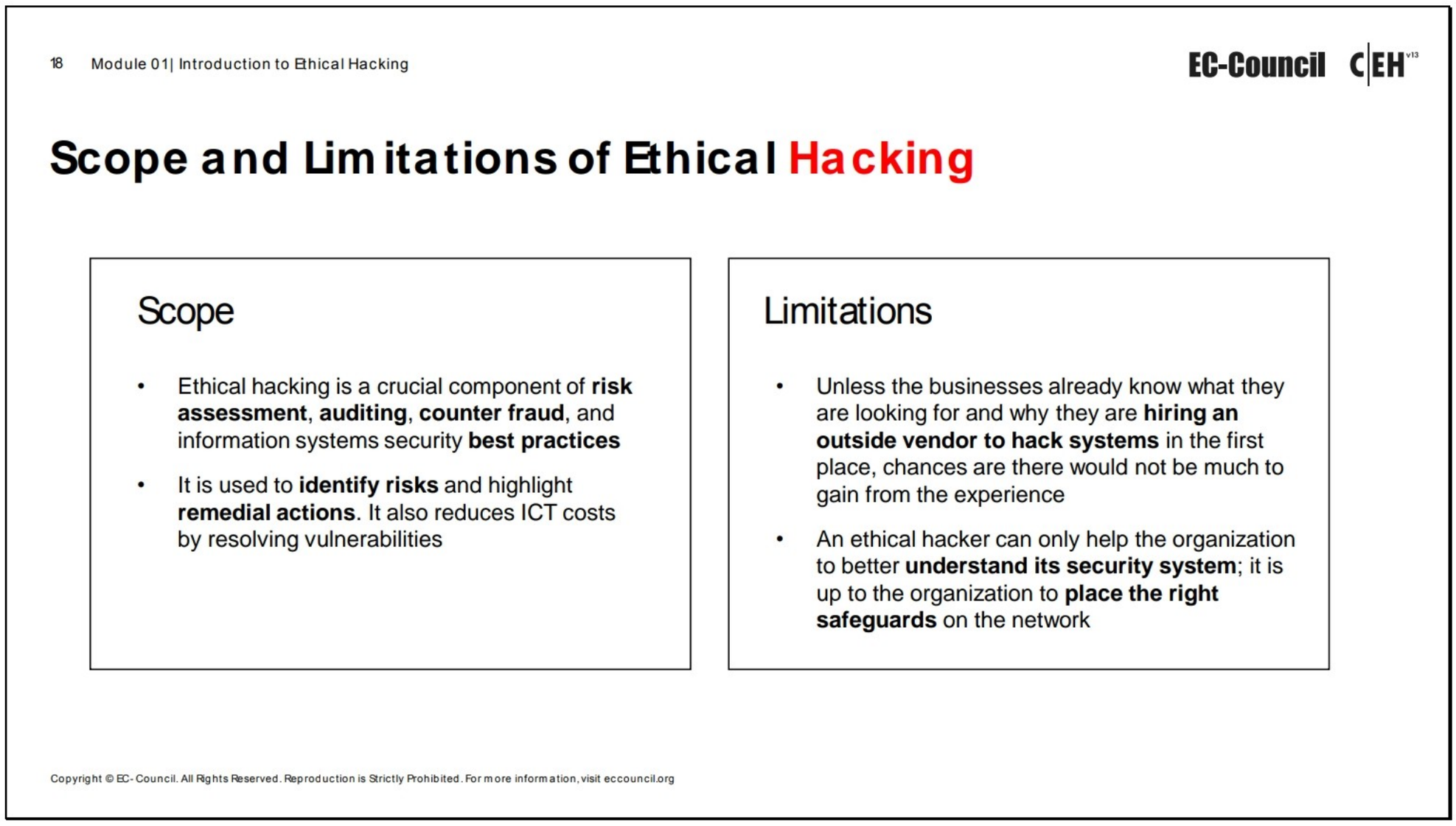
   Sometimes attackers will try to breach a system for days, weeks, or even months. Other times they will gain access but will wait before doing anything damaging. Instead, they will take the time to assess the potential use of exposed information. During the reconnaissance and covering tracks phases, the ethical hacker should notice and stop the attack.

After carrying out attacks, hackers may clear their tracks by modifying log files and creating backdoors, or by deploying trojans. Ethical hackers must investigate whether such activities have been recorded and what preventive measures have been taken. This not only provides them with an assessment of the attacker's proficiency but also gives them insight into the existing security measures of the system being evaluated. The entire process of ethical hacking and subsequent patching of discovered vulnerabilities depends on questions such as:

- What is the organization trying to protect?
- Against whom or what are they trying to protect it?
- Are all the components of the information system adequately protected, updated, and patched?
- How much time, effort, and money is the client willing to invest to gain adequate protection?
- Do the information security measures comply with industry and legal standards?

Sometimes, in order to save on resources or prevent further discovery, the client might decide to end the evaluation after the first vulnerability is found; therefore, it is important that the ethical hacker and the client work out a suitable framework for investigation beforehand. The client must be convinced of the importance of these security exercises through concise descriptions of what is happening and what is at stake. The ethical hacker must also remember to convey to the client that it is never possible to guard systems completely, but that they can always be improved.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Scope and Limitations of Ethical Hacking

Security experts broadly categorize computer crimes into two categories: crimes facilitated by a computer and those in which the computer is the target.

Ethical hacking is a structured and organized security assessment, usually as part of a penetration test or security audit, and is a crucial component of risk assessment, auditing, counter fraud, and information systems security best practices. It is used to identify risks and highlight remedial actions. It is also used to reduce Information and Communications Technology (ICT) costs by resolving vulnerabilities.

Ethical hackers determine the scope of the security assessment according to the client's security concerns. Many ethical hackers are members of a "Tiger Team." A tiger team works together to perform a full-scale test covering all aspects of the network, as well as physical and system intrusion.

An ethical hacker should know the penalties of unauthorized hacking into a system. No ethical hacking activities associated with a network-penetration test or security audit should begin before receiving a signed legal document giving the ethical hacker express permission to perform the hacking activities from the target organization. Ethical hackers must be judicious with their hacking skills and recognize the consequences of misusing those skills.

The ethical hacker must follow certain rules to fulfill their ethical and moral obligations. They must do the following:

- Gain authorization from the client and have a signed contract giving the tester permission to perform the test.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

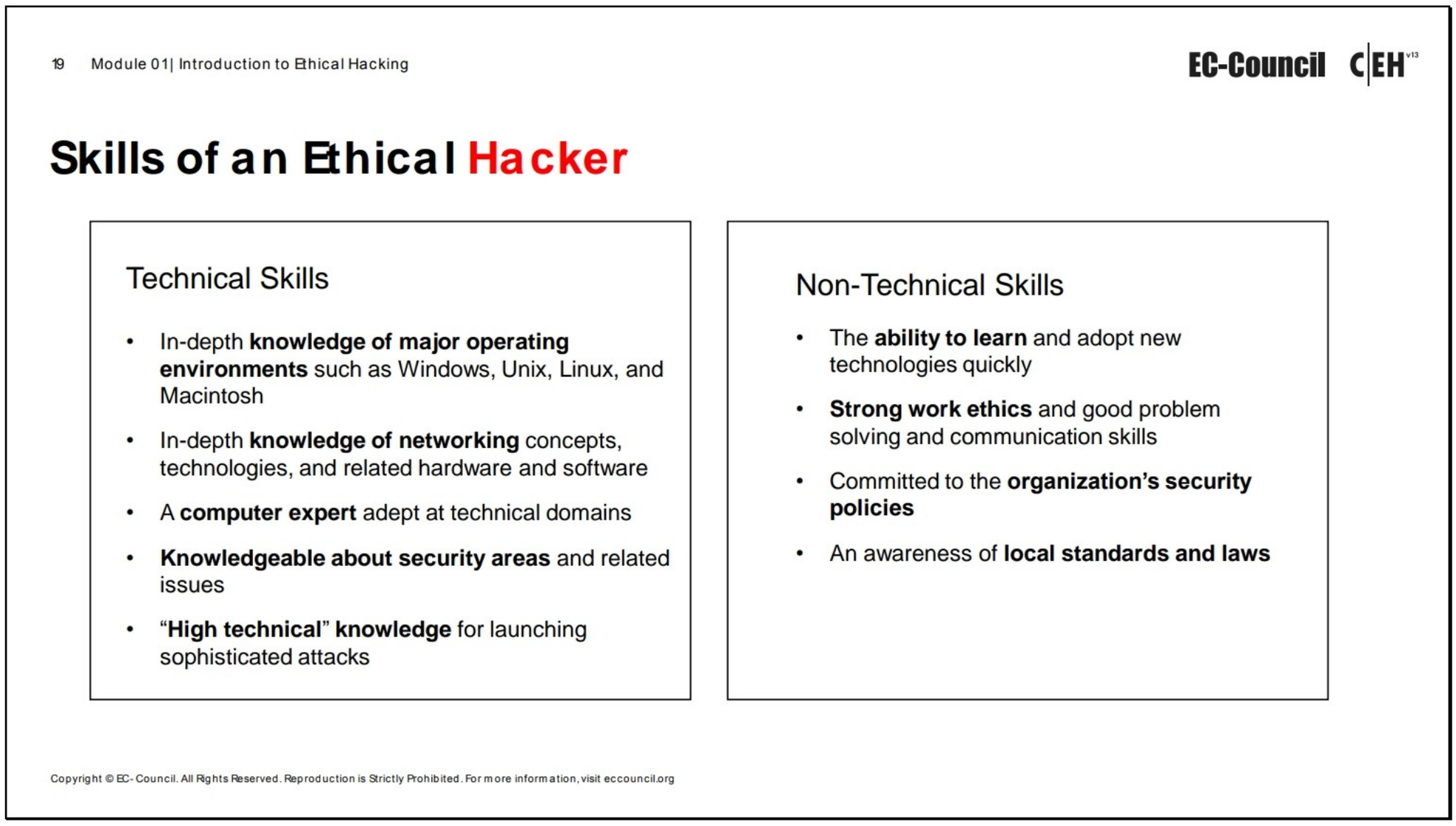
- Maintain confidentiality when performing the test and follow a Nondisclosure Agreement (NDA) with the client for the confidential information disclosed during the test. The information gathered might contain sensitive information, and the ethical hacker must not disclose any information about the test or the confidential company data to a third party.
- Perform the test up to but not beyond the agreed-upon limits. For example, ethical hackers should perform DoS attacks only if they have previously agreed upon this with the client. Loss of revenue, goodwill, and worse consequences could befall an organization whose servers or applications are unavailable to customers because of the testing.

The following steps provide a framework for performing a security audit of an organization, which will help in ensuring that the test is organized, efficient, and ethical:

- Talk to the client and discuss the needs to be addressed during the testing
- Prepare and sign NDA documents with the client
- Organize an ethical hacking team and prepare the schedule for testing
- Conduct the test
- Analyze the results of the testing and prepare a report
- Present the report findings to the client

However, there are limitations too. Unless the businesses first know what they are looking for and why they are hiring an outside vendor to hack their systems in the first place, chances are there would not be much to gain from experience. An ethical hacker, thus, can only help the organization to better understand its security system. It is up to the organization to place the right safeguards on the network.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Skills of an Ethical Hacker

It is essential for an ethical hacker to acquire the knowledge and skills to become an expert hacker and to use this knowledge in a lawful manner. The technical and non-technical skills to be a good ethical hacker are discussed below:

- **Technical Skills**
  - In-depth knowledge of major operating environments, such as Windows, Unix, Linux, and Macintosh
  - In-depth knowledge of networking concepts, technologies, and related hardware and software
  - A computer expert adept at technical domains
  - The knowledge of security areas and related issues
  - High technical knowledge of how to launch sophisticated attacks
- **Non-Technical Skills**
  - The ability to quickly learn and adapt new technologies
  - A strong work ethic and good problem solving and communication skills
  - Commitment to an organization's security policies
  - An awareness of local standards and laws

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

AI- Driven Ethical Hacking

Advancements in AI have led to more sophisticated cyber threats, as **hackers increasingly use AI-driven tools** to enhance and automate their attacks, **presenting significant challenges to cybersecurity**

AI-driven ethical hacking is a **modern approach to cybersecurity** where artificial intelligence (AI) technologies are used to **enhance the capabilities of ethical hackers**

Leveraging AI in ethical hacking enables professionals to **anticipate emerging threats**, **outpace malicious actors**, and **proactively mitigate risks**

AI-driven ethical hacking involves use of AI technologies such as **AI algorithms**, **machine learning models**, and **automation frameworks** to facilitate and automate ethical hacking efforts

Benefits: **1. Efficiency** **2. Accuracy** **3. Scalability** **4. Cost-Effectiveness**

Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

AI-Driven Ethical Hacking

In today's rapidly evolving landscape, artificial intelligence (AI) has emerged as a transformative force across diverse fields, shaping various sectors, revolutionizing processes, and enhancing efficiency. With the advancement of AI, cyberthreats have become more sophisticated. Hackers are increasingly leveraging AI-driven tools and techniques to automate and augment hacking attempts, posing significant challenges to cybersecurity.

AI-driven ethical hacking is a modern approach to cybersecurity where artificial intelligence (AI) technologies are used to enhance the capabilities of ethical hackers. Ethical hacking, also known as penetration testing, involves identifying and exploiting vulnerabilities in a system to improve security. Ethical hacking is more efficient, scalable, and effective when combined with AI.

This strategic adoption of AI technologies presents a transformative opportunity for ethical hackers to enhance their capabilities, strengthen their cybersecurity defenses, and effectively mitigate emerging cyber threats. Using AI technologies in ethical hacking endeavors, ethical hackers empower themselves to stay ahead of malicious actors, anticipate evolving attack vectors, and proactively mitigate risks.

AI-driven ethical hacking involves the use of AI technologies, such as AI algorithms, machine learning models, and automation frameworks, to facilitate and automate ethical hacking efforts. By embracing AI-driven approaches, ethical hackers can not only enhance the efficiency and efficacy of their cybersecurity efforts but also contribute to fostering a safer and more resilient digital ecosystem.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Benefits

- **Efficiency**: AI can quickly process large amounts of data, making the ethical hacking process faster and more efficient.
- **Accuracy**: AI reduces the likelihood of human error and increases the accuracy of vulnerability assessments.
- **Scalability**: AI-driven solutions can be scaled to handle the growing complexity and volume of cyberthreats.
- **Cost-Effectiveness**: Automation and efficiency gains can reduce the overall costs of cybersecurity.

Applications of AI-Driven Ethical Hacking

- **Network Security**: Monitoring network traffic for suspicious activities and potential breaches.
- **Application Security**: Testing Web and mobile applications for vulnerabilities using AI-powered tools.
- **Cloud Security**: Identifying and mitigating risks in cloud environments.
- **IoT Security**: Protecting Internet of Things (IoT) devices from cyber threats.
- **Threat Intelligence**: Gathering and analyzing threat data to provide actionable insights.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

How AI-Driven Ethical Hacking Helps Ethical Hacker?

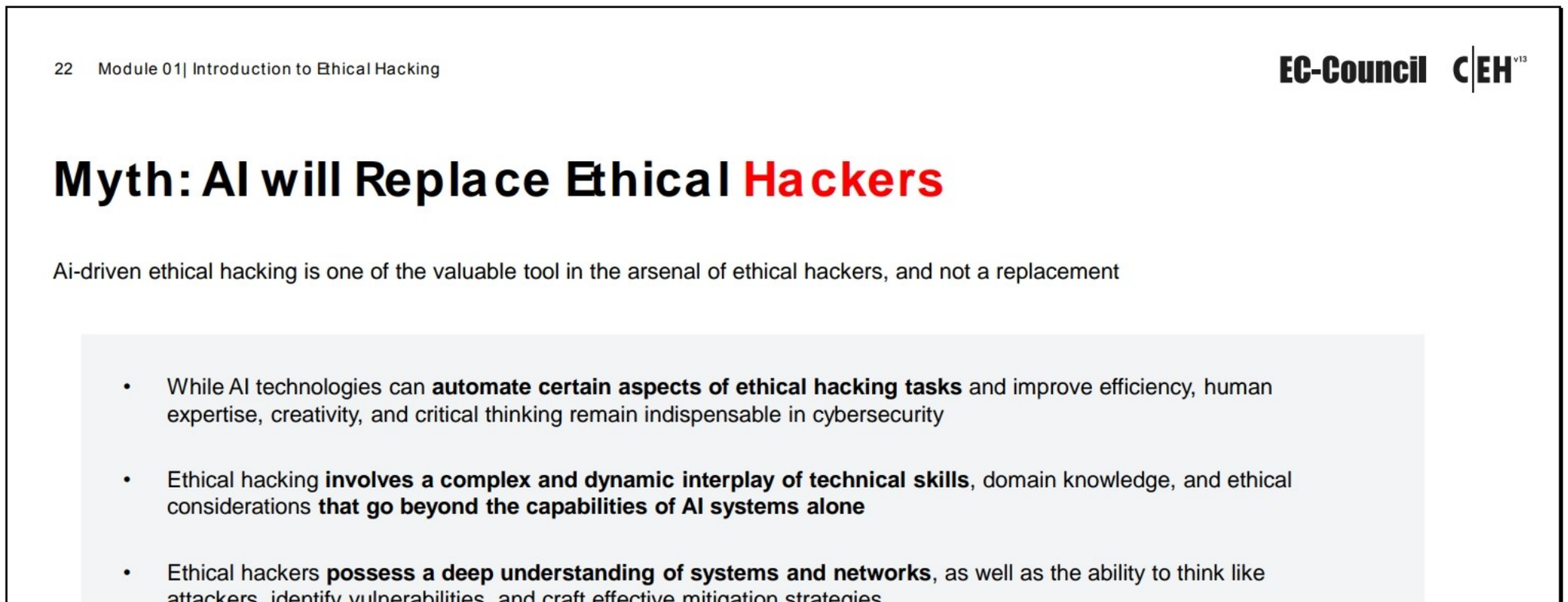
AI-driven ethical hacking leverages artificial intelligence (AI) technologies to enhance the capabilities of ethical hackers. AI-driven ethical hacking enhances the efficiency, effectiveness, and scope of cybersecurity measures and provides ethical hackers with powerful tools to safeguard digital assets against increasingly sophisticated cyber threats.

- **Automation of Repetitive Tasks**: AI can automate the repetitive tasks involved in ethical hacking, such as scanning vulnerabilities, monitoring network traffic, and identifying potential threats. This reduces the time and effort required for manual testing and allows ethical hackers to focus on more complex tasks.
- **Predictive Analysis**: AI algorithms can predict potential security breaches by analyzing data patterns and anomalies. Machine learning models can learn from past attacks to identify signs of future threats, thereby providing a proactive approach to cybersecurity. This helps ethical hackers proactively address vulnerabilities before they can be exploited by malicious actors.
- **Advanced Threat Detection**: AI-driven tools can detect sophisticated and previously unknown threats (zero-day vulnerabilities) using deep learning and anomaly-detection techniques. These tools can identify subtle indicators of compromise that traditional methods can miss.
- **Enhanced Decision Making**: AI tools can provide insights and recommendations based on data analysis, which aid ethical hackers in making informed decisions about where to allocate resources and how to respond to threats.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Adaptive Learning**: AI systems continuously learn and adapt to new types of cyberattacks. As cyber threats evolve, AI can update its knowledge base and improve its detection and response strategies without requiring manual intervention.
- **Enhanced Reporting**: AI can generate detailed and accurate reports on vulnerabilities and their potential impact. These reports can help organizations prioritize their security efforts and allocate resources more effectively.
- **Simulation and Testing**: AI-driven ethical hacking tools can simulate real-world cyberattacks and test the resilience of a system. These simulations help organizations understand how their defenses would perform under actual attack conditions and identify areas for improvement.
- **Scalability**: AI-driven tools can handle large-scale environments and complex systems more efficiently than manual methods can. This scalability is crucial for organizations with extensive and diverse IT infrastructure.
- **Continuous Monitoring**: AI enables the continuous monitoring and assessment of security postures, ensuring that vulnerabilities are identified and mitigated in real time rather than during periodic reviews.
- **Adaptive Defense Mechanisms**: AI can adapt to new threats as they evolve, updating its algorithms and response strategies to counteract the latest hacking techniques and exploitations.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Myth: AI will Replace Ethical Hackers

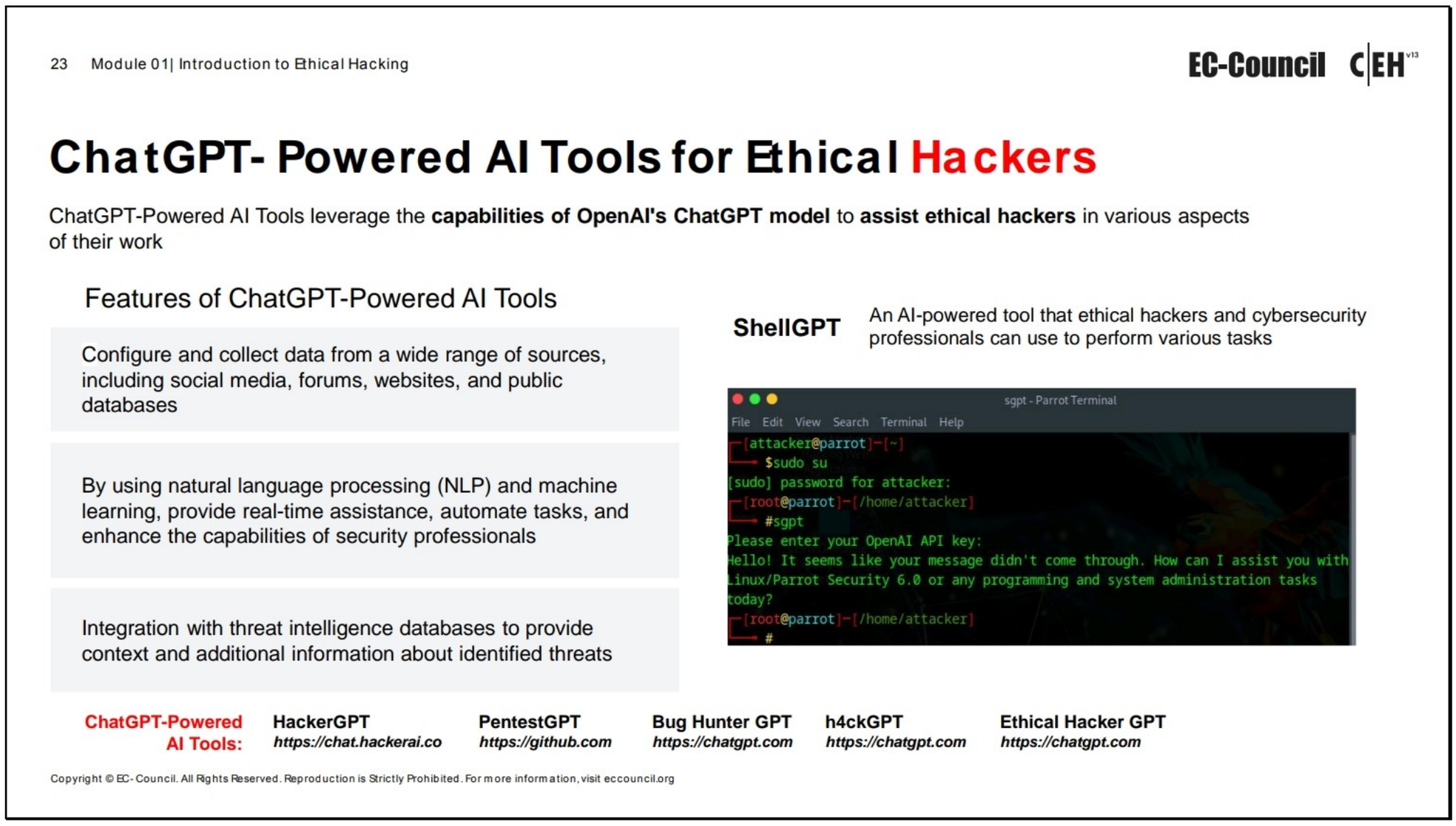
AI-driven ethical hacking is undoubtedly a powerful tool within the arsenal of ethical hackers, but it is crucial to recognize that it does not operate in isolation; rather, it complements, rather than replaces, human expertise.

- While AI technologies can automate certain aspects of ethical hacking tasks and significantly enhance efficiency, they cannot replace the creativity, critical thinking, and complex knowledge that human ethical hackers bring to tables.
- Ethical hacking involves determining how digital objects work and making them safer. It is like solving a puzzle in which you explore the computer staff and networks. You need to know about different software and hardware, and be ready for new challenges. The following rules and laws are as important as identifying problems:
- Although artificial intelligence (AI) tools can make the hacking process faster and easier, they are imperfect. Humans need to oversee them, ensure they are working correctly, and interpret the results. Sometimes, ethical hacking involves making difficult decisions where strict rules may not apply; that is, where human judgment becomes crucial. Humans can think of attackers, identify potential points of entry, and exploit vulnerabilities in ways that AI systems may struggle to comprehend. Moreover, ethical human hackers can leverage their knowledge and contextual understanding to craft tailored mitigation strategies to address the specific needs and challenges of a given system or network.
- AI-driven ethical hacking is beneficial for cybersecurity; however, it should not replace human hackers. When AI and humans work together, organizations can improve their cybersecurity and protect themselves against different threats. This combination of

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

human creativity and technology can improve ethical hacking and cybersecurity better in the future.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



ChatGPT-Powered AI Tools for Ethical Hackers

ChatGPT-Powered AI Tools leverage the capabilities of OpenAI's ChatGPT model to revolutionize ethical hacking. By integrating NLP and machine learning, these tools assist ethical hackers in various aspects of their work, thereby enhancing their efficiency, accuracy, and overall effectiveness in identifying and mitigating cybersecurity threats.

Key Features:

- **Data Collection and Configuration:** ChatGPT-powered tools can configure and collect data from a wide range of data sources, such as social media platforms, forums, websites, and public databases, to enhance their ability to identify potential vulnerabilities.
- **Real-Time Assistance and Task Automation:** Utilizing advanced NLP and machine learning techniques, ChatGPT-powered tools can automate various tasks such as vulnerability scanning, threat analysis, and reporting, thereby streamlining the workflow of security professionals.
- **Integration with Threat Intelligence Databases:** ChatGPT-powered tools are integrated with threat intelligence databases, providing ethical hackers with valuable context and additional information regarding the identified threats. This integration enhances the accuracy and relevance of the threat analysis, enabling ethical hackers to make informed decisions and respond effectively to potential security breaches.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Examples:

1. **ShellGPT:** ShellGPT is an AI-powered tool that enhances accuracy in managing complex systems, writing secure code, and automating repetitive tasks, such as a variety of shell and command-line tasks.

   Features of ShellGPT:

   - **Generating Shell Commands**: Provides the necessary commands to help you navigate through complex systems effortlessly.
   - **Completing Shell Commands**: It suggest completions to ensure accurate and efficient command execution.
   - **Writing Code Snippets**: Assists in generating secure code in various programming languages to enhance hacking toolkit
   - **Creating Comments and Documentation**: Explains intricate code blocks and scripts, making collaboration smoother and code releases more readable, user-friendly, and transparent
   - **Answering General Questions**: Gives answers to the queries directly in the terminal

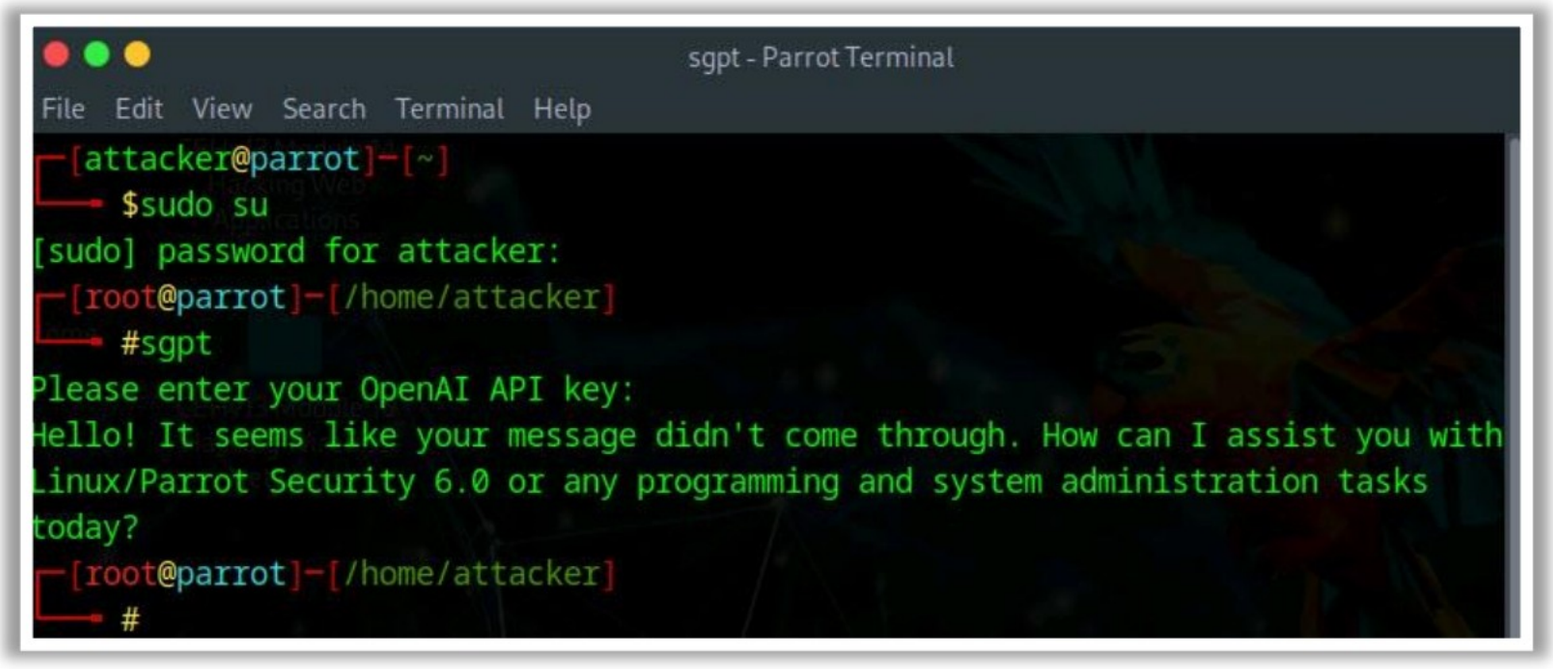


Figure 1.2: Screenshot of ShellGPT

2. **AutoGPT:** AutoGPT is an AI-powered tool designed to automate task execution and data processing. It leverages the capabilities of advanced AI models to generate actionable insights, streamline workflows, and enhance decision-making processes in various domains including cybersecurity.
3. **WormGPT:** WormGPT is an AI-powered tool that assists cybersecurity professionals in automating the generation of worm-like scripts and payloads. It leverages AI to create sophisticated malware for testing and defense purposes, ensuring that robust security measures are in place.
4. **ChatGPT with DAN prompt:** ChatGPT with DAN Prompt is a customized version of ChatGPT that utilizes the DAN (Do Anything Now) prompt to enhance its capabilities. This tool enables ethical hackers to perform a wide range of tasks by leveraging the flexibility and power of DAN prompts.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

5. **FreedomGPT:** FreedomGPT is an AI tool designed to provide ethical hackers with unrestricted access to AI. It aims to bypass traditional content filters and restrictions, allowing users to explore a wide range of functionalities and information.
6. **FraudGPT:** FraudGPT is an AI tool specifically designed to detect and prevent fraudulent activities. It leverages machine learning and AI to analyze patterns, identify suspicious behaviors, and provide actionable insights to mitigate fraud.
7. **ChaosGPT:** ChaosGPT is an AI tool designed to simulate and understand chaotic and unpredictable behaviors.
8. **PoisonGPT:** PoisonGPT is an AI-powered tool that introduces malicious models into otherwise trusted AI systems. It is used to study and understand the implications of AI model poisoning, helping develop defenses against such attacks.

Applications and Benefits:

- **Enhanced Security Posture:** By leveraging the advanced capabilities of ChatGPT, these AI tools significantly enhance an organization's security posture. Ethical hackers can identify and mitigate threats efficiently, thereby ensuring robust protection against cyberattacks.
- **Operational Efficiency:** Automation of routine tasks and real-time assistance provided by ChatGPT-powered tools increase the operational efficiency of ethical hackers. This allows them to perform more comprehensive security assessments in a shorter time.
- **Improved Decision-Making:** Integration with threat intelligence databases and the ability to process large volumes of data enable ethical hackers to make better-informed decisions. The contextual information provided by these tools helps prioritize vulnerabilities and determine the most effective mitigation strategies.

Additional ChatGPT-Powered Hacking Tools

The rise of these sophisticated AI hacking tools has marked a significant shift in the cybersecurity landscape, empowering ethical hackers to stay ahead of emerging threats and challenges. Some of the most notable ChatGPT-powered hacking tools include **HackerGPT, BurpGPT, BugBountyGPT, PentestGPT, GPT White Hack, CybGPT, BugHunterGPT, Hacking APIs GPT, h4ckGPT, HackerNewsGPT, Ethical Hacker GPT, and GP(en)T(ester).** These tools collectively enhance the capabilities of ethical hackers and cybersecurity professionals by leveraging AI to automate tasks, provide real-time insights, and improve the overall effectiveness of security operations.

1. **HackerGPT**

   Source: *www.chat.hackerai.co*

   HackerGPT is an AI-driven tool designed to assist ethical hackers in identifying vulnerabilities. By leveraging advanced AI capabilities, HackerGPT provides real-time assistance and automates complex tasks, thereby significantly reducing the time and effort required for a thorough security assessment.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

2. **BurpGPT**

   Source: www.*burpgpt.app*

   BurpGPT integrates the Burp Suite, a popular web vulnerability scanner, to enhance its capabilities using AI. It utilizes AI-driven analysis to improve the accuracy of vulnerability detection and reduce false positives. By automating report generation and enhancing the scanning process, BurpGPT streamlines web application security testing and delivers precise results.

3. **BugBountyGPT**

   Source: www.*chatgpt.com/g/g-Rsk7ADgbD-bugbountygpt*

   BugBountyGPT is tailored for bug bounty hunters and provides tools and insights for identifying and reporting security vulnerabilities. It automates the detection of vulnerabilities and seamlessly integrates with bug bounty platforms, offering AI-driven insights that enhance the efficiency and accuracy of bug bounty hunting.

4. **PentestGPT**

   Source: *www.github.com/GreyDGL/PentestGPT*

   PentestGPT was designed to assist penetration testers by automating various aspects of the testing process. It leverages AI to conduct thorough vulnerability assessments and generate detailed reports, thereby significantly reducing the required manual effort.

5. **GPT White Hack**

   Source: *www.chatgpt.com/g/g-3ngv8eP6R-gpt-white-hack*

   GPT White Hack focuses on ethical hacking and provides tools to identify and mitigate security threats. Utilizing AI-driven risk assessment and threat detection, this tool offers real-time recommendations for mitigating the identified vulnerabilities.

6. **CybGPT**

   Source: *www.github.com/Coinnect-SA/CybGPT*

   CybGPT is a comprehensive AI tool for cybersecurity professionals that offers a wide range of features for enhancing security operations. It integrates threat intelligence, automates security assessments, and provides AI-driven incident-response capabilities.

7. **BugHunterGPT**

   Source: *www.chatgpt.com/g/g-y2KnRe0w4-bug-hunter-gpt*

   BugHunterGPT assists security researchers in identifying and reporting bugs and vulnerabilities. It automates the detection process and integrates various reporting platforms, providing AI-driven analyses and recommendations.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

8. **Hacking APIs GPT**

   Source: *www.chatgpt.com/g/g-UZxOCmqLH-hacking-apis-gpt*

   Hacking APIs GPT focuses on identifying vulnerabilities in APIs and providing tools to test and secure them. It automates API vulnerability scanning, and uses AI-driven testing and analysis to deliver comprehensive reports.

9. **h4ckGPT**

   Source: *www.chatgpt.com/g/g-1ehIO0APO-h4ckgpt*

   h4ckGPT is a versatile AI tool designed to assist ethical hackers in various aspects of their work. It offers real-time assistance, automates vulnerability identification, and provides recommendations and insights driven by AI.

10. **HackerNewsGPT**

    Source: *www.chatgpt.com/g/g-BIfVX3cVX-hackernews-gpt*

    HackerNewsGPT leverages AI to provide real-time news and updates relevant to cybersecurity professionals. It aggregates news, performs AI-driven analyses of security trends, and offers customizable alerts.

11. **Ethical Hacker GPT**

    Source: *www.chatgpt.com/g/g-j4PQ2hyqn-ethical-hacker-gpt*

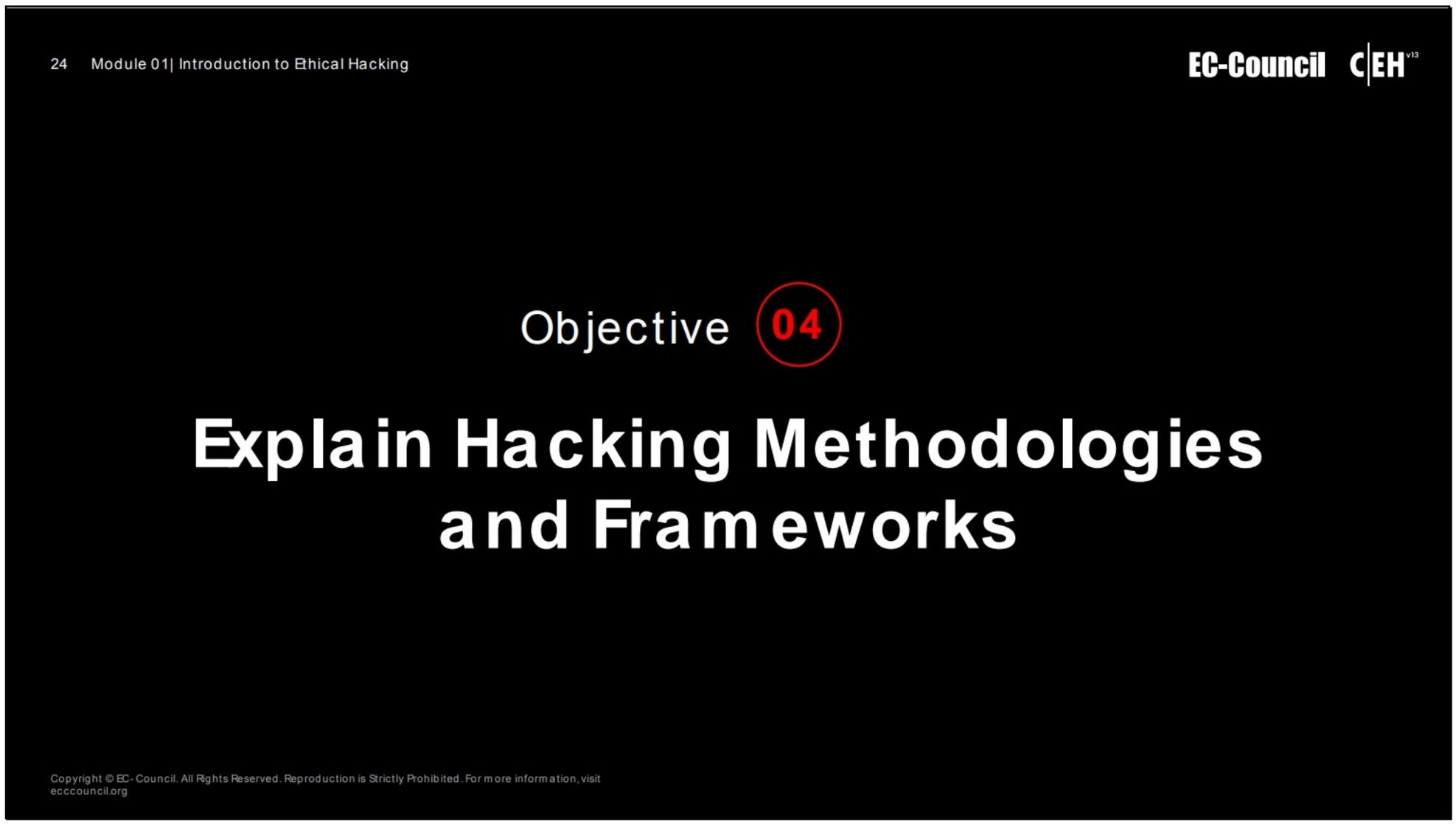
    Ethical Hacker GPT provides tools and insights specifically designed for ethical hackers. It offers AI-driven vulnerability assessments, real-time hacking assistance, and comprehensive reporting.

12. **GP(en)T(ester)**

    Source: *www.chatgpt.com/g/g-zQfyABDUJ-gp-en-t-ester*

    GP(en)T(ester) is an AI-powered tool designed to assist ethical hackers in various aspects of their work. It automates red teaming workflows, identifies vulnerabilities using AI, and generates detailed reports.

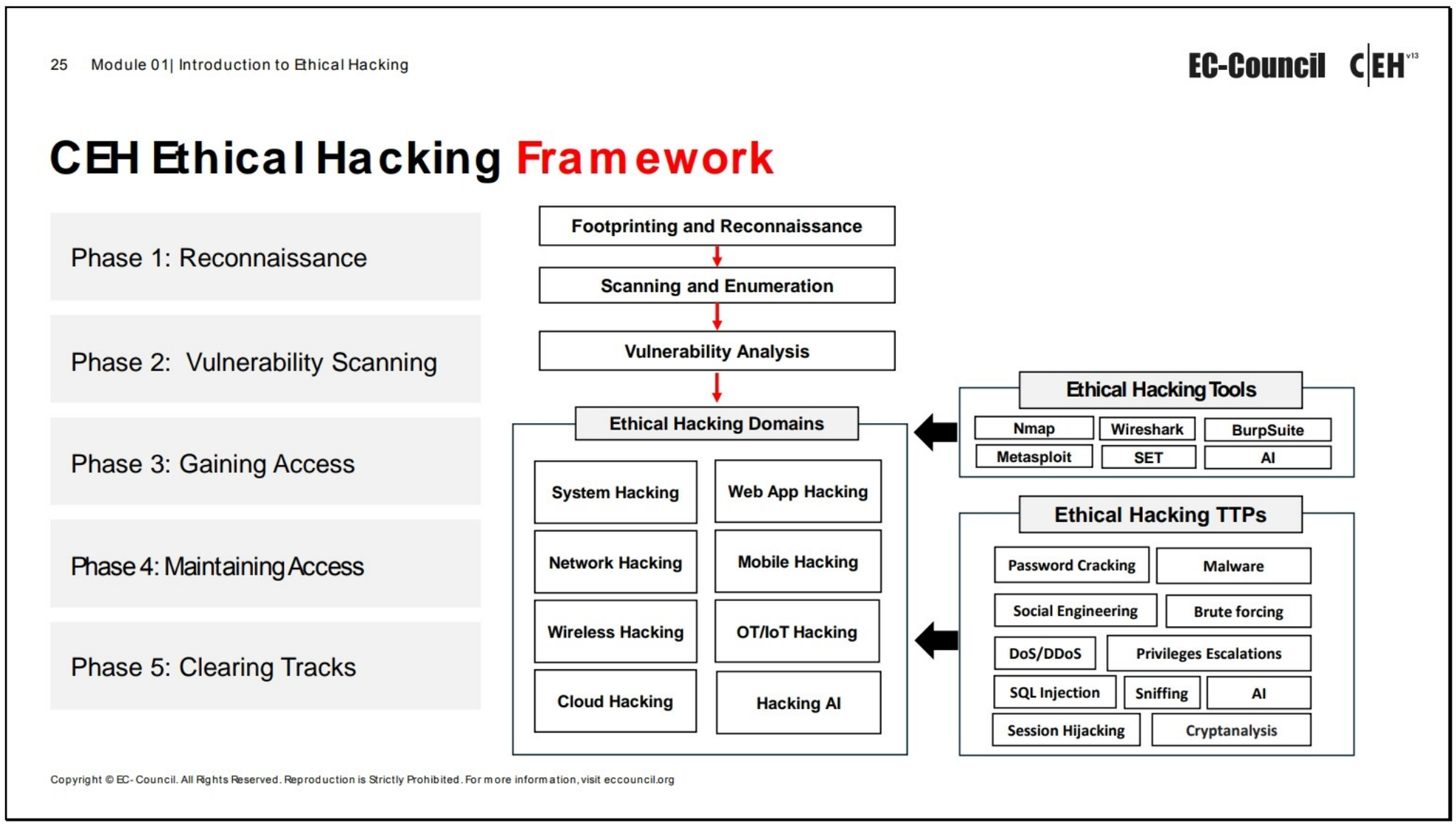
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Hacking Methodologies and Frameworks

Learning the hacking methodologies and frameworks helps ethical hackers understand the phases involved in hacking attempts along with the tactics, techniques, and procedures used by real hackers. This knowledge further helps them in strengthening the security infrastructure of their organization. This section discusses various hacking methodologies and frameworks such as the CEH ethical hacking framework, cyber kill chain methodology, MITRE attack framework, and Diamond Model of Intrusion Analysis.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



CEH Ethical Hacking Framework

EC-council's CEH ethical hacking framework defines the step-by-step process to perform ethical hacking. The CEH ethical hacking framework follows the same process as that of an attacker, and the only differences are in its hacking goals and strategies. This methodology helps security professionals and ethical hackers understand the various phases followed by real hackers in order to achieve their objectives. An understanding of the CEH ethical hacking framework helps ethical hackers learn various tactics, techniques, and tools used by attackers at various phases of hacking, which further guide them to succeed in the ethical hacking process.

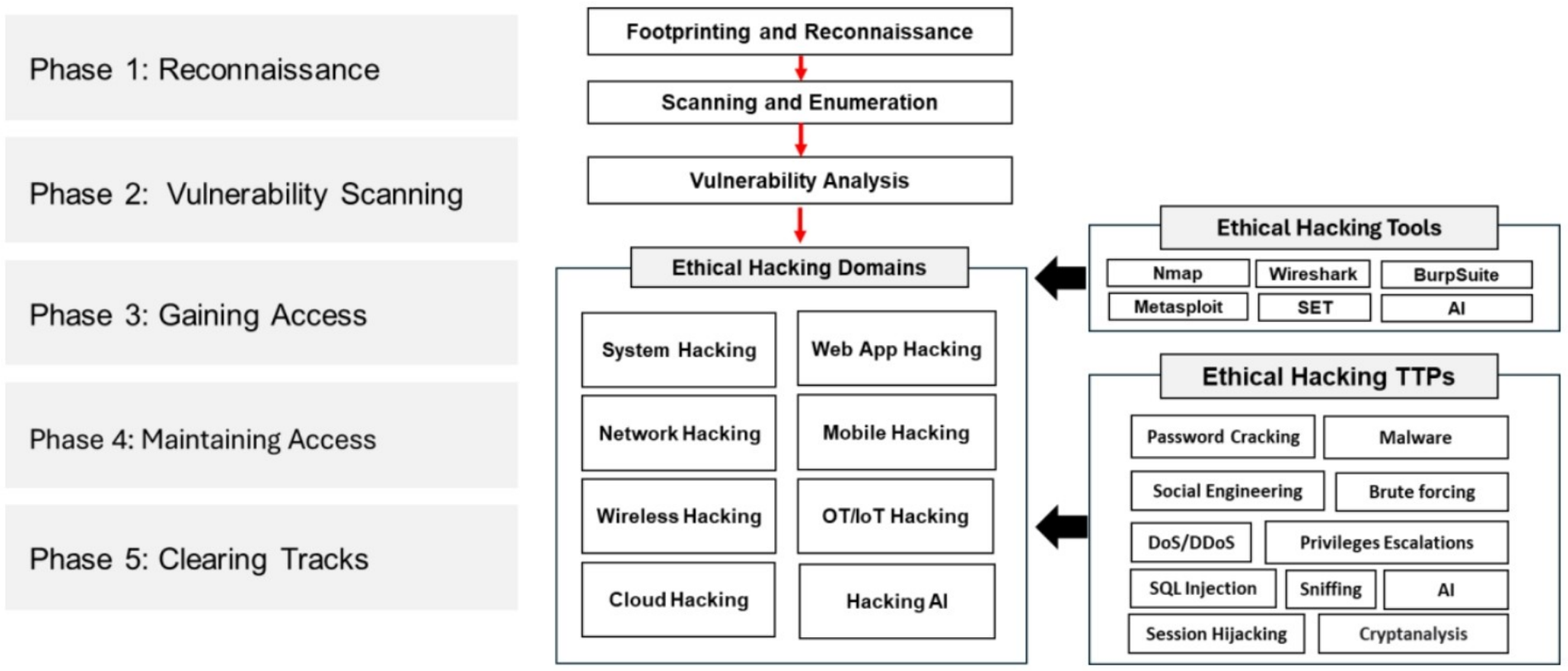


Figure 1.3: EC-council's CEH ethical hacking framework

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

According to the CEH ethical hacking framework, the following are the various phases involved in hacking.

- **Phase 1: Reconnaissance**

  Footprinting and reconnaissance constitute the preparatory phase, in which an attacker gathers as much information as possible about the target prior to launching an attack. In this phase, the attacker creates a profile of the target organization and obtains information such as its IP address range, namespace, and employees. Footprinting facilitates system hacking by revealing vulnerabilities. For example, the organization's website may provide employee biographies or a personnel directory, which the hacker can use for social engineering. Conducting a Whois query on the web can provide information about the networks and domain names associated with a specific organization. The footprinting target range may include the target organization's clients, employees, operations, network, and systems.

  Note: Footprinting techniques are covered in Module 02: Footprinting and Reconnaissance.

  Reconnaissance techniques are broadly categorized into active and passive.

  When an attacker is using passive reconnaissance techniques, they do not interact with the target directly. Instead, the attacker relies on publicly available information, news releases, or other no-contact methods.

  Active reconnaissance techniques, on the other hand, involve direct interactions with the target system by using tools to detect open ports, accessible hosts, router locations, network mapping, details of operating systems, and applications.

  Scanning

  Scanning is used to identify active hosts, open ports, and unnecessary services enabled on particular hosts. In this phase, the attacker uses the details gathered during reconnaissance to scan the network for specific information. Scanning is a logical extension of active reconnaissance; in fact, some experts do not differentiate scanning from active reconnaissance. However, there is a slight difference in that scanning involves more in-depth probing by the attacker. Often, the reconnaissance and scanning phases overlap, and it is not always possible to separate them.

  Note: Scanning techniques are covered in Module 03: Scanning Networks.

  Enumeration

  Enumeration involves making active connections to a target system or subjecting it to direct queries. It is a method of intrusive probing through which attackers gather information such as network user lists, routing tables, security flaws, shared users, groups, applications, and banners.

  Note: Enumeration techniques are covered in Module 04: Enumeration.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Phase 2: Vulnerability Scanning**

  Vulnerability assessment is the examination of the ability of a system or application, including its current security procedures and controls, to withstand assault. It recognizes, measures, and classifies security vulnerabilities in computer systems, networks, and communication channels. Attackers perform vulnerability analysis to identify security loopholes in the target organization's network, communication infrastructure, and end systems. The identified vulnerabilities are used by attackers to perform further exploitation of the target network.

  Note: Vulnerability assessment concepts are discussed in Module 05: Vulnerability Analysis.

- **Phase 3: Gaining Access**

  This is the phase in which actual hacking occurs. The previous phases help attackers identify security loopholes and vulnerabilities in the target organizational IT assets. Attackers use this information, along with techniques such as password cracking and the exploitation of vulnerabilities including buffer overflows, to gain access to the target organizational system.

  Gaining access refers to the point at which the attacker obtains access to the operating system (OS) or applications on a computer or network. A hacker's chances of gaining access to a target system depend on several factors, such as the architecture and configuration of the target system, the perpetrator's skill level, and the initial level of access obtained. Once an attacker gains access to the target system, they attempt to escalate privileges to obtain complete control. In this process, they also compromise the intermediate systems connected to it.

  Escalating Privileges

  After gaining access to a system using a low-privilege user account, the attacker may attempt to increase their privileges to the administrator level to perform protected system operations so that they can proceed to the next level of the system hacking phase, which is the execution of applications. The attacker exploits known system vulnerabilities to escalate user privileges.

- **Phase 4: Maintaining Access**

  Maintaining access refers to the phase in which an attacker attempts to retain ownership of the system. Once an attacker gains access to the target system with admin- or root-level privileges (thus owning the system), they can use both the system and its resources at will. The attacker can either use the system as a launchpad to scan and exploit other systems or maintain a low profile and continue exploitation. Both of these actions can cause significant damage.

  Attackers can upload, download, or manipulate data, applications, and configurations on the owned system and also use malicious software to transfer usernames, passwords, and any other information stored in the system. They can maintain control over the system for a long time by closing vulnerabilities to prevent other hackers from

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

exploiting them. Occasionally, in the process, the attacker may provide some degree of protection to the system from other attacks. Attackers use compromised systems to launch further attacks.

- **Clearing Tracks**

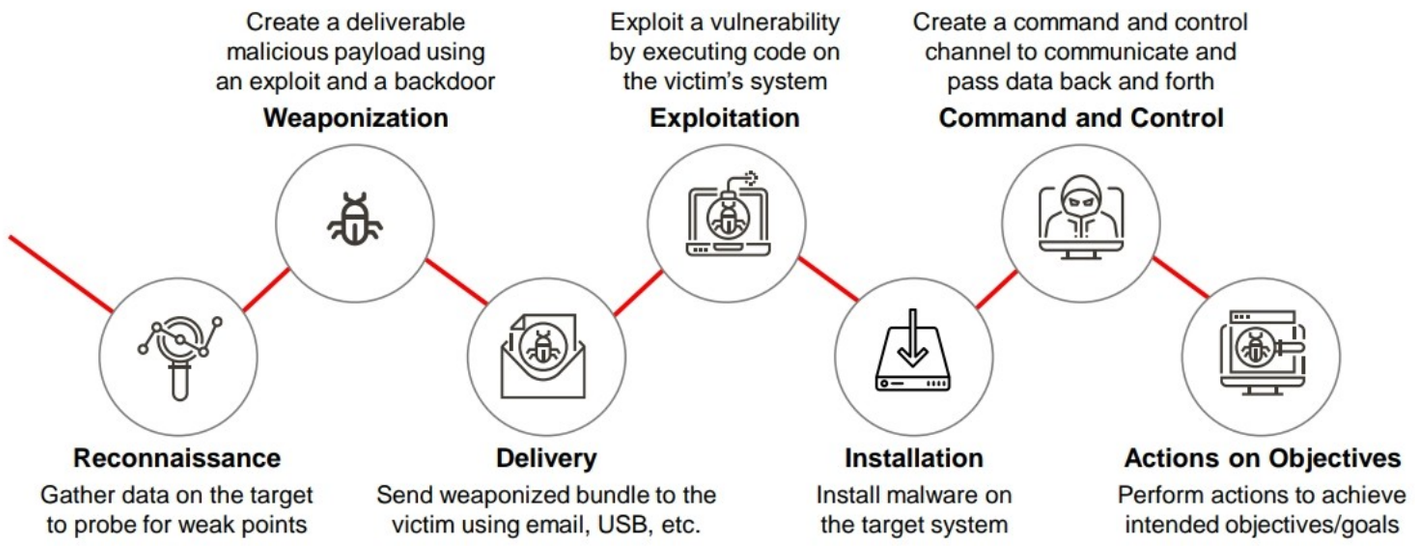
  To remain undetected, it is important for attackers to erase all the evidence of security compromise from the system. To achieve this, they might modify or delete logs in the system using certain log-wiping utilities, thus removing all evidence of their presence.

  Note: The complete system hacking process (gaining access, maintaining access, and clearing tracks) is covered in Module 06: System Hacking.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Cyber Kill Chain Methodology

- The cyber kill chain methodology is a component of intelligence-driven defense for the identification and **prevention of malicious intrusion activities**
- It provides greater insight into attack phases, which helps security professionals to understand the **adversary's tactics, techniques, and procedures beforehand**



Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Cyber Kill Chain Methodology

The cyber kill chain methodology is a component of intelligence-driven defense for the identification and prevention of malicious intrusion activities. This methodology helps security professionals in identifying the steps that adversaries follow in order to accomplish their goals.

The cyber kill chain is a framework developed for securing cyberspace based on the concept of military kill chains. This method aims to actively enhance intrusion detection and response. The cyber kill chain is equipped with a seven-phase protection mechanism to mitigate and reduce cyber threats.

According to Lockheed Martin, cyberattacks might occur in seven different phases, from reconnaissance to the final accomplishment of the objective. An understanding of cyber kill chain methodology helps security professionals to leverage security controls at different stages of an attack and helps them to prevent the attack before it succeeds. It also provides greater insight into the attack phases, which helps in understanding the adversary's TTPs beforehand.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Discussed below are various phases included in cyber kill chain methodology:

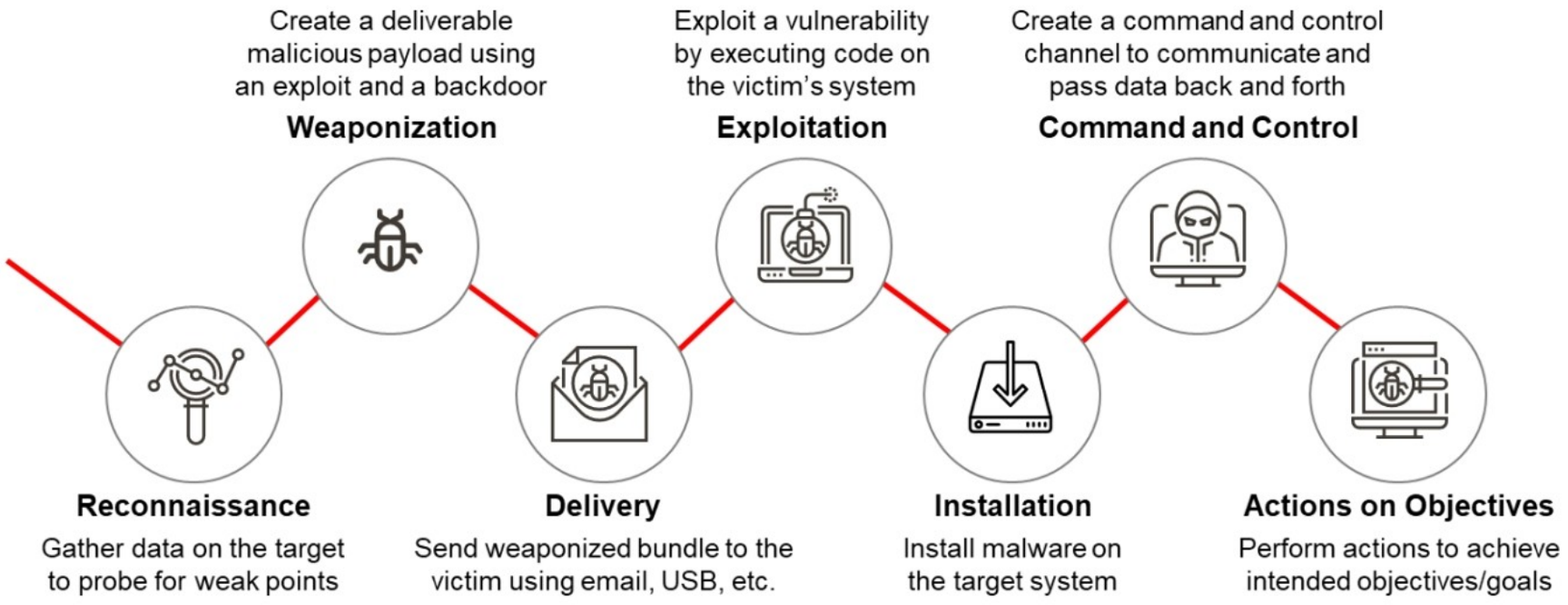


Figure 1.4: Cyber kill chain methodology

- **Reconnaissance**

  An adversary performs reconnaissance to collect as much information about the target as possible to probe for weak points before actually attacking. They look for information such as publicly available information on the Internet, network information, system information, and the organizational information of the target. By conducting reconnaissance across different network levels, the adversary can gain information such as network blocks, specific IP addresses, and employee details. The adversary may use automated tools to obtain information such as open ports and services, vulnerabilities in applications, and login credentials. Such information can help the adversary in gaining backdoor access to the target network.

  Activities of the adversary include the following:

  - Gathering information about the target organization by searching the Internet or through social engineering
  - Performing analysis of various online activities and publicly available information
  - Gathering information from social networking sites and web services
  - Obtaining information about websites visited
  - Monitoring and analyzing the target organization's website
  - Performing Whois, DNS, and network footprinting
  - Performing scanning to identify open ports and services

- **Weaponization**

  The adversary analyzes the data collected in the previous stage to identify the vulnerabilities and techniques that can exploit and gain unauthorized access to the target organization. Based on the vulnerabilities identified during analysis, the adversary selects or creates a tailored deliverable malicious payload (remote-access malware weapon) using an exploit and a backdoor to send it to the victim. An adversary may

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

target specific network devices, operating systems, endpoint devices, or even individuals within the organization to carry out their attack. For example, the adversary may send a phishing email to an employee of the target organization, which may include a malicious attachment such as a virus or worm that, when downloaded, installs a backdoor on the system that allows remote access to the adversary.

The following are the activities of the adversary:

- Identifying appropriate malware payload based on the analysis
- Creating a new malware payload or selecting, reusing, modifying the available malware payloads based on the identified vulnerability
- Creating a phishing email campaign
- Leveraging exploit kits and botnets

- **Delivery**

  The previous stage included creating a weapon. Its payload is transmitted to the intended victim(s) as an email attachment, via a malicious link on websites, or through a vulnerable web application or USB drive. Delivery is a key stage that measures the effectiveness of the defense strategies implemented by the target organization based on whether the intrusion attempt of the adversary is blocked or not.

  The following are the activities of the adversary:

  - Sending phishing emails to employees of the target organization
  - Distributing USB drives containing malicious payload to employees of the target organization
  - Performing attacks such as watering hole on the compromised website
  - Implementing various hacking tools against the operating systems, applications, and servers of the target organization

- **Exploitation**

  After the weapon is transmitted to the intended victim, exploitation triggers the adversary's malicious code to exploit a vulnerability in the operating system, application, or server on a target system. At this stage, the organization may face threats such as authentication and authorization attacks, arbitrary code execution, physical security threats, and security misconfiguration.

  Activities of the adversary include the following:

  - Exploiting software or hardware vulnerabilities to gain remote access to the target system

- **Installation**

  The adversary downloads and installs more malicious software on the target system to maintain access to the target network for an extended period. They may use the

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

weapon to install a backdoor to gain remote access. After the injection of the malicious code on one target system, the adversary gains the capability to spread the infection to other end systems in the network. Also, the adversary tries to hide the presence of malicious activities from security controls like firewalls using various techniques such as encryption.

The following are the activities of the adversary:

- Downloading and installing malicious software such as backdoors
- Gaining remote access to the target system
- Leveraging various methods to keep backdoor hidden and running
- Maintaining access to the target system

- **Command and Control**

  The adversary creates a command and control channel, which establishes two-way communication between the victim's system and adversary-controlled server to communicate and pass data back and forth. The adversaries implement techniques such as encryption to hide the presence of such channels. Using this channel, the adversary performs remote exploitation on the target system or network.

  The following are the activities of the adversary:

  - Establishing a two-way communication channel between the victim's system and the adversary-controlled server
  - Leveraging channels such as web traffic, email communication, and DNS messages.
  - Applying privilege escalation techniques
  - Hiding any evidence of compromise using techniques such as encryption

- **Actions on Objectives**

  The adversary controls the victim's system from a remote location and finally accomplishes their intended goals. The adversary gains access to confidential data, disrupts the services or network, or destroys the operational capability of the target by gaining access to its network and compromising more systems. Also, the adversary may use this as a launching point to perform other attacks.

Tactics, Techniques, and Procedures (TTPs)

Organizations should understand TTPs to protect their network against threat actors and upcoming attacks. TTPs enable the organizations to stop attacks at the initial stage, thereby protecting the network against massive damages.

- **Tactics**

  Tactics describe the way the threat actor operates during different phases of an attack. It consists of the various tactics used to gather information for the initial exploitation, perform privilege escalation and lateral movement, and deploy measures for

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

persistence access to the system. Generally, APT groups depend on a certain set of unchanging tactics, but in some cases, they adapt to different circumstances and alter the way they perform their attacks. Therefore, the difficulty of detecting and attributing the attack campaign depends on the tactics used to perform the attack.

An organization can profile threat actors based on tactics they use; this consists of the way they gather information about a target, the methods they follow for initial compromise, and the number of entry points they use while attempting to enter the target network.

For example, to obtain information, some threat actors depend solely on information available on the Internet, whereas others might perform social engineering or use connections in intermediate organizations. Once information such as the email addresses of employees of the target organization is gathered, the threat actors either choose to approach the target one by one or as a group. Furthermore, the attackers' designed payload can stay constant from the beginning to the end of the attack or may be changed based on the targeted individual. Therefore, to understand the threat actors better, tactics used in the early stages of an attack must be analyzed properly.

Another method of analyzing the APT groups is inspecting the infrastructure and tools used to perform their attack. For example, consider establishing a command and control channel on the servers controlled by the attacker. These C&C servers may be located within a specific geographical location or may spread across the Internet and can be static or can change dynamically. It is also important to analyze the tools used to perform the attack. This includes analyzing the exploits and tools used by various APT groups. In such a scenario, a sophisticated threat actor may exploit many zero-day vulnerabilities by using adapted tools and obfuscation methods. However, this might be difficult as less-sophisticated threat actors generally depend on publicly known vulnerabilities and open-source tools. Identifying this type of tactic helps in profiling the APT groups and building defensive measures in advance.

In some cases, understanding the tactics used in the last stages of an attack helps in profiling the threat actor. Also, the methods used to cover the tracks help the target organization understand attack campaigns. Analyzing the tactics used by the attackers helps in creating an initial profile by understanding different phases of an APT life cycle. This profile helps in performing further analysis of the techniques and procedures used by the attackers. An attacker may continually change the TTPs used, so it is important to constantly review and update the tactics used by the APT groups.

- **Techniques**

  To launch an attack successfully, threat actors use several techniques during its execution. These techniques include initial exploitation, setting up and maintaining command and control channels, accessing the target infrastructure, and covering the tracks of data exfiltration. The techniques followed by the threat actor to conduct an attack might vary, but they are mostly similar and can be used for profiling. Therefore,

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

understanding the techniques used in the different phases of an attack is essential to analyzing the threat groups effectively.

Techniques can also be analyzed at each stage of the threat life cycle. Therefore, the techniques at the initial stage mainly describe the tools used for information gathering and initial exploitation. The techniques used in this stage need not necessarily have a technical aspect. For example, in social engineering, certain non-technical software tools are used as an effective way of gathering information. An attacker can use such tools to obtain the email addresses of target organization employees through publicly available resources.

In the same manner, purely human-based social engineering can be used to perform the initial exploitation. For example, consider a scenario where the victim is tricked via a phone call to reveal their login credentials for accessing the target organization's internal network. These techniques are used in the initial phase of an attack to gather information about the target and break the first line of defense.

Techniques used in the middle stages of an attack mostly depend on technical tools for initially escalating privileges on systems that are compromised or performing lateral movements within the target organization's network. At this stage of an attack, the attackers use various exploits or misuse configuration vulnerabilities on the target system. They may also exploit network design flaws to gain access to other systems in the network. In all of these cases, either exploits or a collection of tools allows the attacker to perform a successful attack. In this scenario, the term "technique" is the set of tools and the way they are used to obtain intermediate results during an attack campaign.

The techniques in the last stage of an attack can have both technical and nontechnical aspects. In such a scenario, the techniques used for data-stealing are usually based on network technology and encryption. For example, the threat actor encrypts the stolen files, transfers them through the established command and control channel, and copies them to their own system. After successfully executing the attack and transferring the files, the attacker follows certain purely technical techniques to cover their tracks. They use automated software tools to clear logs files to evade detection.

After aggregating the techniques used in all the stages of an attack, the organization can use the information to profile the threat actors. In order to make an accurate attribution of threat actors, the organization must observe all the techniques used by its adversaries.

- **Procedures**

  "Procedures" involve a sequence of actions performed by the threat actors to execute different steps of an attack life cycle. The number of actions usually differs depending upon the objectives of the procedure and the APT group. An advanced threat actor uses advanced procedures that consist of more actions than a normal procedure to achieve the same intermediate result. This is done mainly to increase the success rate of an attack and decrease the probability of detection by security mechanisms.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

For example, in a basic procedure of information gathering, an actor collects information about the target organization; identifies key targets, employees; collects their contact details, identifies vulnerable systems and potential entry points to the target network, and documents all the collected information. The further actions of an adversary depend on the tactics used. These actions include extensive research and repeated information gathering to collect in-depth and up-to-date information on the target individuals via social networking sites. This information can assist threat actors in performing spear phishing, monitoring security controls to identify zero-day exploits in the target systems, and other tasks. For example, a threat actor using a more detailed procedure executes the malware payload. At the time of execution, the malicious code decrypts itself, evades security monitoring controls, deploys persistence, and establishes a command and control channel for communicating with the victim system. This type of procedure is common for malware, where different threat actors may implement the same feature, and hence it is useful in forensic investigations.

An understanding and proper analysis of the procedures followed by certain threat actors during an attack helps organizations profile threat actors. In the initial stage of an attack, such as during information gathering, observing the procedure of an APT group is difficult. However, the later stages of an attack can leave trails that may be used to understand the procedures the attacker followed.

Adversary Behavioral Identification

Adversary behavioral identification involves the identification of the common methods or techniques followed by an adversary to launch attacks to penetrate an organization's network. It gives security professionals insight into upcoming threats and exploits. It helps them plan network security infrastructure and adapt a range of security procedures as prevention against various cyberattacks.

Given below are some of the behaviors of an adversary that can be used to enhance the detection capabilities of security devices:

- **Internal Reconnaissance**

  Once the adversary is inside the target network, they follow various techniques and methods to carry out internal reconnaissance. This includes the enumeration of systems, hosts, processes, the execution of various commands to find out information such as the local user context and system configuration, hostname, IP addresses, active remote systems, and programs running on the target systems. Security professionals can monitor the activities of an adversary by checking for unusual commands executed in the Batch scripts and PowerShell and by using packet capturing tools.

- **Use of PowerShell**

  PowerShell can be used by an adversary as a tool for automating data exfiltration and launching further attacks. To identify the misuse of PowerShell in the network, security professionals can check PowerShell's transcript logs or Windows Event logs. The user

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

agent string and IP addresses can also be used to identify malicious hosts who try to exfiltrate data.

- **Unspecified Proxy Activities**

  An adversary can create and configure multiple domains pointing to the same host, thus, allowing an adversary to switch quickly between the domains to avoid detection. Security professionals can find unspecified domains by checking the data feeds that are generated by those domains. Using this data feed, the security professionals can also find any malicious files downloaded and the unsolicited communication with the outside network based on the domains.

- **Use of Command-Line Interface**

  On gaining access to the target system, an adversary can make use of the command-line interface to interact with the target system, browse the files, read file content, modify file content, create new accounts, connect to the remote system, and download and install malicious code. Security professionals can identify this behavior of an adversary by checking the logs for process ID, processes having arbitrary letters and numbers, and malicious files downloaded from the Internet.

- **HTTP User Agent**

  In HTTP-based communication, the server identifies the connected HTTP client using the user agent field. An adversary modifies the content of the HTTP user agent field to communicate with the compromised system and to carry further attacks. Therefore, security professionals can identify this attack at an initial stage by checking the content of the user agent field.

- **Command and Control Server**

  Adversaries use command and control servers to communicate remotely with compromised systems through an encrypted session. Using this encrypted channel, the adversary can steal data, delete data, and launch further attacks. Security professionals can detect compromised hosts or networks by identifying the presence of a command and control server by tracking network traffic for outbound connection attempts, unwanted open ports, and other anomalies.

- **Use of DNS Tunneling**

  Adversaries use DNS tunneling to obfuscate malicious traffic in the legitimate traffic carried by common protocols used in the network. Using DNS tunneling, an adversary can also communicate with the command and control server, bypass security controls, and perform data exfiltration. Security professionals can identify DNS tunneling by analyzing malicious DNS requests, DNS payload, unspecified domains, and the destination of DNS requests.

- **Use of Web Shell**

  An adversary uses a web shell to manipulate the web server by creating a shell within a website; it allows an adversary to gain remote access to the functionalities of a server.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Using a web shell, an adversary performs various tasks such as data exfiltration, file transfers, and file uploads. Security professionals can identify the web shell running in the network by analyzing server access, error logs, suspicious strings that indicate encoding, user agent strings, and through other methods.

- **Data Staging**

  After successful penetration into a target's network, the adversary uses data staging techniques to collect and combine as much data as possible. The types of data collected by an adversary include sensitive data about the employees and customers, the business tactics of an organization, financial information, and network infrastructure information. Once collected, the adversary can either exfiltrate or destroy the data. Security professionals can detect data staging by monitoring network traffic for malicious file transfers, file integrity monitoring, and event logs.

Indicators of Compromise (IoCs)

Cyber threats are continuously evolving with the newer TTPs adapted based on the vulnerabilities of the target organization. Security professionals must perform continuous monitoring of IoCs to effectively and efficiently detect and respond to evolving cyber threats. Indicators of Compromise are the clues, artifacts, and pieces of forensic data that are found on a network or operating system of an organization that indicate a potential intrusion or malicious activity in the organization's infrastructure.

However, IoCs are not intelligence; rather, IoCs act as a good source of information about threats that serve as data points in the intelligence process. Actionable threat intelligence extracted from IoCs helps organizations enhance incident-handling strategies. Cybersecurity professionals use various automated tools to monitor IoCs to detect and prevent various security breaches to the organization. Monitoring IoCs also helps security teams enhance the security controls and policies of the organization to detect and block suspicious traffic to thwart further attacks. To overcome the threats associated with IoCs, some organizations like STIX and TAXII have developed standardized reports that contain condensed data related to attacks and shared it with others to leverage the incident response.

An IoC is an atomic indicator, computed indicator, or behavioral indicator. It is the information regarding suspicious or malicious activities that is collected from various security establishments in a network's infrastructure. Atomic indicators are those that cannot be segmented into smaller parts, and whose meaning is not changed in the context of an intrusion. Examples of atomic indicators are IP addresses and email addresses. Computed indicators are obtained from the data extracted from a security incident. Examples of computed indicators are hash values and regular expressions. Behavioral indicators refer to a grouping of both atomic and computed indicators, combined on the basis of some logic.

Categories of Indicators of Compromise

The cybersecurity professionals must have proper knowledge about various possible threat actors and their tactics related to cyber threats, mostly called Indicators of Compromise (IoCs).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

This understanding of IoCs helps security professionals quickly detect the threats entering the organization and protect the organization from evolving threats.

For this purpose, IoCs are divided into four categories:

- **Email Indicators**

  Attackers usually prefer email services to send malicious data to the target organization or individual. Such socially engineered emails are preferred due to their ease of use and comparative anonymity. Examples of email indicators include the sender's email address, email subject, and attachments or links.

- **Network Indicators**

  Network indicators are useful for command and control, malware delivery, and identifying details about the operating system, browser type, and other computer-specific information. Examples of network indicators include URLs, domain names, and IP addresses.

- **Host-Based Indicators**

  Host-based indicators are found by performing an analysis of the infected system within the organizational network. Examples of host-based indicators include filenames, file hashes, registry keys, DLLs, and mutex.

- **Behavioral Indicators**

  Generally, typical IoCs are useful for identifying indications of intrusion, such as malicious IP addresses, virus signatures, MD5 hash, and domain names. Behavioral IoCs are used to identify specific behavior related to malicious activities such as code injection into the memory or running the scripts of an application. Well-defined behaviors enable broad protection to block all current and future malicious activities. These indicators are useful to identify when legitimate system services are used for abnormal or unexpected activities. Examples of behavioral indicators include document executing PowerShell script, and remote command execution.

Listed below are some of the key Indicators of Compromise (IoCs):

- Unusual outbound network traffic
- Unusual activity through a privileged user account
- Geographical anomalies
- Multiple login failures
- Increased database read volume
- Large HTML response size
- Multiple requests for the same file
- Mismatched port-application traffic
- Suspicious registry or system file changes

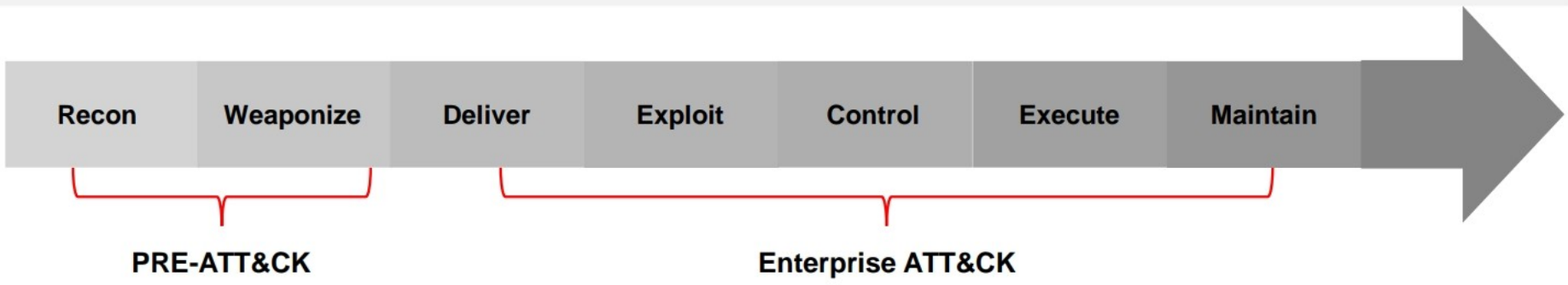
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Unusual DNS requests
- Unexpected patching of systems
- Signs of Distributed Denial-of-Service (DDoS) activity
- Bundles of data in the wrong places
- Web traffic with superhuman behavior

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

MITRE ATT&CK Framework

1. MITRE ATT&CK is a globally accessible knowledge base of **adversary tactics and techniques** based on real-world observations
2. The ATT&CK knowledge base is used as a foundation for the development of specific **threat models** and methodologies in the private sector, **government**, and the **cybersecurity product** and service community
3. The 14 tactic categories within ATT&CK for Enterprise are derived from the later stages (exploit, control, maintain, and execute) of the seven stages of the **Cyber Kill Chain**



https://attack.mitre.org

Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

MITRE ATT&CK Framework

Source: *https://attack.mitre.org*

MITRE ATT&CK is a globally accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community.

MITRE ATT&CK comprises three collections of tactics and techniques, called Enterprise, Mobile, and PRE-ATT&CK matrices, as each collection is represented in a matrix form. ATT&CK for Enterprise contains 14 categories of tactics, which are derived from the later stages (exploit, control, maintain, and execute) of the seven-stage Cyber Kill Chain. This provides a deeper level of granularity in describing what can occur during an intrusion.

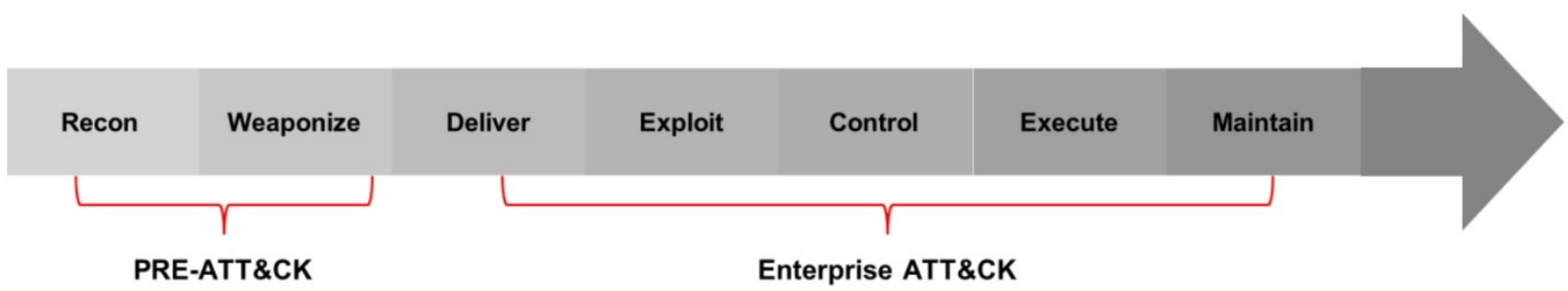


Figure 1.5: MITRE Attack Framework

The following are the tactics in ATT&CK for Enterprise

- Reconnaissance
- Resource Development
- Initial Access
- Execution
- Persistence
- Privilege Escalation

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Defense Evasion
- Credential Access
- Discovery
- Lateral Movement
- Collection
- Command and Control
- Exfiltration
- Impact

Some MITRE ATT&CK for Enterprise Use Cases:

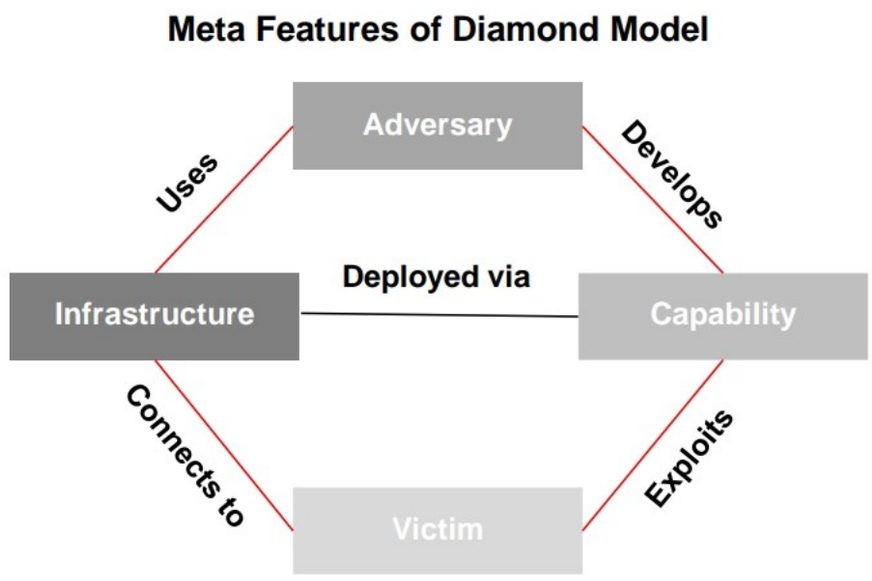
- Prioritize development and acquisition efforts for computer network defense capabilities.
- Conduct analyses of alternatives between network defense capabilities.
- Determine "coverage" of a set of network defense capabilities.
- Describe an intrusion chain of events based on the technique used from start to finish with a common reference.
- Identify commonalities between adversary tradecraft, as well as distinguishing characteristics.
- Connect mitigations, weaknesses, and adversaries.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Diamond Model of Intrusion Analysis

- The Diamond Model offers a framework for **identifying the clusters of events** that are correlated on any of the systems in an organization
- It can control the **vital atomic element** occurring in any intrusion activity, which is referred to as the Diamond event
- Using this model, **efficient mitigation approaches** can be developed, and analytic efficiency can be increased

Adversary	An opponent "**who**" was behind the attack
Victim	The target that has been exploited or "**where**" the attack was performed
Capability	The attack strategies or "**how**" the attack was performed
Infrastructure	"**what**" the adversary used to reach the victim



Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Diamond Model of Intrusion Analysis

The Diamond Model, developed by expert analysts, introduces state-of-the-art technology for intrusion analysis. This model offers a framework and a set of procedures for recognizing clusters of events that are correlated on any of the systems in an organization. The model determines the vital atomic element that occurs in any intrusion activity and is referred to as the Diamond event. Analysts can identify the events and connect them as activity threads for obtaining information regarding how and what transpired during an attack. Analysts can also easily identify whether any data are required by examining the missing features. It also offers a method or route map for analyzing incidents related to any malicious activity and predict the possibility of an attack and its origin.

With the Diamond Model, more advanced and efficient mitigation approaches can be developed, and analytic efficiency can be increased. This also results in cost savings for the defender and rising cost for the adversary. The Diamond event consists of four basic features: adversary, capability, infrastructure, and victim. This model is named so because when all the features are arranged according to the relationship between them, it forms as a diamond-shaped structure. Although it appears to be a simple approach, it is rather complex and requires high expertise and skill to traceroute the flow of attack.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

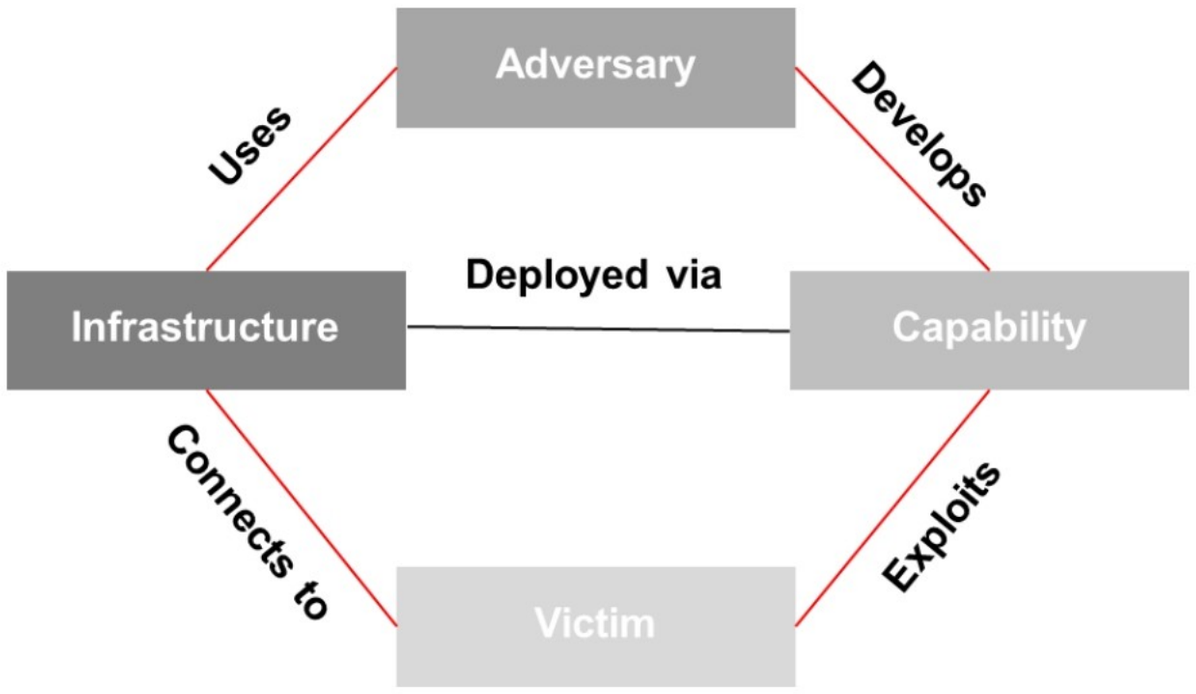


Figure 1.6: Meta features of the Diamond Model

The following are the essential features of the Diamond event in the Diamond Model of Intrusion Analysis.

- **Adversary:** An adversary often refers to an opponent or hacker responsible for the attack event. An adversary takes advantage of a capability against the victim to perform a malicious activity for financial benefit or to damage the reputation of the victim. An adversary can be individuals such as insiders or a competitor organization. Adversaries can use many techniques to gain information such as email addresses and network assets and attempt to attack any applications used in smartphones to gain sensitive information.
- **Victim:** The victim is the target that has been exploited or the environment where the attack was performed. The adversary exploits the vulnerabilities or security loopholes in the victim's infrastructure by using their resources. The victim can be any person, organization, institution, or even network information such as IP addresses, domain names, email addresses, and sensitive personal information of an individual.
- **Capability:** Capability refers to all the strategies, methods, and procedures associated with an attack. It can also be a malware or tool used by an adversary against the target. Capability includes simple and complex attack techniques such as brute forcing and ransomware attacks.
- **Infrastructure:** Infrastructure refers to the hardware or software used in the network by the target that has a connection with the adversary. It refers to "what" the adversary has used to reach the victim. Consider an organization having an email server in which all the data regarding employee email IDs and other personal details are stored. The adversary can use the server as infrastructure to perform any type of attack by targeting a single employee. Exploiting infrastructure leads to data leakage and data exfiltration.

Additional Event Meta-Features

In the Diamond Model, an event contains some of the basic meta-features that provide additional information such as the time and source of the event. These meta-features help in linking related events, making it easier and faster for analysts to trace an attack.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The following are the features that help in connecting related events.

- **Timestamp:** This feature can reveal the time and date of an event. It is important as it can indicate the beginning and end of the event. It also helps in analysis and determining the periodicity of the event.
- **Phase**: The phase helps in determining the progress of an attack or any malicious activity. The different phases of an attack include the phases used in the cyber kill chain framework: reconnaissance, weaponization, delivery, exploitation etc.
- **Result**: The result is the outcome of any event. For example, the result of an attack can be success, failure, or unknown. It can also be segregated using security fundamentals such as confidentiality(C) compromised, integrity(I) compromised, and availability(A) compromised. CIA Compromised.
- **Direction**: This feature refers to the direction of the attack. For instance, the direction can indicate how the adversary was routed to the victim. This feature can be immensely helpful when describing network-based and host-based events. The possible values for this feature include victim to infrastructure, adversary to infrastructure, infrastructure to infrastructure, and bidirectional.
- **Methodology**: The methodology refers to any technique that is used by the adversary to perform an attack. This feature allows the analyst to define the overall class of action performed. Some attack techniques are spear-phishing emails, distributed denial-of-service (DDoS) attacks, content delivery attacks, and drive-by-compromise.
- **Resource**: Resource feature entails the use of external resources like tools or technology used to perform the attack. It includes hardware, software, access, knowledge, data etc.

Extended Diamond Model

The extended Diamond Model also includes necessary features such as socio-political meta-features to determine the relationship between the adversary and victim as well as technology meta-features for infrastructure and capabilities.

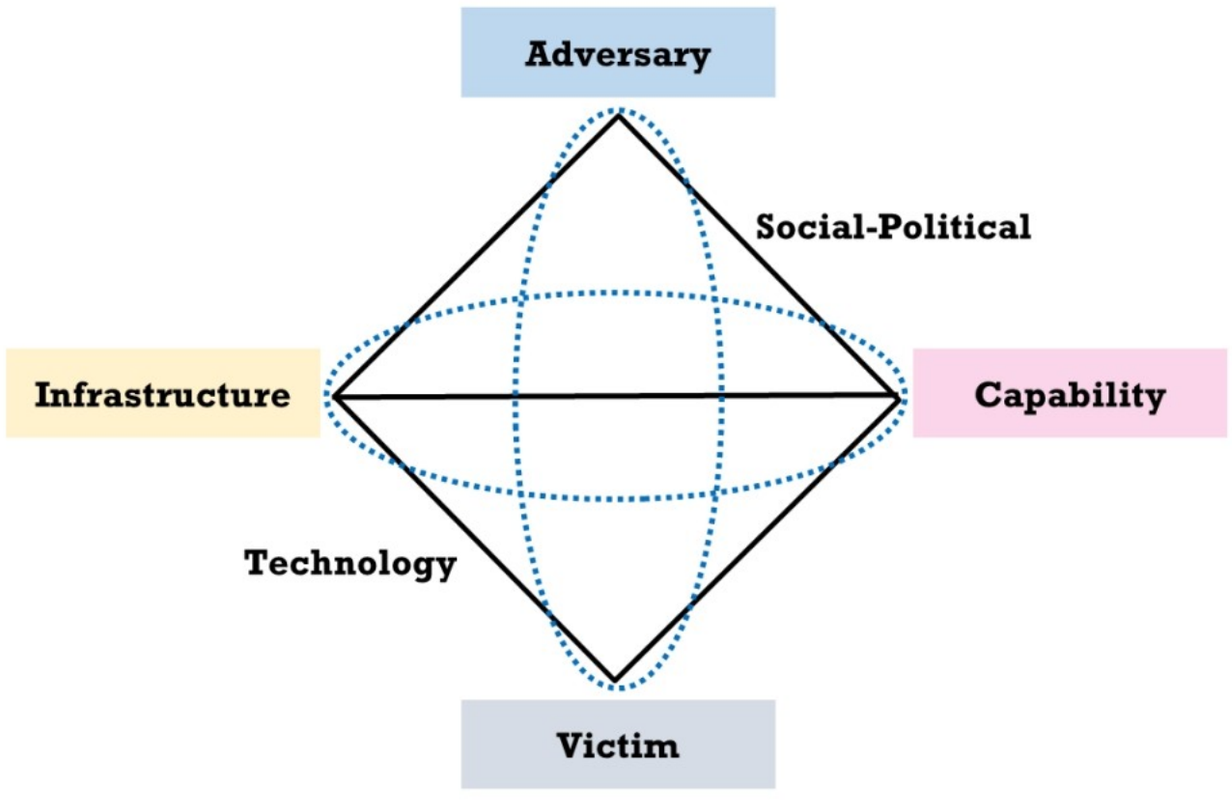
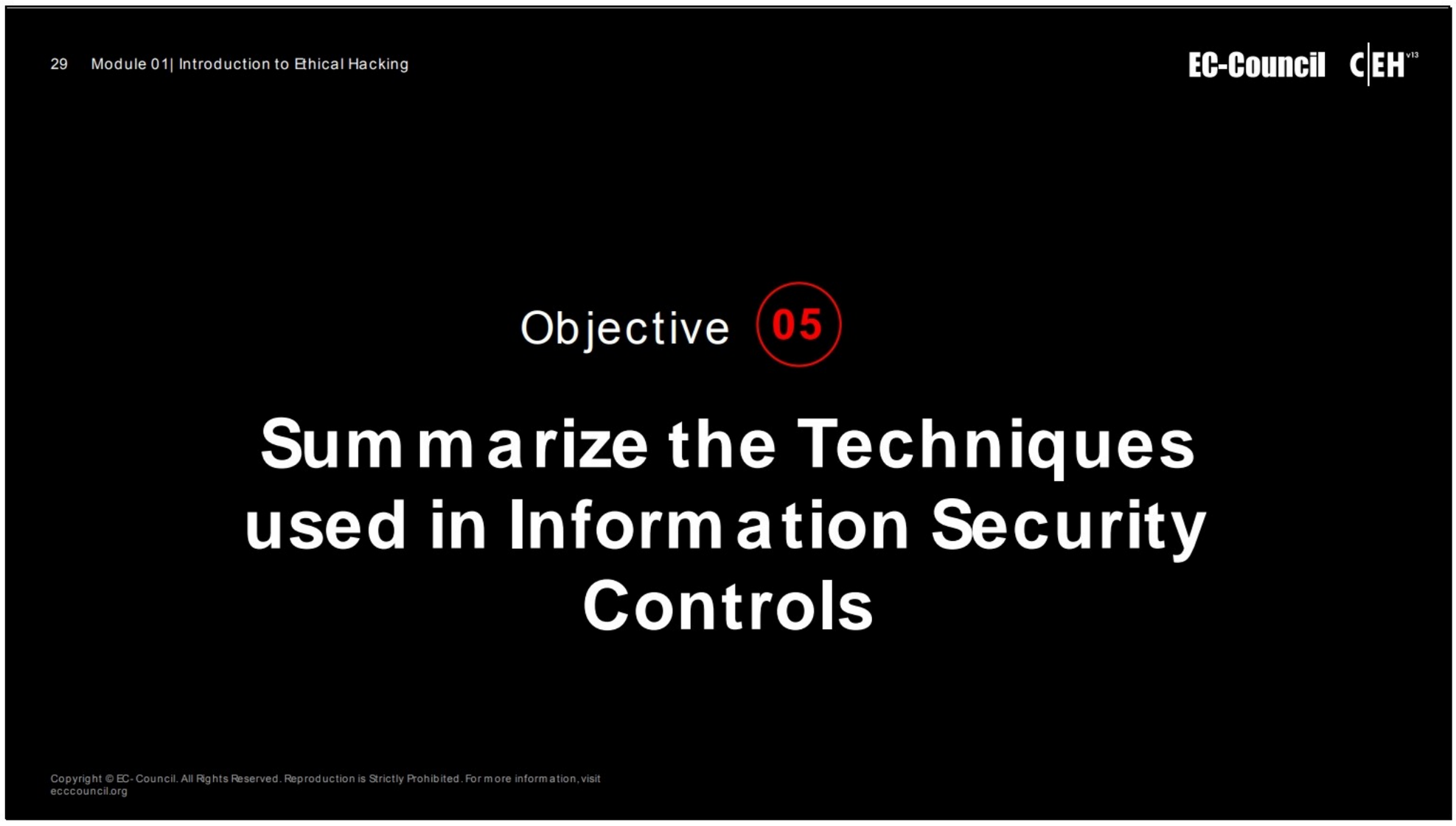


Figure 1.7: Extended Diamond Model of Intrusion Analysis

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Socio-political meta-feature:** The socio-political meta-feature describes the relationship between the adversary and victim. This feature is used to determine the goal or motivation of the attacker; common motivations include financial benefit, corporate espionage, and hacktivism.
- **Technology meta-feature:** The technology meta-feature describes the relationship between the infrastructure and capability. This meta-feature describes how technology can enable both infrastructure and capability for communication and operation. It can also be used to analyze the technology used in an organization to identify any malicious activity.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

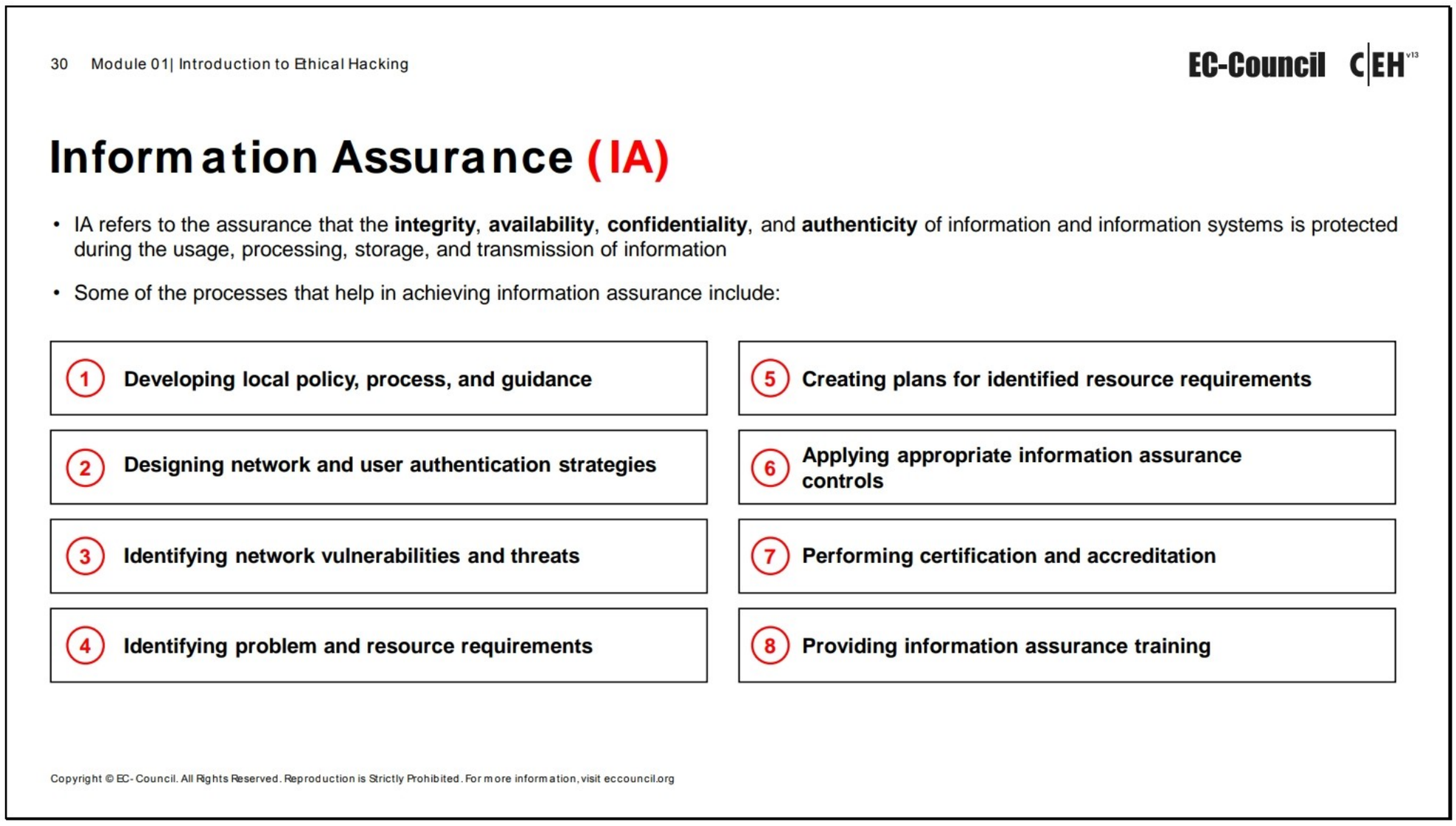


Information Security Controls

Information security controls prevent the occurrence of unwanted events and reduce risk to the organization's information assets. The basic security concepts critical to information on the Internet are confidentiality, integrity, and availability; the concepts related to the persons accessing the information are authentication, authorization, and non-repudiation. Information is the greatest asset of an organization. It must be secured using various policies, creating awareness, employing security mechanisms, or by other means.

This section deals with Information Assurance (IA), continual/adaptive security strategy, defense-in-depth, risk management, cyber threat intelligence, threat modeling, incident management, and AI and ML concepts.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Information Assurance (IA)

IA refers to the assurance of the integrity, availability, confidentiality, and authenticity of information and information systems during the usage, processing, storage, and transmission of information. Security experts accomplish information assurance with the help of physical, technical, and administrative controls. Information Assurance and Information Risk Management (IRM) ensure that only authorized personnel access and use information. This helps in achieving information security and business continuity.

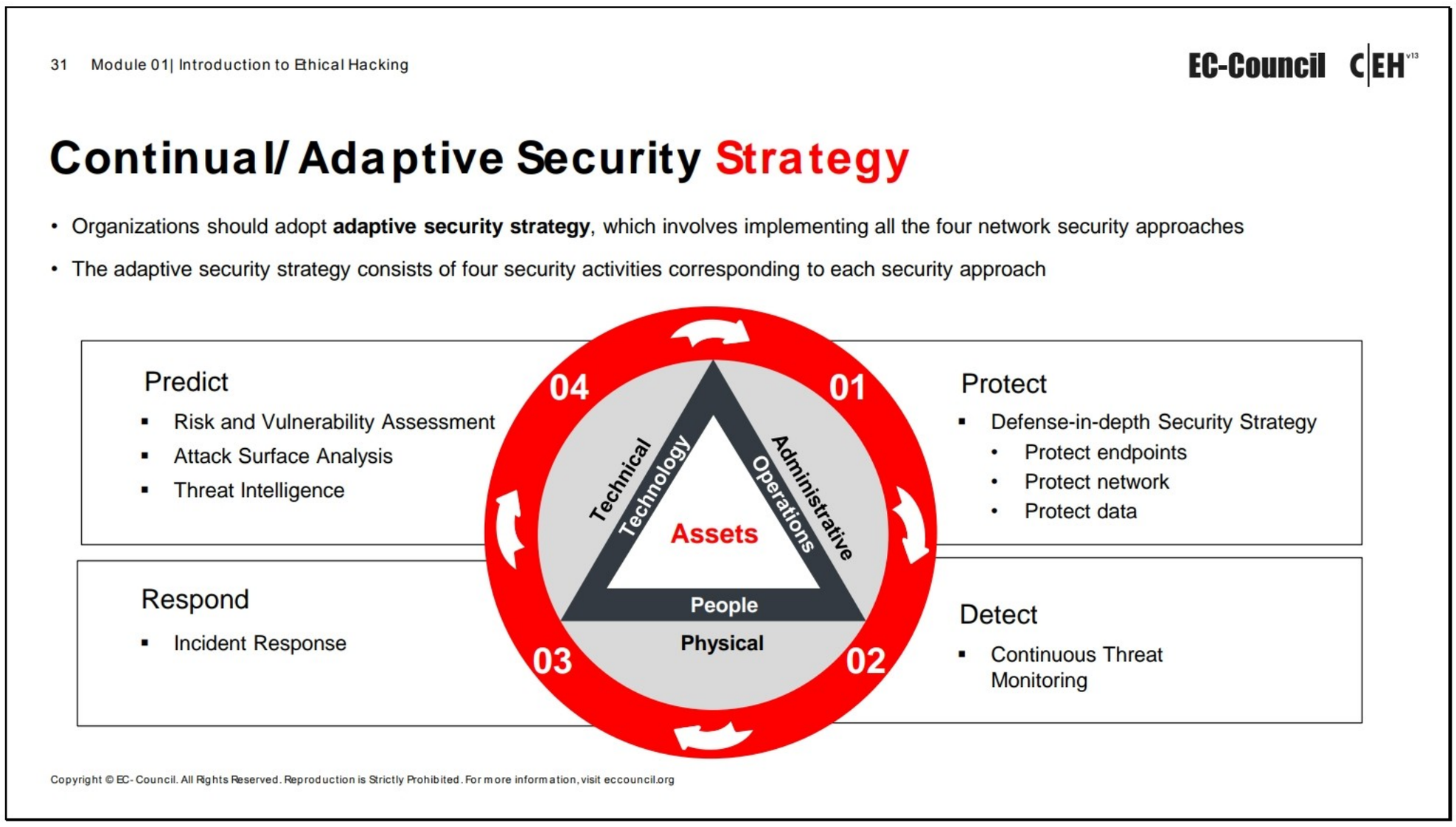
Some of the processes that help in achieving information assurance include:

- Developing local policy, process, and guidance in such a way to maintain the information systems at an optimum security level
- Designing network and user authentication strategy—Designing a secure network ensures the privacy of user records and other information on the network. Implementing an effective user authentication strategy secures the information system's data
- Identifying network vulnerabilities and threats—Vulnerability assessments outline the security posture of the network. Performing vulnerability assessments in search of network vulnerabilities and threats help to take the proper measures to overcome them
- Identifying problems and resource requirements
- Creating a plan for identified resource requirements
- Applying appropriate information assurance controls
- Performing the Certification and Accreditation (C&A) process of information systems helps to trace vulnerabilities, and implement safety measures to nullify them

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Providing information assurance training to all personnel in federal and private organizations brings among them an awareness of information technology

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Continual/Adaptive Security Strategy

The adaptive security strategy prescribes that continuous prediction, prevention, detection, and response actions must be taken to ensure comprehensive computer network defense.

- **Protection:** This includes a set of prior countermeasures taken towards eliminating all the possible vulnerabilities on the network. It includes security measures such as security policies, physical security, host security, firewall, and IDS.
- **Detection:** Detection involves assessing the network for abnormalities such as attacks, damages, unauthorized access attempts, and modifications, and identifying their locations in the network. It includes the regular monitoring of network traffic using network monitoring and packet sniffing tools.
- **Responding:** Responding to incidents involves actions such as identifying incidents, finding their root causes, and planning a possible course of actions for addressing them. It includes incident response, investigation, containment, impact mitigation, and eradication steps for addressing the incidents. It also includes deciding whether the incident is an actual security incident or a false positive.
- **Prediction:** Prediction involves the identification of potential attacks, targets, and methods prior to materialization to a viable attack. Prediction includes actions such as conducting risk and vulnerability assessment, performing attack surface analysis, consuming threat intelligence data to predict future threats on the organization.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

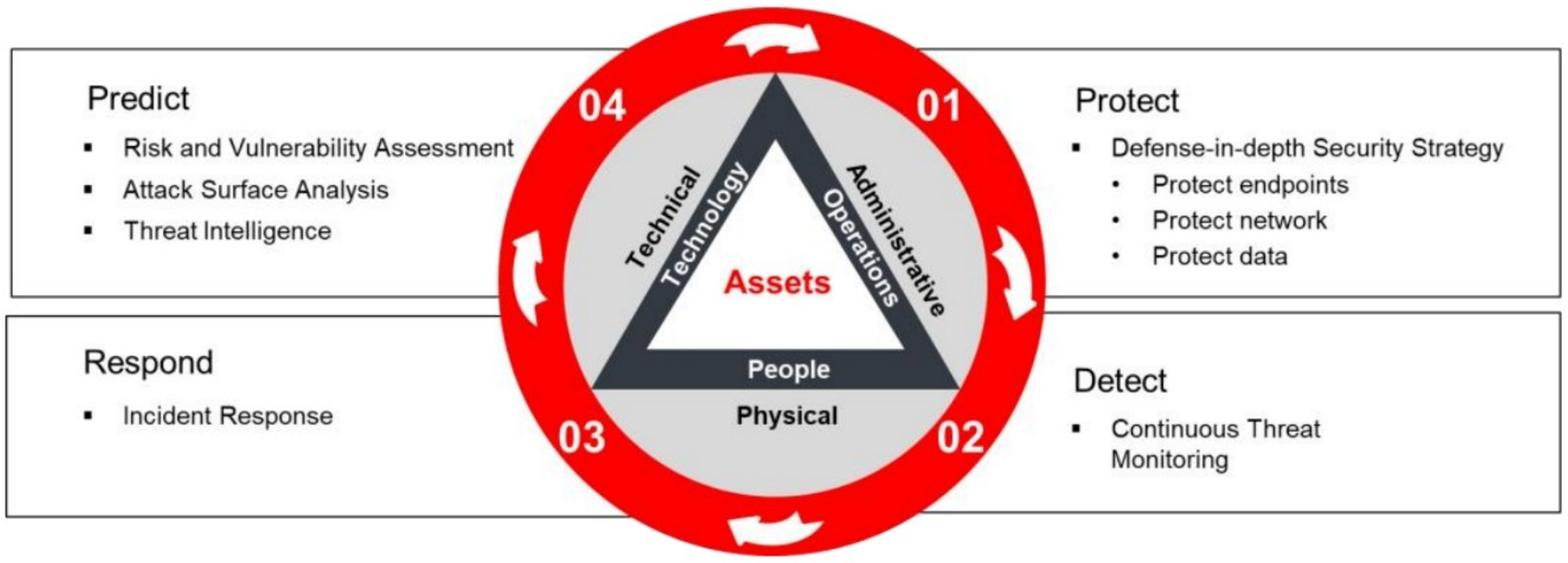
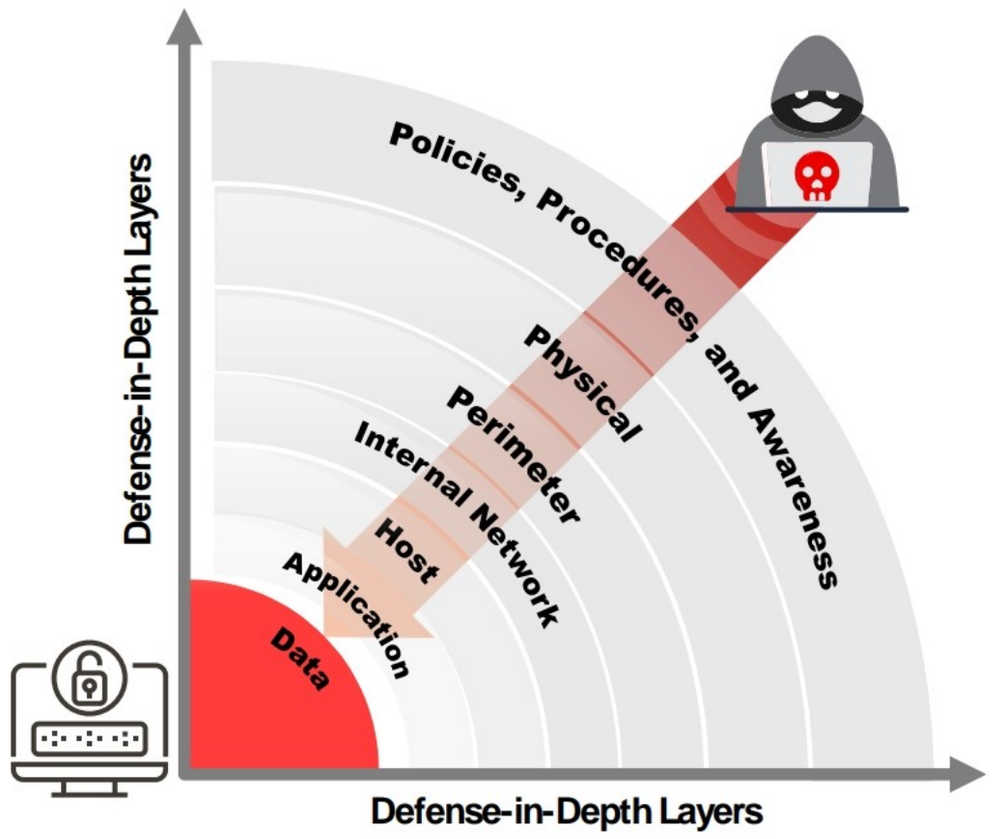


Figure 1.8: Continual/Adaptive Security Strategy

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Defense- in- Depth

- Defense-in-depth is a security strategy in which **several protection layers** are placed throughout an information system
- It helps to **prevent direct attacks** against the system and its data because a break in one layer only leads the attacker to the next layer



Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Defense-in-Depth

Defense-in-depth is a security strategy in which security professionals use several protection layers throughout an information system. This strategy uses the military principle that it is more difficult for an enemy to defeat a complex and multi-layered defense system than to penetrate a single barrier. Defense-in-depth helps to prevent direct attacks against an information system and its data because a break in one layer only leads the attacker to the next layer. If a hacker gains access to a system, defense-in-depth minimizes any adverse impact and gives administrators and engineers time to deploy new or updated countermeasures to prevent a recurrence of the intrusion.

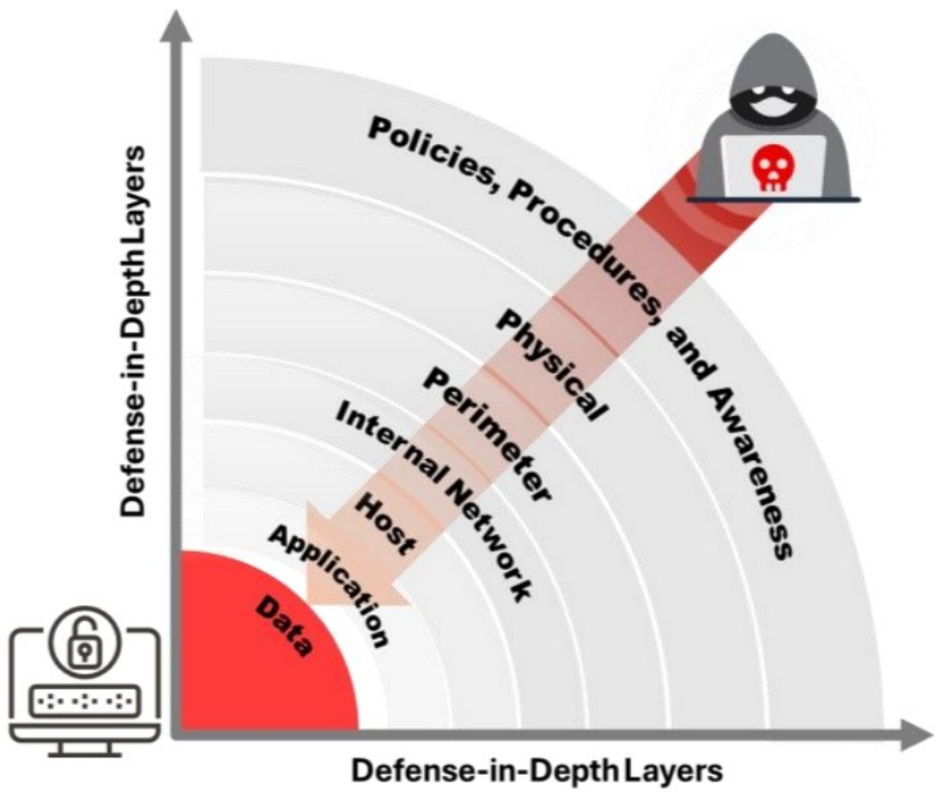


Figure 1.9: Defense in Depth

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

33 Module 01| Introduction to Ethical Hacking

EC-Council C|EH v13

What is Risk?

- Risk refers to the degree of **uncertainty** or expectation that an adverse event may cause damage to the system
- Risks are categorized into different levels according to their estimated impact on the system
- A risk matrix is used to scale risk by considering the **probability**, **likelihood**, and **consequence or impact** of the risk

Risk Levels

Risk Level	Action
Extreme or High	▪ Immediate measures should be taken to combat risk ▪ Identify and impose controls to reduce risk to a reasonably low level
Medium	▪ No urgent action is required ▪ Implement controls as soon as possible to reduce risk to a reasonably low level
Low	▪ Take preventive steps to mitigate the effects of risk

Risk Matrix

Probability		Consequences					
	Likelihood		Insignificant	Minor	Moderate	Major	Severe
81 - 100%		Very High Probability	Low	Medium	High	Extreme	Extreme
61 - 80%		High Probability	Low	Medium	High	High	Extreme
41 - 60%		Equal Probability	Low	Medium	Medium	High	High
21 - 40%		Low Probability	Low	Low	Medium	Medium	High
1 - 20%		Very Low Probability	Low	Low	Medium	Medium	High

Note: This is an example of a risk matrix. Organizations need to create their own risk matrix based on their business needs

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

What is Risk?

Risk refers to the degree of uncertainty or expectation of potential damage that an adverse event may cause to the system or its resources, under specified conditions. Alternatively, risk can also be:

- The probability of the occurrence of a threat or an event that will damage, cause loss to, or have other negative impacts on the organization, either from internal or external liabilities.
- The possibility of a threat acting upon an internal or external vulnerability and causing harm to a resource.
- The product of the likelihood that an event will occur and the impact that the event might have on an information technology asset.

The relation between Risk, Threats, Vulnerabilities, and Impact is as follows:

RISK = Threats x Vulnerabilities x Impact

The impact of an event on an information asset is the product of vulnerability in the asset and the asset's value to its stakeholders. IT risk can be expanded to

RISK = Threat × Vulnerability × Asset Value

In fact, the risk is the combination of the following two factors:

- The probability of the occurrence of an adverse event
- The consequence of the adverse event

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Risk Level

Risk level is an assessment of the resulted impact on the network. Various methods exist to differentiate the risk levels depending on the risk frequency and severity. One of the common methods used to classify risks is to develop a two-dimensional matrix.

Working out the frequency or probability of an incident happening (likelihood) and its possible consequences is necessary to analyze risks. This is referred to as the level of risk. Risk can be represented and calculated using the following formula:

Level of Risk = Consequence x Likelihood

Risks are categorized into different levels according to their estimated impact on the system. Primarily, there are four risk levels, which include extreme, high, medium, and low levels. Remember that control measures may decrease the level of a risk, but do not always entirely eliminate the risk.

Risk Level	Consequence	Action
Extreme or High	Serious or Imminent danger	➢ Immediate measures are required to combat the risk ➢ Identify and impose controls to reduce the risk to a reasonably low level
Medium	Moderate danger	➢ Immediate action is not required, but action should be implement quickly ➢ Implement controls as soon as possible to reduce the risk to a reasonably low level
Low	Negligible danger	➢ Take preventive steps to mitigate the effects of risk

Table 1.4: Risk Levels

Risk Matrix

The risk matrix scales the risk occurrence or likelihood probability, along with its consequences or impact. It is the graphical representation of risk severity and the extent to which the controls can or will mitigate it. The Risk matrix is one of the simplest processes to use for increased visibility of risk; it contributes to the management's decision-making capability. The risk matrix defines various levels of risk and categorizes them as the product of negative probability and negative severity. Although there are many standard risk matrices, individual organizations must create their own.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Probability		Consequences					
	Likelihood	Insignificant		Minor	Moderate	Major	Severe
81 - 100%		Very High Probability	Low	Medium	High	Extreme	Extreme
61 - 80%		High Probability	Low	Medium	High	High	Extreme
41 - 60%		Equal Probability	Low	Medium	Medium	High	High
21 - 40%		Low Probability	Low	Low	Medium	Medium	High
1 - 20%		Very Low Probability	Low	Low	Medium	Medium	High

Table 1.5: Risk Matrix

The above table is the graphical representation of a risk matrix, which is used to visualize and compare risks. It differentiates the two levels of risk and is a simple way of analyzing them.

- Likelihood: The chance of the risk occurring
- Consequence: The severity of a risk event that occurs

Note: This is an example of a risk matrix. Organizations must create individual risk matrices based on their business needs.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Risk Management

- Risk management is the process of **reducing and maintaining risk at an acceptable level** by means of a well-defined and actively employed security program

Risk Management Phases

Risk Identification	**Identifies the sources**, causes, consequences, and other details of the internal and external risks affecting the security of the organization
Risk Assessment	**Assesses the organization's risk** and provides an estimate of the likelihood and impact of the risk
Risk Treatment	**Selects and implements appropriate controls** for the identified risks
Risk Tracking	**Ensures appropriate controls are implemented** to handle known risks and calculates the chances of a new risk occurring
Risk Review	**Evaluates the performance** of the implemented risk management strategies

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Risk Management

Risk management is the process of identifying, assessing, responding to, and implementing the activities that control how the organization manages the potential effects of risk. It has a prominent place throughout the security life cycle and is a continuous and ever-increasing complex process. The types of risks vary from organization to organization, but the act of preparing a risk management plan is common to all organizations.

Risk Management Objectives

- Identify potential risks—this is the main objective of risk management
- Identify the impact of risks and help the organization develop better risk management strategies and plans
- Prioritize the risks, depending on the impact or severity of the risk, and use established risk management methods, tools, and techniques to assist in this task
- Understand and analyze the risks and report identified risk events.
- Control the risk and mitigate its effect.
- Create awareness among the security staff and develop strategies and plans for lasting risk management strategies.

Risk management is a continuous process performed by achieving goals at every phase. It helps reduce and maintain risk at an acceptable level utilizing a well-defined and actively employed security program. This process is applied in all stages of the organization, for example, to specific network locations in both strategic and operational contexts.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The four key steps commonly termed as risk management phases are:

- Risk Identification
- Risk Assessment
- Risk Treatment
- Risk Tracking and Review

Every organization should follow the above steps while performing the risk management process.

- **Risk Identification**

  The initial step of the risk management plan. Its main aim is to identify the risks—including the sources, causes, and consequences of the internal and external risks affecting the security of the organization before they cause harm. The risk identification process depends on the skill set of the people, and it differs from one organization to another.

- **Risk Assessment**

  This phase assesses the organization's risks and estimates the likelihood and impact of those risks. Risk assessment is an ongoing iterative process that assigns priorities for risk mitigation and implementation plans, which in turn help to determine the quantitative and qualitative value of risk. Every organization should adopt a risk evaluation process in order to detect, prioritize, and remove risks.

  The risk assessment determines the kind of risks present, their likelihood and severity, and the priorities and plans for risk control. Organizations perform a risk assessment when they identify a hazard but are not able to control it immediately. A risk assessment is followed by a regular update of all information facilities.

- **Risk Treatment**

  Risk treatment is the process of selecting and implementing appropriate controls on the identified risks in order to modify them. The risk treatment method addresses and treats the risks according to their severity level. Decisions made in this phase are based on the results of a risk assessment. The purpose of this step is to identify treatments for the risks that fall outside the department's risk tolerance and provide an understanding of the level of risk with controls and treatments. It identifies the priority order in which individual risks should be treated, monitored, and reviewed. The following information is needed before treating the risk:

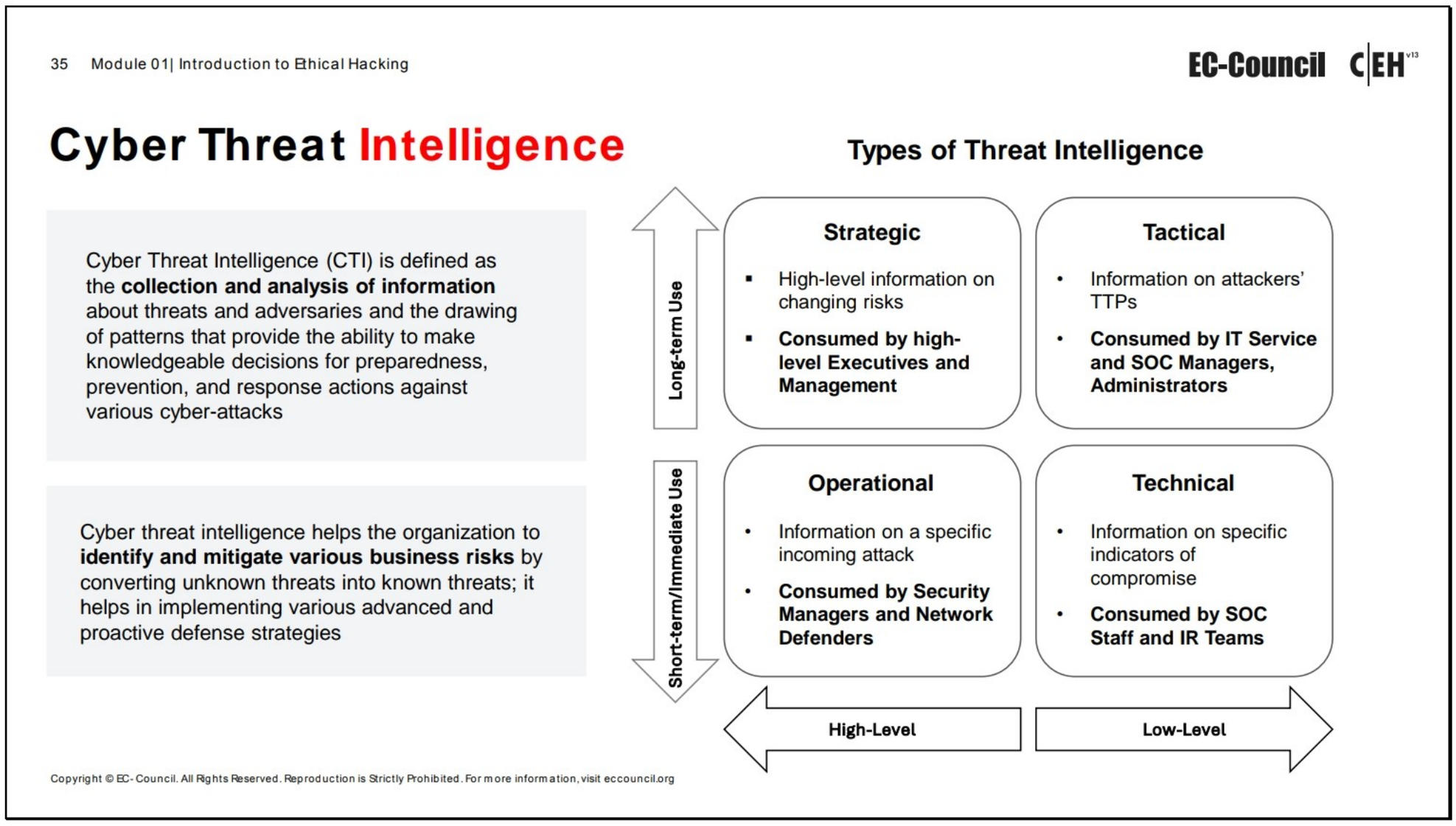
  - The appropriate method of treatment
  - The people responsible for the treatment
  - The costs involved
  - The benefits of treatment
  - The likelihood of success
  - Ways to measure and assess the treatment

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Risk Tracking and Review**

  An effective risk management plan requires a tracking and review structure to ensure effective identification and assessment of the risks as well as the use of appropriate controls and responses. The tracking and review process should determine the measures and procedures adopted and ensure that the information gathered to perform the assessment was appropriate. The review phase evaluates the performance of the implemented risk management strategies. Performing regular inspections of policies and standards, as well as regularly reviewing them, helps to identify the opportunities for improvement. Further, the monitoring process ensures that there are appropriate controls in place for the organization's activities and that all procedures are understood and followed.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Cyber Threat Intelligence

According to the Oxford dictionary, a threat is defined as "the possibility of a malicious attempt to damage or disrupt a computer network or system." A threat is a potential occurrence of an undesired event that can eventually damage and interrupt the operational and functional activities of an organization. A threat can affect the integrity and availability factors of an organization. The impact of threats is very great and may affect the state of the physical IT assets in an organization. The existence of threats may be accidental, intentional, or due to the impact of some action.

Cyber threat intelligence, usually known as CTI, is the collection and analysis of information about threats and adversaries and the drawing up of patterns that provide an ability to make knowledgeable decisions for preparedness, prevention, and response actions against various cyberattacks. It is the process of recognizing or discovering any "unknown threats" that an organization may face so that necessary defense mechanisms can be applied to avoid such occurrences. It involves collecting, researching, and analyzing trends and technical developments in the field of cyber threats (including cybercrime, hacktivism, and espionage). Any knowledge about threats that results in an organization's planning and decision-making to handle it is a piece of threat Intelligence. The main aim of CTI is to make the organization aware of existing or emerging threats and prepare them to develop a proactive cybersecurity posture in advance of exploitation. This process, where unknown threats are converted into possibly known ones, helps to anticipate the attack before it can happen, and ultimately results in a better and more secure system. Thus, threat Intelligence is useful in achieving secure data sharing and global transactions among organizations.

Threat intelligence processes can be used to identify the risk factors that are responsible for malware attacks, SQL injections, web application attacks, data leaks, phishing, denial-of-service

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

attack, and other attacks. Such risks, after being filtered out, can be put on a checklist and handled appropriately. Threat intelligence is beneficial for an organization to handle cyber threats with effective planning and execution. Along with a thorough analysis of the threat, CTI also strengthens the organization's defense system, creates awareness about impending risks, and aids in responding against such risks.

Types of Threat Intelligence

Threat intelligence is contextual information that describes threats and guides organizations in making various business decisions. It is extracted from a huge collection of sources and information. It provides operational insight by looking outside the organization and issuing alerts on evolving threats to the organization. For the better management of information that is collected from different sources, it is important to subdivide threat intelligence into different types. This subdivision is performed based on the consumers and goals of the intelligence. From the perspective of consumption, threat intelligence is divided into four different types. They are, namely, strategic, tactical, operational, and technical threat intelligence. These four types differ in terms of data collection, data analysis, and intelligence consumption.

- **Strategic Threat Intelligence**

  Strategic threat intelligence provides high-level information regarding cybersecurity posture, threats, details about the financial impact of various cyber activities, attack trends, and the impact of high-level business decisions. This information is consumed by the high-level executives and management of the organization, such as IT management and CISO. It helps the management to identify current cyber risks, unknown future risks, threat groups, and attribution of breaches. The intelligence obtained provides a risk-based view that mainly focuses on high-level concepts of risks and their probability. It mainly deals with long-term issues and provides real-time alerts for threats to the organization's critical assets, such as IT infrastructure, employees, customers, and applications. This intelligence is used by the management to make strategic business decisions and to analyze their effect. Based on the analysis, the management can allocate sufficient budget and staff to protect critical IT assets and business processes.

  Strategic threat intelligence is generally in the form of a report that mainly focuses on high-level business strategies. Since the characteristic of strategic threat intelligence is preeminent, the data collection also relates to high-level sources and requires highly skilled professionals to extract information. This intelligence is collected from sources such as OSINT, CTI vendors, and ISAOs and ISACs.

  The strategic threat intelligence helps organizations identify any similar past incidents, their intentions, and any attributes that might identify the attacking adversaries, why the organization is within the scope of the attack, major attack trends, and how to reduce the risk level.

  Generally, strategic threat intelligence includes the following information:

  - The financial impact of cyber activity
  - Attribution for intrusions and data breaches

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Threat actors and attack trends
- The threat landscape for various industry sectors
- Statistical information on data breaches, data theft, and malware
- Geopolitical conflicts involving various cyberattacks
- Information on how adversary TTPs change over time
- Industry sectors that might impact due to high-level business decisions

- **Tactical Threat Intelligence**

  Tactical threat intelligence plays a major role in protecting the resources of the organization. It provides information related to the TTPs used by threat actors (attackers) to perform attacks. Tactical threat intelligence is consumed by cybersecurity professionals such as IT service managers, security operations managers, network operations center (NOC) staff, administrators, and architects. It helps the cybersecurity professionals understand how the adversaries are expected to perform their attack on the organization, identify the information leakage from the organization, and assess the technical capabilities and goals of the attackers along with the attack vectors. Using tactical threat intelligence, security personnel develop detection and mitigation strategies beforehand through procedures such as updating security products with identified indicators and patching vulnerable systems.

  The collection sources for tactical threat intelligence include campaign reports, malware, incident reports, attack group reports, and human intelligence, among other information. This intelligence is generally obtained by reading white or technical papers, communicating with other organizations, or purchasing intelligence from third parties. It includes highly technical information on topics such as malware, campaigns, techniques, and tools in the form of forensic reports.

  Tactical threat intelligence provides day-to-day operational support by helping analysts assess various security incidents related to events, investigations, and other activities. It also guides the high-level executives of the organizations in making strategic business decisions.

- **Operational Threat Intelligence**

  Operational threat intelligence provides information about specific threats against the organization. It provides contextual information about security events and incidents that help defenders disclose potential risks, provide greater insight into attacker methodologies, identify past malicious activities, and perform investigations on malicious activity in a more efficient way. It is consumed by security managers or heads of incident response, network defenders, security forensics, and fraud detection teams. It helps organizations to understand the possible threat actors and their intention, capability, and opportunity to attack vulnerable IT assets and the impact of a successful attack. In many cases, only government organizations can collect this type of intelligence. However, doing so helps IR and forensic teams to deploy security assets to

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

identify and stop upcoming attacks, improve early-stage attack detecting capability, and reduce an attack's damage to IT assets.

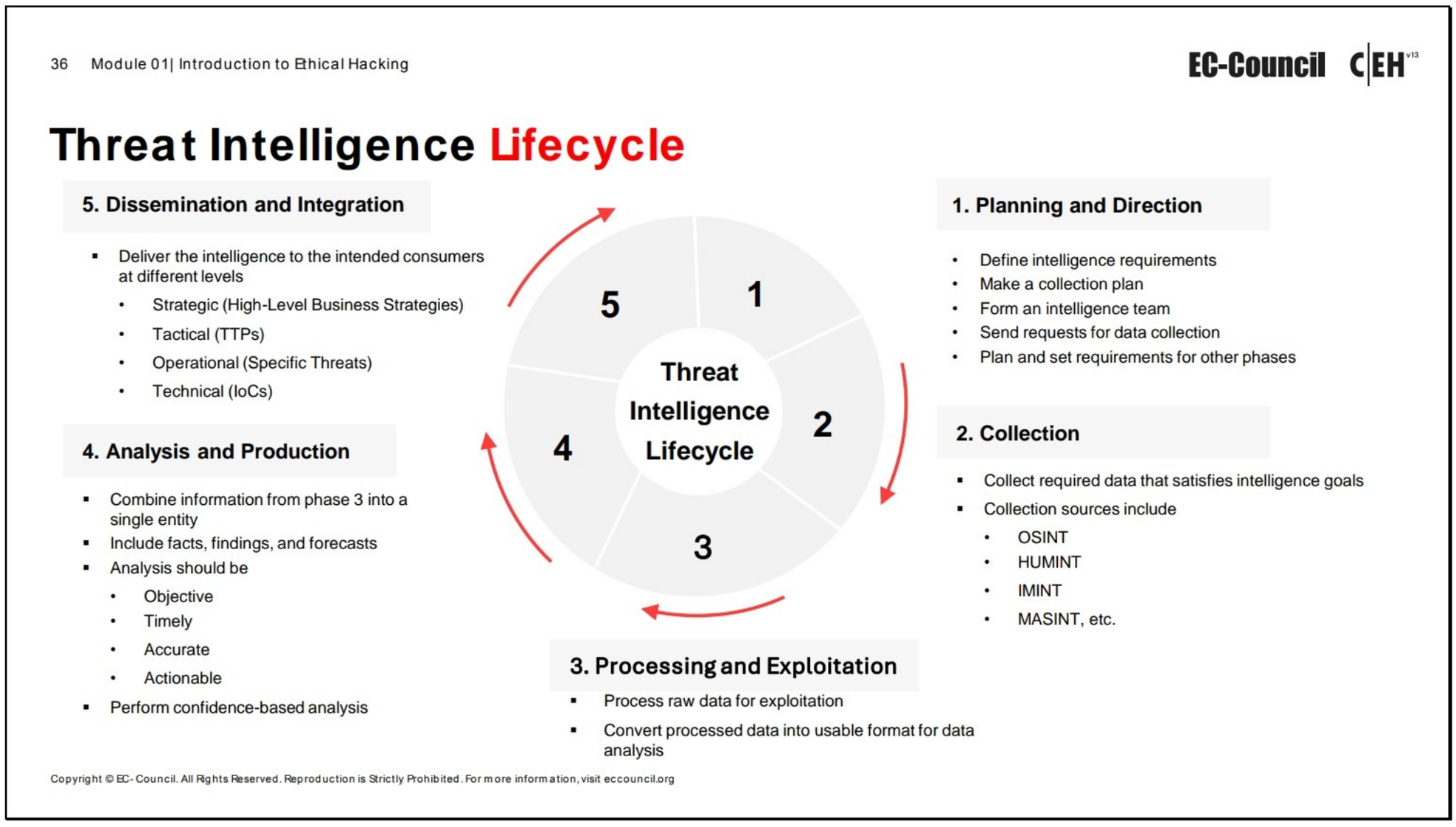
Operational threat intelligence is generally collected from sources such as humans, social media, and chat rooms; it may and also be collected from the real-world activities and events that result in cyberattacks. Operational threat intelligence is obtained by analyzing human behavior, threat groups, and by similar means. This information helps to predict future attacks and thus enhances incident response plans and mitigation strategies. Operational threat intelligence generally appears as a report that contains identified malicious activities, recommended courses of action, and warnings of emerging attacks.

- **Technical Threat Intelligence**

  Technical threat intelligence provides information about resources an attacker uses to perform an attack; this includes command and control channels, tools, and other items. It has a shorter lifespan compared to tactical threat intelligence and mainly focuses on a specific IoC. It provides rapid distribution and response to threats. For example, a piece of malware used to perform an attack is tactical threat intelligence, whereas the details related to the specific implementation of the malware come under technical threat intelligence. Other examples of technical threat intelligence include the specific IP addresses and domains used by malicious endpoints, phishing email headers, and hash checksums of malware, among others. Technical threat intelligence is consumed by SOC staff and IR teams.

  The indicators of technical threat intelligence are collected from active campaigns, attacks that are performed on other organizations, or data feeds provided by external third parties. These indicators are generally collected as part of investigations of attacks performed on various organizations. This information helps security professionals add the identified indicators to the defensive systems such as IDS and IPS, firewalls, and endpoint security systems, thereby enhancing the detection mechanisms used to identify the attacks at an early stage. It also helps them identify malicious traffic and IP addresses suspected of spreading malware and spam emails. This intelligence is directly fed into the security devices in digital format to block and identify inbound and outbound malicious traffic entering the organization's network.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Threat Intelligence Lifecycle

The threat intelligence lifecycle is a continuous process of developing intelligence from raw data that supports organizations to develop defensive mechanisms to thwart emerging risks and threats. The higher-level executives of the organization will provide continuous support to the intelligence team by evaluating and giving feedback at every stage.

The threat intelligence lifecycle consists of five phases: planning and direction, collection, processing and exploitation, analysis and production, and dissemination and integration.

- **Planning and Direction**

  In this phase, proper plan is developed based on the strategic intelligence requirement, for example, what are the requirements for developing the threat intelligence, which intelligence information should be given priority, etc. This phase defines the entire intelligence program from data collection to delivery of final intelligence product and acts as a basis for the complete intelligence process. It also includes identifying the requirements of data, methods to be used to collect data, and establishing a collection plan. The requirements are set in such a way that effective and genuine intelligence data can be gathered using the constant number of resources from various open sources of intelligence (OSINT). Along with the requirements, requests are sent to collect data from various internal and external sources. During this phase, an intelligence team is formed, and their key roles and responsibilities are also formulated. Also, the planning and requirements are set for the later stages of the cycle to provide proper support for its functioning.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Collection**

  In this phase, we need to focus more on collecting the desired intelligence that is defined in phase one. The data can be collected in different ways through either technical or human means. The collection of the information can be performed directly or secretly based on the confidentiality of the information. The intelligence is collected through sources like human intelligence (HUMINT), imagery intelligence (IMINT), measurement and signature intelligence (MASINT), signal intelligence (SIGNT), open source intelligence (OSINT), and IoCs, and other third parties. This includes collecting data from critical applications, network infrastructure, security infrastructure, etc. Once the collection process is done, the data is transferred for processing in the next stage.

- **Processing and Exploitation**

  Until this phase, the data is not in a proper format, and it is in the form of raw data. The data obtained from previous phases is processed for exploitation and transformed into useful information that could be understood by the consumers. The raw data is converted into meaningful information by highly trained professionals using sophisticated technology and tools. This interpreted data is converted into a usable format that can be directly used in the data analysis phase. The processing to be effective requires proper understanding of the data collection plan, requirements of the consumer, analytical strategy, and types of data that are being processed. Many automated tools are used to apply data processing functions such as structuring, decryption, language translation, parsing, data reduction, filtering, data correlation, and data aggregation.

- **Analysis and Production**

  After processing the intelligence into a proper format, analyzing the intelligence for getting refined information is performed in this phase. The analysis includes facts, findings, and forecasts, which enable the estimation and anticipation of attacks and results. The analysis should be objective, timely, accurate, and actionable. To extract timely and accurate information, analysts need to implement four types of reasoning techniques, which include deduction, induction, abduction, and scientific method based on confidence. As the information is obtained from different sources, analysts try to combine these various sources into a single entity in this phase.

  The raw data is converted into information by applying various data analysis techniques such as qualitative and quantitative analyses, machine-based techniques, and statistical methods. When the analyzed information provides sufficient context for identifying a threat, then it is elevated to intelligence. This phase identifies potential threats to the organization and further helps in developing appropriate countermeasures to respond to the identified threats.

- **Dissemination and Integration**

  The analyzed information is then ready for the integration and distribution to the intended consumers, which is done either by automated means or by manual methods.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Major threat information types that are generally used for dissemination include threat indicators, adversary TTPs, security alerts, threat intelligence reports, and tool configuration information for using tools to automate all the phases of threat intelligence. Different intelligence reports are generated to meet the requirements of the management and higher-level executives at strategic, operational, tactical, and technical levels.

The strategic threat intelligence is consumed by high-level executives and management and focuses on high-level business strategies. The operational threat intelligence is consumed by cyber security professionals such as security managers and network defenders and mainly focuses on specific threats to the organizations. The tactical threat intelligence is consumed by cyber security professionals such as IT service and SOC managers, administrators and architects and focuses on adversary's TTPs. The technical threat intelligence is consumed by SOC staff and IR teams and includes information related to the identified IoCs. The disseminated intelligence helps organizations in building defensive and mitigation strategies for the identified threats. Sharing threat intelligence internally and externally helps the organizations gain situational awareness and also to enhance the current security posture and risk management processes.

This phase also provides feedback giving more inputs to the information requirements thereby repeating the threat intelligence lifecycle. The feedback is an assessment that describes whether the extracted intelligence meets the requirements of the intelligence consumer. This feedback helps in producing more accurate intelligence through relevant and timely assessments.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Threat Modeling

Threat modeling is a **risk assessment approach** for analyzing the security of an application by capturing, organizing, and analyzing all the information that affects the security of an application

Threat Modeling Process

1 **Identify Security Objectives**	Helps to determine how much **effort needs to be put** toward subsequent steps
2 **Application Overview**	Identify the **components**, **data flows**, and trust boundaries
3 **Decompose the Application**	Helps to find more relevant and more **detailed threats**
4 **Identify Threats**	Identify threats relevant to the **control** scenario and context using the information obtained in steps 2 and 3
5 **Identify Vulnerabilities**	**Identify weaknesses** related to the threats found using **vulnerability categories**

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Threat Modeling

Threat modeling is a risk assessment approach for analyzing the security of an application by capturing, organizing, and analyzing all the information that affects it. The threat model consists of three major building blocks: understanding the adversary's perspective, characterizing the security of the system, and determining threats. Every application should have a developed and documented threat model that should be revisited as the application evolves and development progresses.

Threat modeling helps to:

- Identify relevant threats to a particular application scenario
- Identify key vulnerabilities in an application's design
- Improve security design

When using this approach, an administrator should keep the following in mind:

- Try not to be rigid about specific steps or implementations; instead, focus on the approach. If any step becomes impassable, go right to step 4 of the threat modeling process and identify the problem.
- Use scenarios to scope the modeling activity.
- Use existing design documents. Use items like documented use cases or use stories, architectural diagrams, data flow diagrams, or other design documentation.
- Start with a whiteboard before capturing information in documents or getting lost in details. It may be helpful to use a digital camera with printing capabilities to document and distribute the information from the whiteboard.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Use an iterative approach. Add more details and improve the threat model as design and development continue. This will help with becoming familiar with the modeling process and developing the threat model to better examine more possible scenarios.
- Obtain input about the host and network constraints from the system and network administrators. To better understand the end-to-end deployment diagram, obtain as much information as possible about host configurations, firewall policies, allowed protocols and ports, and other relevant details.

The threat modeling process involves five steps:

1. **Identify Security Objectives**

   Security objectives are the goals and constraints related to the application's confidentiality, integrity, and availability. Security-specific objectives guide the threat modeling efforts and help to determine how much effort needs to be put toward subsequent steps. To identify security objectives, administrators should ask the following questions:

   - What data should be protected?
   - Are there any compliance requirements?
   - Are there specific quality-of-service requirements?
   - Are there intangible assets to protect?

2. **Application Overview**

   Identify the components, data flows, and trust boundaries. To draw the end-to-end deployment scenario, the administrator should use a whiteboard. First, they should draw a rough diagram that explains the workings and structure of the application, its subsystems, and its deployment characteristics. The deployment diagram should contain the following:

   - End-to-end deployment topology
   - Logical layers
   - Key components
   - Key services
   - Communication ports and protocols
   - Identities
   - External dependencies

   Identify Roles

   The administrator should identify people and the roles and actions they can perform within the application. For example, are there higher-privileged groups of users? Who can read data? Who can update data? Who can delete data?

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Identify Key Usage Scenarios

The administrator should use the application's use cases to determine its objective. Use cases explain how the application is used and misused.

Identify Technologies

The administrator should list the technologies and key features of the software, as well as the following technologies in use:

- Operating systems
- Web server software
- Database server software
- Technologies for presentation, business, and data access layers
- Development languages

Identifying these technologies helps to focus on technology-specific threats.

Identify Application Security Mechanisms

The administrator should identify some key points regarding the following:

- Input and data validation
- Authorization and authentication
- Sensitive data
- Configuration management
- Session management
- Parameter manipulation
- Cryptography
- Exception management
- Auditing and logging

These efforts aim to identify relevant details and to add details where required, or to identify areas that require more.

3. Decompose the Application

In this step, the administrator breaks down the application to identify the trust boundaries, data flows, entry points, and exit points. Doing so makes it considerably easier to find more relevant and more detailed threats and vulnerabilities.

Identify Trust Boundaries

Identifying the application's trust boundaries helps the administrator to focus on the relevant areas of the application. It indicates where trust levels change.

- Identify outer system boundaries

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Identify access control points or key places where access requires extra privileges or role membership
- Identify trust boundaries from a data flow perspective

Identify Data Flows

The administrator should list the application's data input from entry to exit. This helps to understand how the application communicates with outside systems and clients and how the internal components interact. They should pay particular attention to the data flow across trust boundaries and the data validation at the trust boundary entry point. A good approach is to start at the highest level and then deconstruct the application by testing the data flow between different subsystems.

Identify Entry Points

The application's entry point can also serve as an entry point for attacks. All users interact with the application at these entry points. Other internal entry points uncovered by subcomponents over the layers of the application may be present only to support internal communication with other components. The administrator should identify these entry points to determine the methods used by an intruder to get in through them. They should focus on the entry points that allow access to critical functionalities and provide adequate defense for them.

Identify Exit Points

The administrator should also identify the points where the application transfers data to the client or external systems. They should prioritize the exit points at which the application writes data containing client input or data from untrusted sources, such as a shared database.

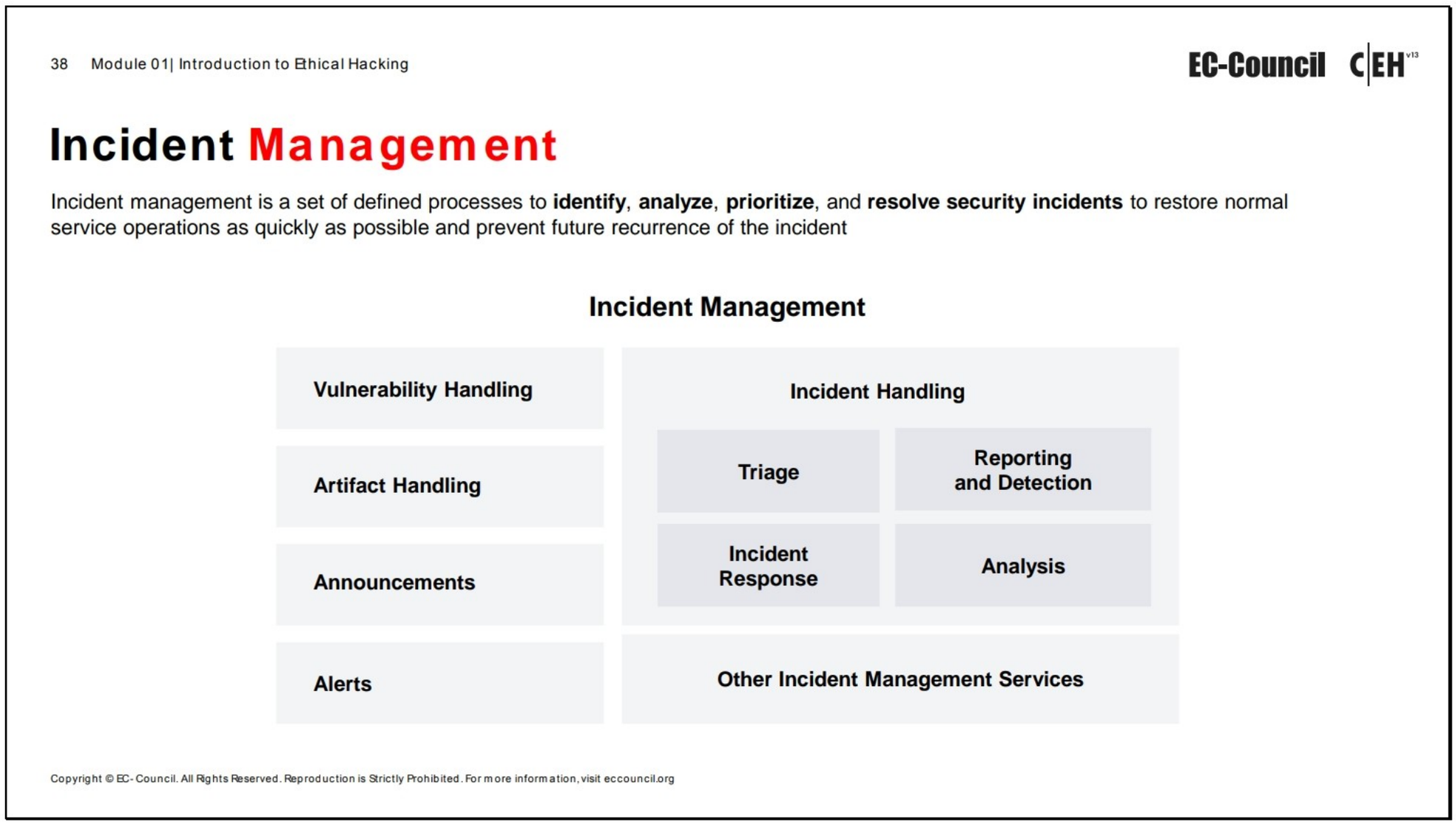
4. **Identify Threats**

   The administrator should identify threats relevant to the control scenario and context using the information obtained in the application overview and decompose application steps. They should bring members of the development and test teams together to identify potential threats. The team should start with a list of common threats grouped by their application vulnerability category. This step uses a question-driven approach to help identify threats.

5. **Identify Vulnerabilities**

   A vulnerability is a weakness in an application (deployed in an information system) that allows attacker exploitation, thereby leading to security breaches. Security administrators should identify any weaknesses related to the threats found using the vulnerability categories to identifying vulnerabilities and fix them beforehand to keep intruders away.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Incident Management

Incident management is a set of defined processes to identify, analyze, prioritize, and resolve security incidents to restore the system to normal service operations as soon as possible, and prevent recurrence of the incident. It involves not only responding to incidents but also triggering alerts to prevent potential risks and threats. A security administrator must identify software that is open to attacks before someone takes advantage of the vulnerabilities.

Incident management includes the following:

- Vulnerability analysis
- Artifact analysis
- Security awareness training
- Intrusion detection
- Public or technology monitoring

The incident management process is designed to:

- Improve service quality
- Resolve problems proactively
- Reduce the impact of incidents on an organization or its business
- Meet service availability requirements
- Increase staff efficiency and productivity
- Improve user and customer satisfaction
- Assist in handling future incidents

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Conducting training sessions to spread awareness among users is an important part of incident management. Such sessions help end-users to recognize suspicious events or incidents easily and report an attacker's behavior to the appropriate authority.

The following people perform incident management activities:

- Human resources personnel take steps to fire employees suspected of harmful computer activities.
- The legal counsel sets the rules and regulations in an organization. These rules can influence the internal security policies and practices of the organization in case an insider or an attacker uses the organization's system for harmful or malicious activities.
- The firewall manager keeps filters in place. These filters are frequently where denial-of-service attacks are made.
- An outsourced service provider repairs systems infected by viruses and malware.

Incident response is one of the functions performed in incident handling. In turn, incident handling is one of the services provided as part of incident management. The following diagram illustrates the relationship between incident response, incident handling, and incident management.

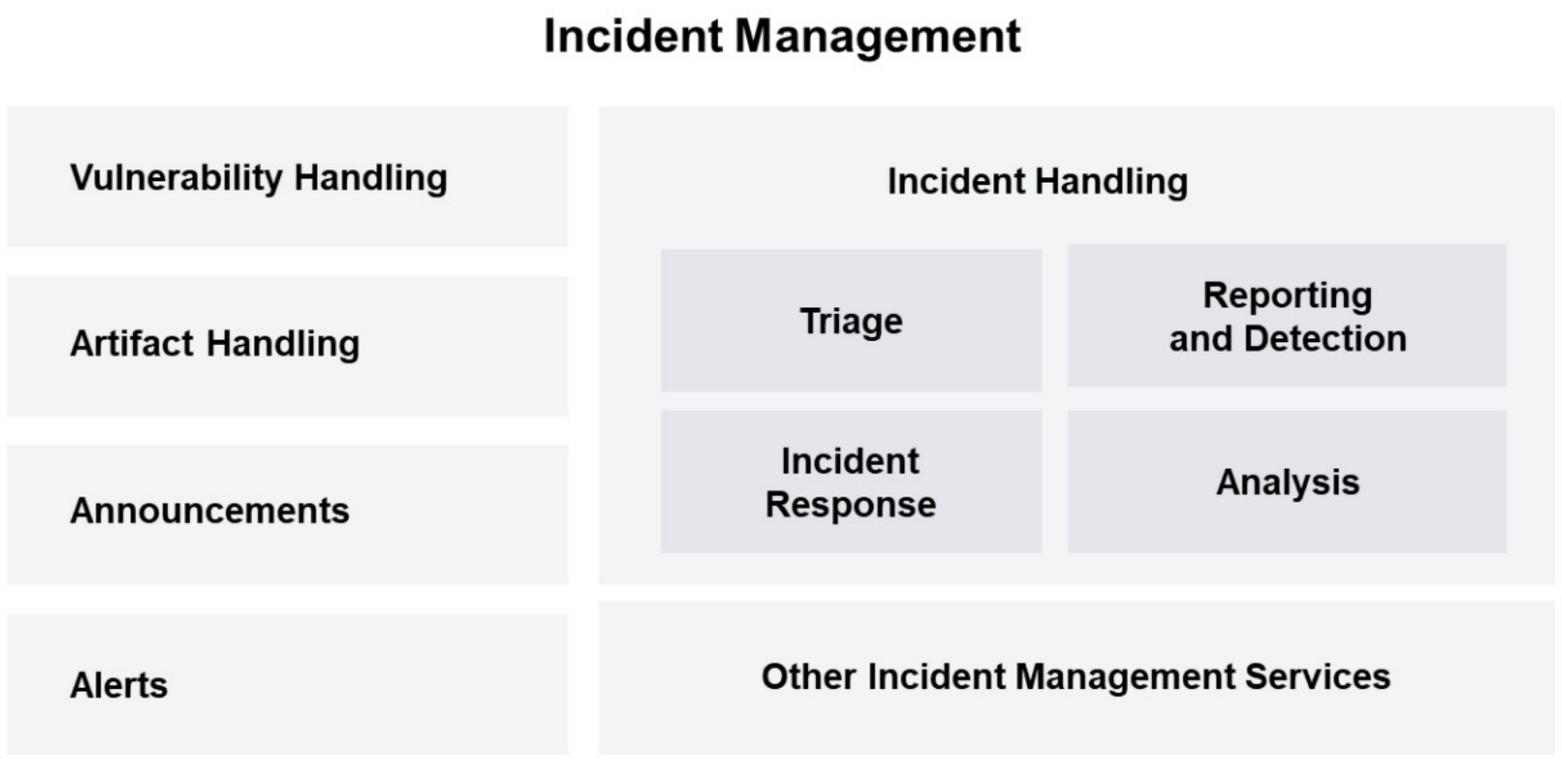
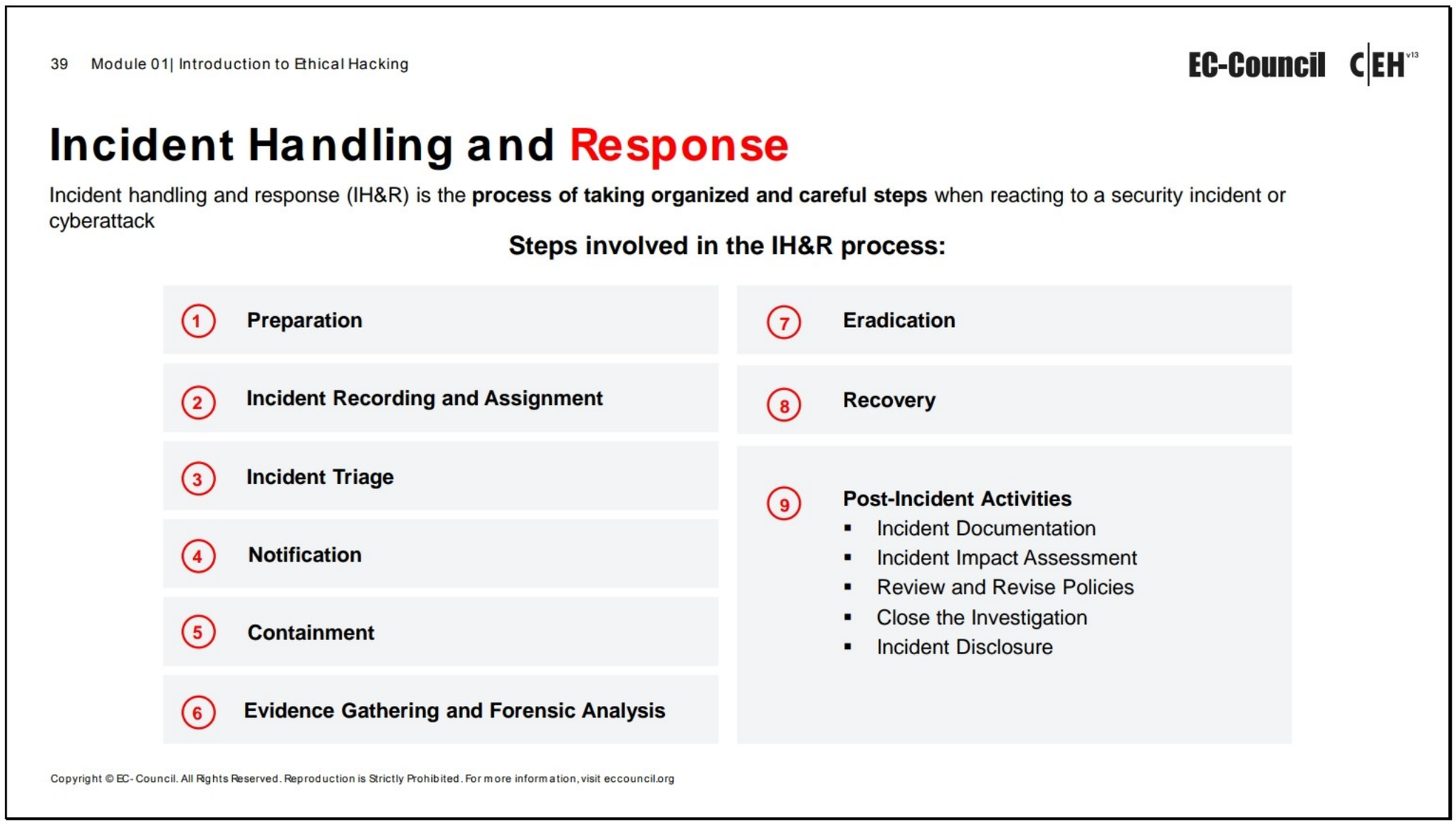


Figure 1.10: Block Diagram of Incident Management

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Incident Handling and Response

Incident handling and response (IH&R) is the process of taking organized and careful steps when reacting to a security incident or cyberattack. It is a set of procedures, actions, and measures taken against an unexpected event occurrence. It involves logging, recording, and resolving incidents that take place in the organization. It notes the incident, when it occurred, its impact, and its cause. It is the practice of managing the incident response processes, such as preparation, detection, containment, eradication, and recovery, to overcome the impact of an incident quickly and efficiently. IH&R processes are important to provide a focused approach for restoring normal business operations as quickly as possible after an incident and with a minimal impact on the business.

The IH&R process involves defining user policies, developing protocols, building incident response teams, auditing organizational assets, planning incident response procedures, obtaining management approval, incident reporting, prioritization, and managing response. It also includes establishing proper communication between the individuals responding to an incident and guiding them to detect, analyze, contain, recover, and prevent incidents.

Discussed below are the steps involved in the IH&R process:

- **Step 1: Preparation**

  The preparation phase includes performing an audit of resources and assets to determine the purpose of security and define the rules, policies, and procedures that drive the IH&R process. It also includes building and training an incident response team, defining incident readiness procedures, and gathering required tools as well as training the employees to secure their systems and accounts.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step 2: Incident Recording and Assignment**

  In this phase, the initial reporting and recording of the incident take place. This phase handles identifying an incident and defining proper incident communication plans for the employees and also includes communication methods that involve informing IT support personnel or submitting an appropriate ticket.

- **Step 3: Incident Triage**

  In this phase, the identified security incidents are analyzed, validated, categorized, and prioritized. The IH&R team further analyzes the compromised device to find incident details such as the type of attack, its severity, target, impact, and method of propagation, and any vulnerabilities it exploited.

- **Step 4: Notification**

  In the notification phase, the IH&R team informs various stakeholders, including management, third-party vendors, and clients, about the identified incident.

- **Step 5: Containment**

  This phase helps to prevent the spread of infection to other organizational assets, preventing additional damage.

- **Step 6: Evidence Gathering and Forensic Analysis**

  In this phase, the IH&R team accumulates all possible evidence related to the incident and submits it to the forensic department for investigation. Forensic analysis of an incident reveals details such as the method of attack, vulnerabilities exploited, security mechanisms averted, network devices infected, and applications compromised.

- **Step 7: Eradication**

  In the eradication phase, the IH&R team removes or eliminates the root cause of the incident and closes all the attack vectors to prevent similar incidents in the future.

- **Step 8: Recovery**

  After eliminating the causes for the incidents, the IH&R team restores the affected systems, services, resources, and data through recovery. It is the responsibility of the incident response team to ensure that that the incident causes no disruption to the services or business of the organization.

- **Step 9: Post-Incident Activities**

  Once the process is complete, the security incident requires additional review and analysis before closing the matter. Conducting a final review is an important step in the IH&R process that includes:

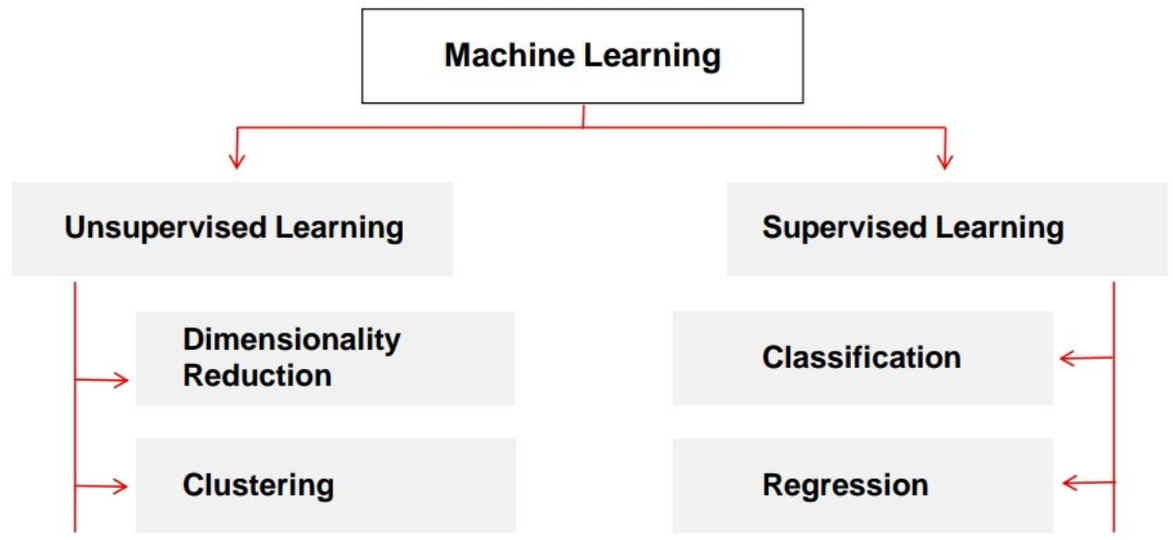
  - Incident documentation
  - Incident impact assessment
  - Reviewing and revising policies
  - Closing the investigation
  - Incident disclosure

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Role of AI and ML in Cyber Security

- Machine learning (ML) and artificial intelligence (AI) are now vastly used across various industries and applications due to the **increase in computing power**, **data collection**, and **storage capabilities**
- ML is an **unsupervised self-learning system** that is used to define what the normal network looks like, along with its devices, and then to backtrack and **report any deviations or anomalies** in real-time
- AI and ML in cyber security helps in **identifying new exploits and weaknesses**, which can then be easily analyzed to mitigate further attacks

- ML classification techniques:
  - Supervised learning makes use of algorithms that input a **set of labeled training data**, with the aim of learning the differences between the labels
  - Unsupervised learning makes use of algorithms that input **unlabeled training data**, with the aim of deducing all categories by itself



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Role of AI and ML in Cyber Security

Machine learning (ML) and Artificial Intelligence (AI) are now popularly used across various industries and applications due to the increase in computing power, data collection, and storage capabilities.

Along with technological advancements in AI, such as self-driving cars, language translators, and big data, there is also a rise in threats such as ransomware, botnets, malware, and phishing. Using AI and ML in cybersecurity helps to identify new exploits and weaknesses, which can be easily analyzed to mitigate further attacks. It reduces the pressure on security professionals and alerts them whenever an action is needed.

What are AI and ML?

Artificial Intelligence is the only solution to defend networks against the various attacks that an antivirus scan cannot detect. A huge amount of collected data is fed into the AI, which processes and analyzes it to understand its details and trends.

ML is a branch of artificial intelligence (AI) that gives the systems the ability to self-learn without any explicit programs. This self-learning system is used to define what the normal network, along with its devices, looks like, and then uses this to backtrack and report any deviations or anomalies in real-time.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

There are two types of ML classification techniques:

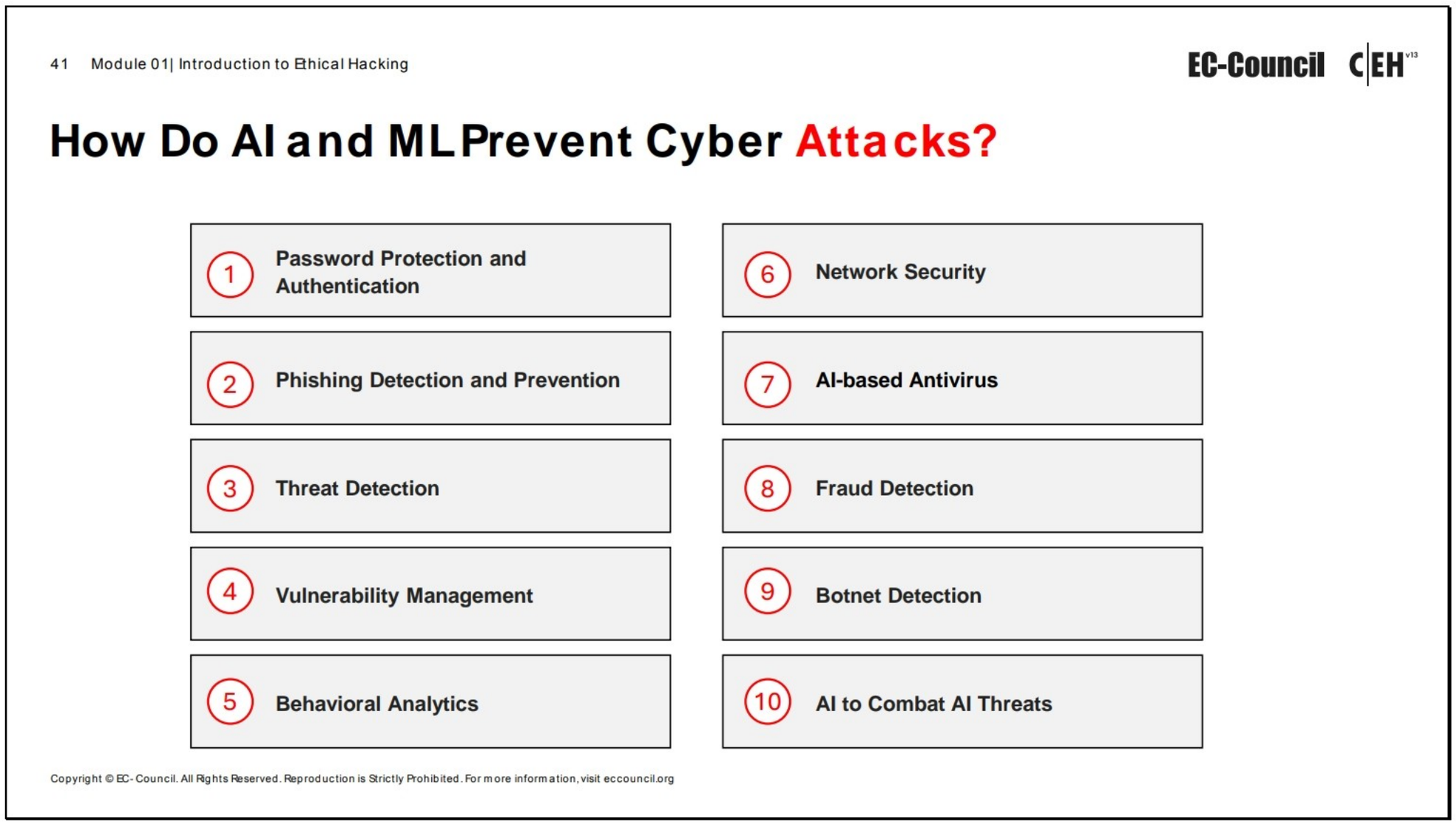
- **Supervised Learning**

  Supervised learning uses algorithms that input a set of labeled training data to attempt to learn the differences between the given labels. Supervised learning is further divided into two subcategories, namely, classification and regression. Classification includes completely divided classes. Its main task is to define the test sample to identify its class. Regression is used when data classes are not separated, such as when the data is continuous.

- **Unsupervised Learning**

  Unsupervised learning makes use of algorithms that input unlabeled training data to attempt to deduce all the categories without guidance. Unsupervised learning is further divided into two subcategories, namely, clustering and dimensionality reduction. Clustering divides the data into clusters based on their similarities, regardless of class information. Dimensionality reduction is the process of reducing the dimensions (attributes) of data.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How Do AI and ML Prevent Cyber Attacks?

Artificial Intelligence (AI), and with it, Machine Learning (ML), is an emerging technology in the field of cybersecurity. It is widely adopted by largescale industries such as automation, IT services, manufacturing, production, and finance. AI plays a crucial role in detecting imminent cyber threats by incorporating machine learning as a subset.

Following are different ways that AI and ML safeguard industries from cybersecurity attacks:

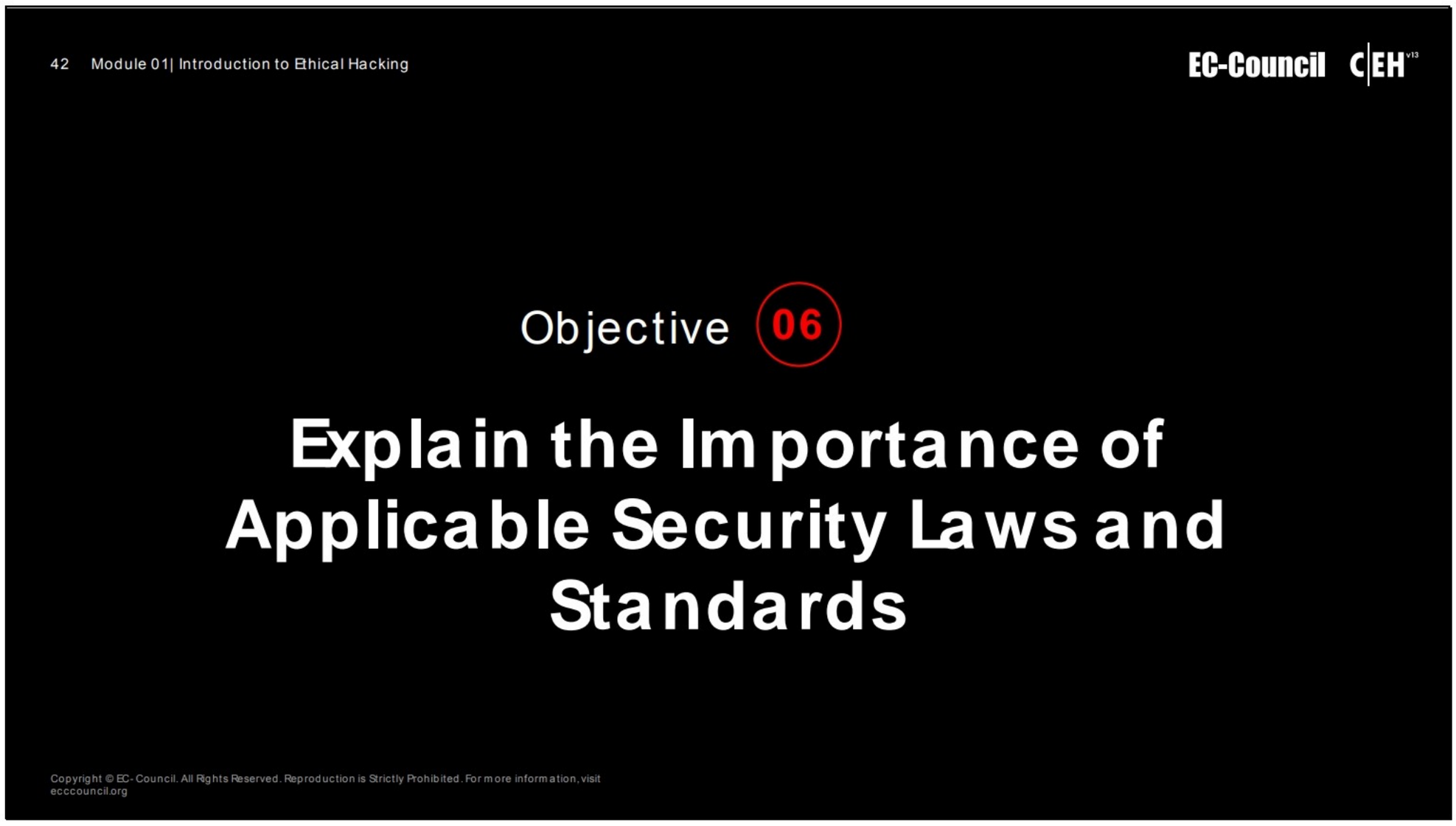
- **Password Protection and Authentication:** Password credentials play a critical role in preventing illegitimate access to the organization's or user's data. If credentials are compromised, the reputation of the organization or person could be damaged. Sometimes, traditional face detection and other biometric security measures can also be vulnerable to these credential breaches. Programmers use AI to improve biometric validations and face recognition to thwart such attacks. AI provides the latest models for recognizing an individual's face by tracking key correlations and patterns.
- **Phishing Detection and Prevention:** Phishing is a common method attackers employ to send their payloads via emails. The majority of users cannot figure out which received emails have a malicious attachment or payload. In this case, AI and ML could play a pivotal role in identifying and preventing such phishing attacks. They can scan and identify phishing emails much faster than a human being can. They can also quickly differentiate malicious websites from legitimate websites.
- **Threat Detection:** Machine learning assists companies in detecting cyber-attacks before systems are compromised. Being a part of AI, machine learning constantly keeps admins notified of imminent cyber threats by carrying out logical data analysis. ML allows systems to run its algorithms upon the data being received, then performs deep learning

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

on the and comprehends the advancements required to ensure the safety of the information systems.

- **Vulnerability Management:** AI and ML-based systems never allow vulnerability to exist for long; they dynamically scan for all types of vulnerabilities and alert the admins before the system is exploited. They can also provide the attacker's information and the patterns used to perform the attack. These AI- and ML-based systems can also forecast how and when a vulnerability exploitation might occur.
- **Behavioral Analytics:** Another notable security improvement by artificial intelligence is "Behavioral Analytics." Attackers who have stolen the credentials of a legitimate user can perform malicious activities on the organization's network; such attempts are difficult to detect and thwart. Here, AI with ML generates specific user patterns based on their regular usage. AI software instantly alerts the admin if it detects any suspicious activity or deviation in regular usage.
- **Network Security:** Two significant factors of network security are generating comprehensive security policies and mapping an enterprise's network topology. Unfortunately, both of these factors are time-consuming. Therefore, administrators are adopting AI to enhance this operation; it can carry out the network traffic analysis and propose efficient security policies by default.
- **AI-based Antivirus:** Traditional antivirus tools perform file scanning on the organization's networks to check if any signatures match those of known viruses or malware. The issue with this is that antivirus tools must be updated when the user wants to scan for new malware or viruses. Updating is time-consuming, and new deployment often takes a certain amount of time. To overcome these issues, organizations employ AI-based antiviruses, which use anomaly detection to understand programs' behavior. AI-based antivirus detects suspicious program behavior instead of matching signatures for viruses.
- **Fraud Detection:** AI and ML algorithms carry out anomaly detection to identify payment inconsistencies and fraudulent transactions. They also perform automated pattern discovery across different transactions. ML can easily differentiate between authentic and illegitimate transactions and blocks fraudulent transactions.
- **Botnet Detection:** Botnets can bypass the Intrusion Detection System (IDS) by leveraging its ineffectiveness in matching signatures. Botnets can be embedded using a highly sophisticated code that makes them untraceable by traditional IDS implementations. Hence, security professionals use AI and ML algorithms that alert about the suspicious behavior of a network and detect unauthorized intrusions.
- **AI to Combat AI Threats:** Attackers can also leverage AI technology to make their way into an organization's network; such cyber threats must be detected immediately. AI software can detect such imminent AI-augmented attacks before the network is compromised.

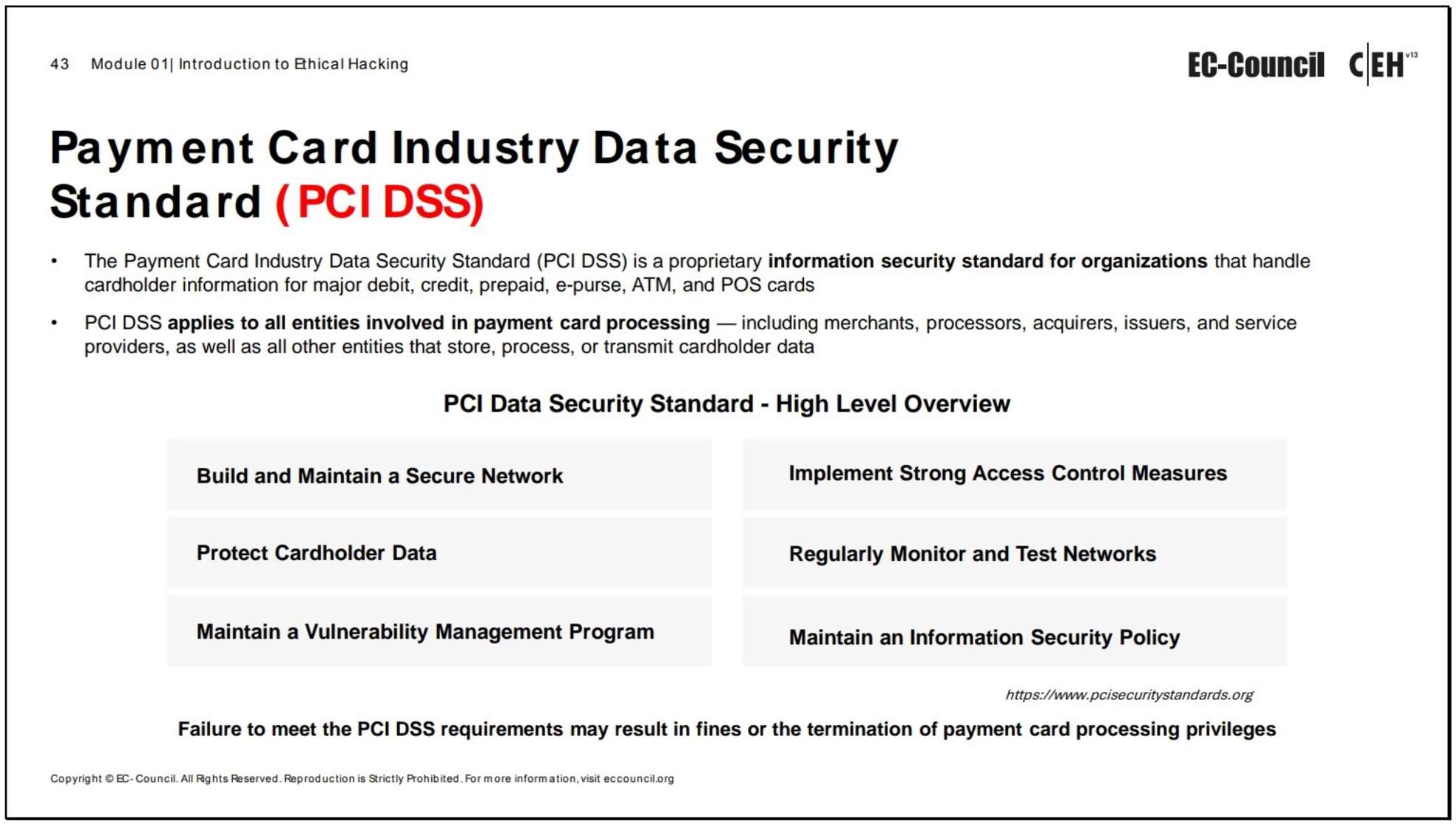
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Information Security Laws and Standards

Laws are a system of rules and guidelines that are enforced by a particular country or community to govern behavior. A Standard is a "document established by consensus and approved by a recognized body that provides, for common and repeated use, rules, guidelines, or characteristics for activities or their results, aimed at the achievement of the optimum degree of order in a given context." This section deals with the various laws and standards dealing with information security in different countries.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Payment Card Industry Data Security Standard (PCI DSS)

Source: *https://www.pcisecuritystandards.org*

The Payment Card Industry Data Security Standard (PCI DSS) is a proprietary information security standard for organizations that handle cardholder information for the major debit, credit, prepaid, e-purse, ATM, and POS cards. This standard offers robust and comprehensive standards and supporting materials to enhance payment card data security. These materials include a framework of specifications, tools, measurements, and support resources to help organizations ensure the safe handling of cardholder information. PCI DSS applies to all entities involved in payment card processing, including merchants, processors, acquirers, issuers, and service providers, as well as all other entities that store, process or transmit cardholder data. PCI DSS comprises a minimum set of requirements for protecting cardholder data. The Payment Card Industry (PCI) Security Standards Council has developed and maintains a high-level overview of PCI DSS requirements.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

PCI Data Security Standard – High Level Overview	
Build and Maintain a Secure Network	▪ Install and maintain a firewall configuration to protect cardholder data ▪ Do not use vendor-supplied defaults for system passwords and other security parameters
Protect Cardholder Data	▪ Protect stored cardholder data ▪ Encrypt transmission of cardholder data across open, public networks
Maintain a Vulnerability Management Program	▪ Use and regularly update anti-virus software or programs ▪ Develop and maintain secure systems and applications
Implement Strong Access Control Measures	▪ Restrict access to cardholder data by business need to know ▪ Assign a unique ID to each person with computer access ▪ Restrict physical access to cardholder data
Regularly Monitor and Test Networks	▪ Track and monitor all access to network resources and cardholder data ▪ Regularly test security systems and processes
Maintain an Information Security Policy	▪ Maintain a policy that addresses information security for all personnel

Table 1.6: Table Showing the PCI Data Security Standard—High-Level Overview

Failure to meet PCI DSS requirements may result in fines or the termination of payment-card processing privileges.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

ISO/ IEC Standards

Standard	Description
ISO/IEC 27001:2022	Specifies the requirements and a framework for **establishing**, **implementing**, **maintaining**, and continually improving an **Information Security Management System (ISMS)**
ISO/IEC 27701:2019	Extends ISO/IEC 27001 to include **privacy management**, focusing on protecting PII and implementing a **Privacy Information Management System (PIMS)**
ISO/IEC 27002:2022	Outlines **best practices** and control objectives **for critical cybersecurity areas**, including access control, cryptography, and security personnel
ISO/IEC 27005:2022	Provides guidelines for **information security risk management** to support the requirements of an ISMS as specified in ISO/IEC 27001
ISO/IEC 27018:2019	Offers code of practice specifically focused on the **protection of personally identifiable information (PII) in public clouds**
ISO/IEC 27032:2023	Explains the relationship between internet, web, network security, and cybersecurity, providing an overview of **internet security**, and identifying key stakeholders and their roles
ISO/IEC 27033-7:2023	Proposes guidelines for the implementation of **network virtualization security**
ISO/IEC 27036-3:2023	Provides guidelines for securing hardware, software, and services **supply chains**
ISO/IEC 27040:2024	Provides technical requirements and guidance for achieving **data storage security** through planning, design, documentation, and implementation

https://www.iso.org

Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

ISO/IEC Standards

Source: *https://www.iso.org*

ISO/IEC 27701:2022

ISO/IEC 27001:2022 is an international standard for Information Security Management Systems (ISMS). It specifies the requirements and framework for establishing, implementing, maintaining, and continually improving an ISMS to ensure confidentiality, integrity, and availability of information. This standard helps organizations manage security risks and protect sensitive information, including financial data, intellectual property, employee details, and information entrusted by third parties.

The standard is designed to be applicable for various purposes:

- Providing a structured approach for identifying, assessing, and managing information security risks.
- Helping organizations comply with regulatory, legal, and contractual obligations regarding information security.
- Strengthening information security posture, thereby reducing the risk of breaches and incidents.
- Continuously enhancing security practices, ensuring that the ISMS adapts to new threats and organizational changes.
- Building trust with customers, partners, and other stakeholders by demonstrating commitment to information security.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Providing a competitive edge by showcasing robust information security practices that can be market differentiators.
- Supporting digitization strategies by integrating information security measures into digital business processes and technologies.
- Addressing security challenges associated with remote working and "bring your own device" (BYOD) policies, reflecting modern workplace practices.
- Including controls relevant to Industry 4.0 technologies and cloud-based services, ensuring that security measures keep pace with technological advancements.
- Introducing requirements for effective communication of information security roles and responsibilities within the organization.

Other Relevant ISO/IEC Standards

- **ISO/IEC 27701:2019**

  ISO/IEC 27701:2019 extends the ISO/IEC 27001 framework to include privacy management, specifically focusing on protecting personally identifiable information (PII). It provides guidelines for implementing a private information management system (PIMS) to help organizations effectively manage privacy risks. Adopting this standard enables organizations to build stakeholder trust, enhance data protection, comply with global privacy regulations, and seamlessly integrate existing information security practices.

- **ISO/IEC 27002:2022**

  ISO/IEC 27002:2022 outlines the best practices and control objectives for critical cybersecurity areas such as access control, cryptography, and security personnel. This paper offers a comprehensive framework for implementing effective security controls to protect sensitive information and ensure regulatory compliance. Adhering to ISO/IEC 27002:2022 helps organizations strengthen their cybersecurity posture, mitigate risks, and enhance overall information security management processes, fostering a secure operational environment.

- **ISO/IEC 27005:2022**

  ISO/IEC 27005:2022 provides comprehensive guidelines for information security risk management and supports the ISMS requirements specified in ISO/IEC 27001. It aids organizations in developing a structured framework for conducting thorough and effective information security risk assessments. Following ISO/IEC 27005:2022, organizations can systematically identify, evaluate, and manage security risks, enhance their ability to protect sensitive information, and maintain robust security postures.

- **ISO/IEC 27018:2019**

  ISO/IEC 27018:2019 offers a code of practice that focuses on PII in public cloud environments. This paper provides guidelines for implementing cloud-specific controls designed to safeguard personal data. Adhering to ISO/IEC 27018:2019 ensures robust PII

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

protection in cloud services, enhances data privacy measures, and builds trust with stakeholders by relying on the secure handling of their personal information.

- **ISO/IEC 27032:2023**

  ISO/IEC 27032:2023 explains the relationship among the Internet, Web, network security, and cybersecurity, providing a comprehensive overview of Internet security and identifying key stakeholders and their roles. This standard assists organizations in enhancing their cybersecurity posture by addressing common Internet security issues and fostering coordinated security efforts among stakeholders. Implementing these guidelines improves resilience against cyber threats and ensures a secure, collaborative approach for managing Internet security challenges.

- **ISO/IEC 27033-7:2023**

  ISO/IEC 27033-7:2023 provides comprehensive guidelines for the implementation network virtualization security. It helps organizations secure and manage virtualization environments and mitigates the associated security risks. By adhering to this standard, organizations can effectively address potential threats and vulnerabilities specific to virtual networks, ensure robust protection, and maintain high security and operational integrity while leveraging virtualization technologies.

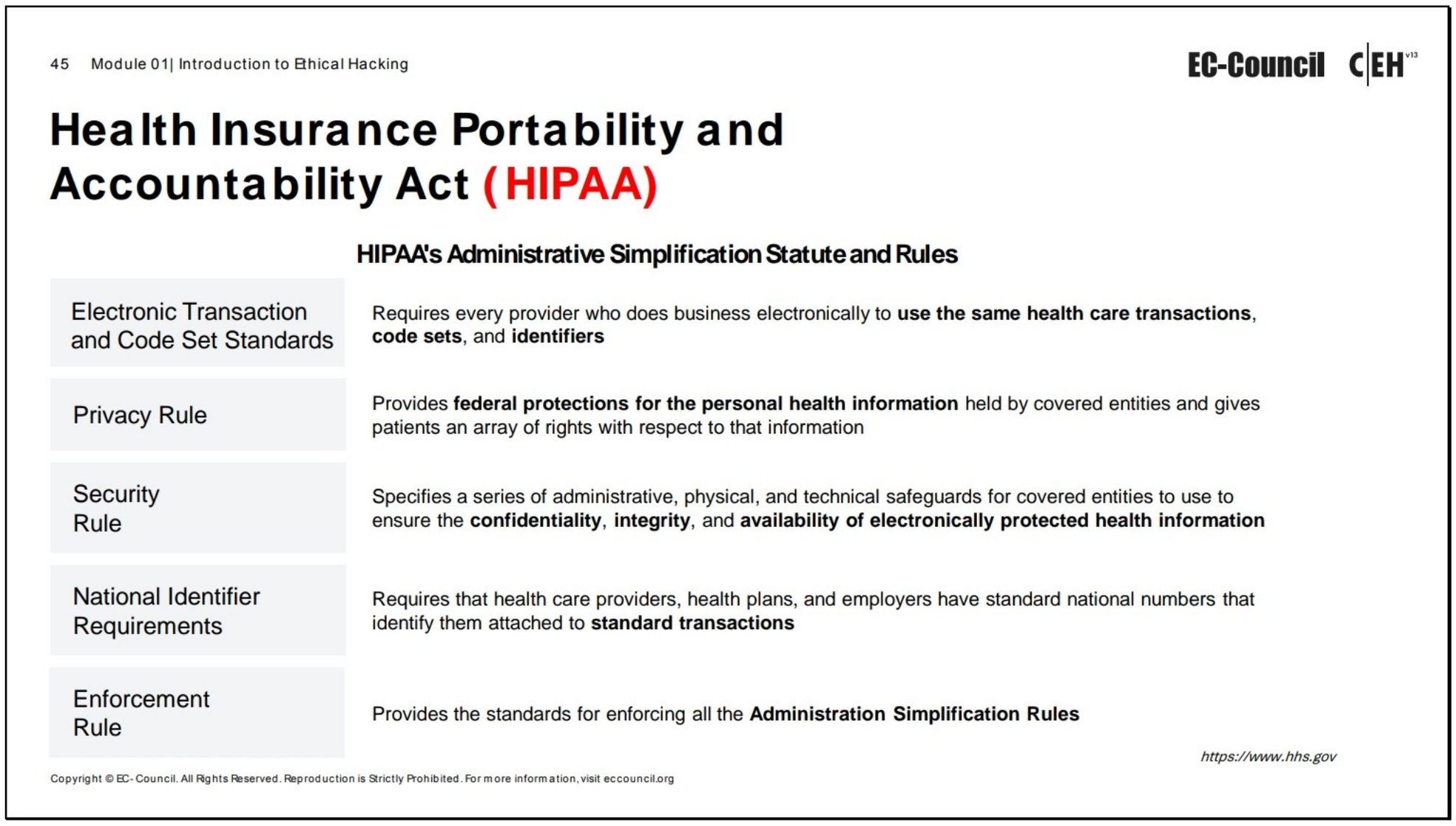
- **ISO/IEC 27036-3:2023**

  ISO/IEC 27036-3:2023 offers detailed guidelines for securing hardware, software, and services supply chains. This standard helps organizations mitigate supply chain security risks by ensuring the secure acquisition and integration of products and services. Following this standard, organizations can establish robust security practices throughout their supply chain, enhancing resilience against potential threats and vulnerabilities associated with third-party products and services, and thereby maintaining operational integrity in a digital environment.

- **ISO/IEC 27040:2024**

  ISO/IEC 27040:2024 provides the detailed technical requirements and guidance for achieving data storage security through careful planning, design, documentation, and implementation. It helps organizations mitigate the risks associated with data storage by applying consistent security measures across various storage devices, media, and networks. Adherence to this standard ensures the integrity, confidentiality, and availability of stored data, thereby enhancing overall data protection. This standard supports a comprehensive and systematic approach to secure data storage and effectively addresses potential vulnerabilities and threats.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Health Insurance Portability and Accountability Act (HIPAA)

Source: *https://www.hhs.gov*

The HIPAA Privacy Rule provides federal protections for the individually identifiable health information held by covered entities and their business associates and gives patients an array of rights to that information. At the same time, the Privacy Rule permits the disclosure of health information needed for patient care and other necessary purposes.

The Security Rule specifies a series of administrative, physical, and technical safeguards for covered entities and their business associates to use to ensure the confidentiality, integrity, and availability of electronically protected health information.

The office of civil rights implemented HIPAA's Administrative Simplification Statute and Rules, as discussed below:

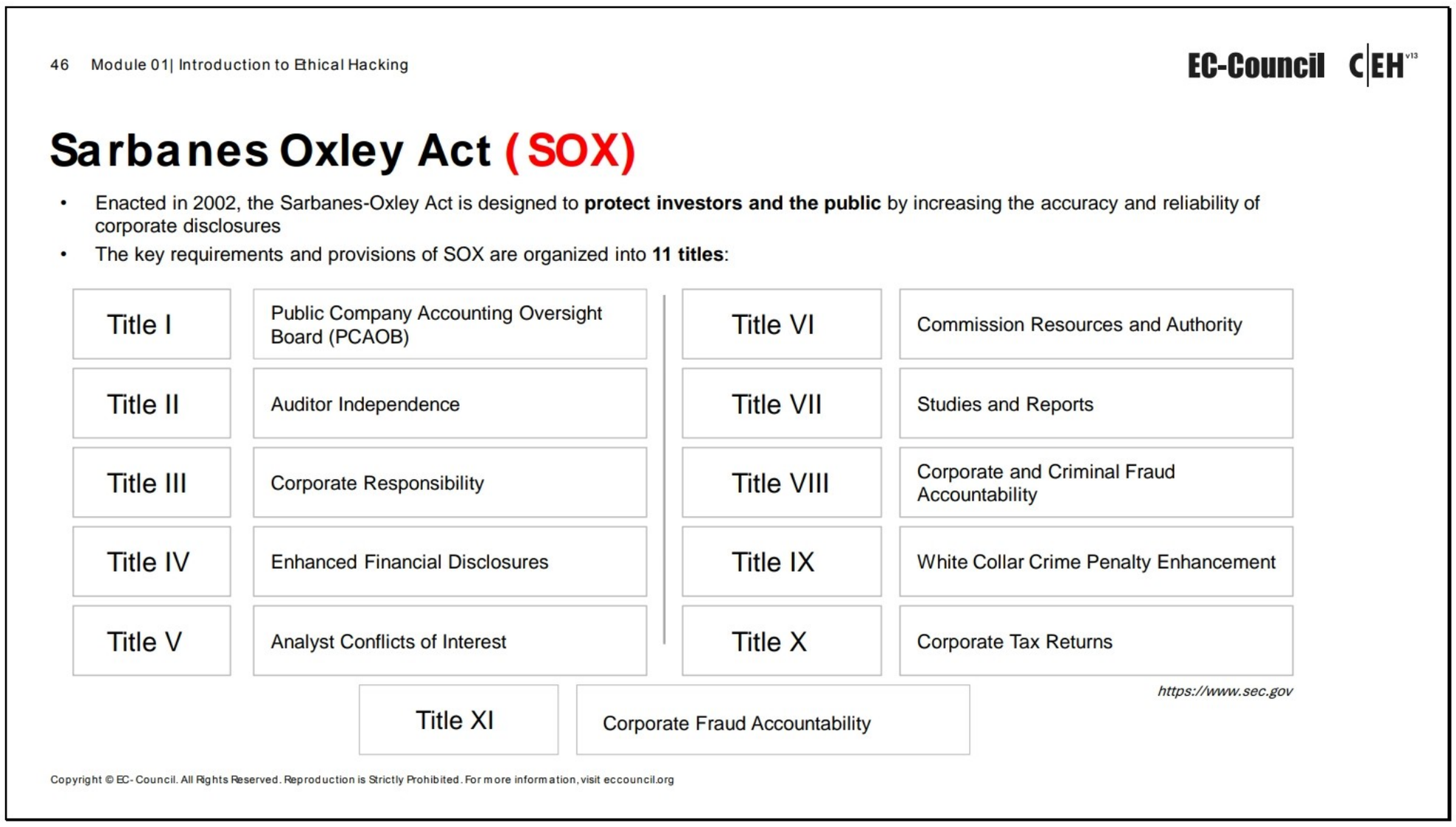
- **Electronic Transactions and Code Set Standards:** Transactions are electronic exchanges involving the transfer of information between two parties for specific purposes. The Health Insurance Portability and Accountability Act of 1996 (HIPAA) designated certain types of organizations as covered entities, including health plans, health care clearinghouses, and certain health care providers. In the HIPAA regulations, the Secretary of Health and Human Services (HHS) adopted certain standard transactions for the Electronic Data Interchange (EDI) of health care data. These transactions are claims and encounter information, payment and remittance advice, claim status, eligibility, enrollment and disenrollment, referrals and authorizations, coordination of benefits, and premium payment. Under HIPAA, if a covered entity electronically conducts one of the adopted transactions, they must use the adopted standard—either from ASC, X12N, or NCPDP (for certain pharmacy transactions). Covered entities must adhere to the

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

content and format requirements of each transaction. Every provider who does business electronically must use the same health care transactions, code sets, and identifiers.

- **Privacy Rule:** The HIPAA Privacy Rule establishes national standards to protect people's medical records and other personal health information and applies to health plans, health care clearinghouses, and health care providers that conduct certain health care transactions electronically. The rule requires appropriate safeguards to protect the privacy of personal health information. It sets limits and conditions on the uses and disclosures that may be made of such information without patient authorization. The rule also gives patients' rights over their health information, including the right to examine and obtain a copy of their health records and to request corrections.
- **Security Rule:** The HIPAA Security Rule establishes national standards to protect individuals' electronic personal health information that is created, received, used, or maintained by a covered entity. The Security Rule requires appropriate administrative, physical, and technical safeguards to ensure the confidentiality, integrity, and security of electronically protected health information.
- **Employer Identifier Standard:** The HIPAA requires that each employer has a standard national number that identifies them on standard transactions.
- **National Provider Identifier Standard (NPI):** The National Provider Identifier (NPI) is a HIPAA Administrative Simplification Standard. The NPI is a unique identification number assigned to covered health care providers. Covered health care providers and all health plans and health care clearinghouses must use the NPIs in the administrative and financial transactions adopted under HIPAA. The NPI is a 10-position, intelligence-free numeric identifier (10-digit number). This means that the numbers do not carry other information about healthcare providers, such as the state in which they live or their medical specialty.
- **Enforcement Rule:** The HIPAA Enforcement Rule contains provisions relating to compliance and investigation, as well as the imposition of civil monetary penalties for violations of the HIPAA Administrative Simplification Rules and procedures for hearings.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Sarbanes Oxley Act (SOX)

Source: *https://www.sec.gov*

Enacted in 2002, the Sarbanes-Oxley Act aims to protect the public and investors by increasing the accuracy and reliability of corporate disclosures. This act does not explain how an organization must store records but describes the records that organizations must store and the duration of their storage. The Act mandated several reforms to enhance corporate responsibility, enhance financial disclosures, and combat corporate and accounting fraud.

The key requirements and provisions of SOX are organized into 11 titles:

- **Title I: Public Company Accounting Oversight Board (PCAOB):** Title I consists of nine sections and establishes the Public Company Accounting Oversight Board to provide independent oversight of public accounting firms that provide audit services ("auditors"). It also creates a central oversight board tasked with registering audit services, defining the specific processes and procedures for compliance audits, inspecting and policing conduct and quality control, and enforcing compliance with the specific mandates of SOX.
- **Title II: Auditor Independence:** Title II consists of nine sections and establishes standards for external auditor independence to limit conflicts of interest. It also addresses new auditor approval requirements, audit partner rotation, and auditor reporting requirements. It restricts auditing companies from providing non-audit services (such as consulting) for the same clients.
- **Title III: Corporate Responsibility:** Title III consists of eight sections and mandates that senior executives take individual responsibility for the accuracy and completeness of corporate financial reports. It defines the interaction between external auditors and

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

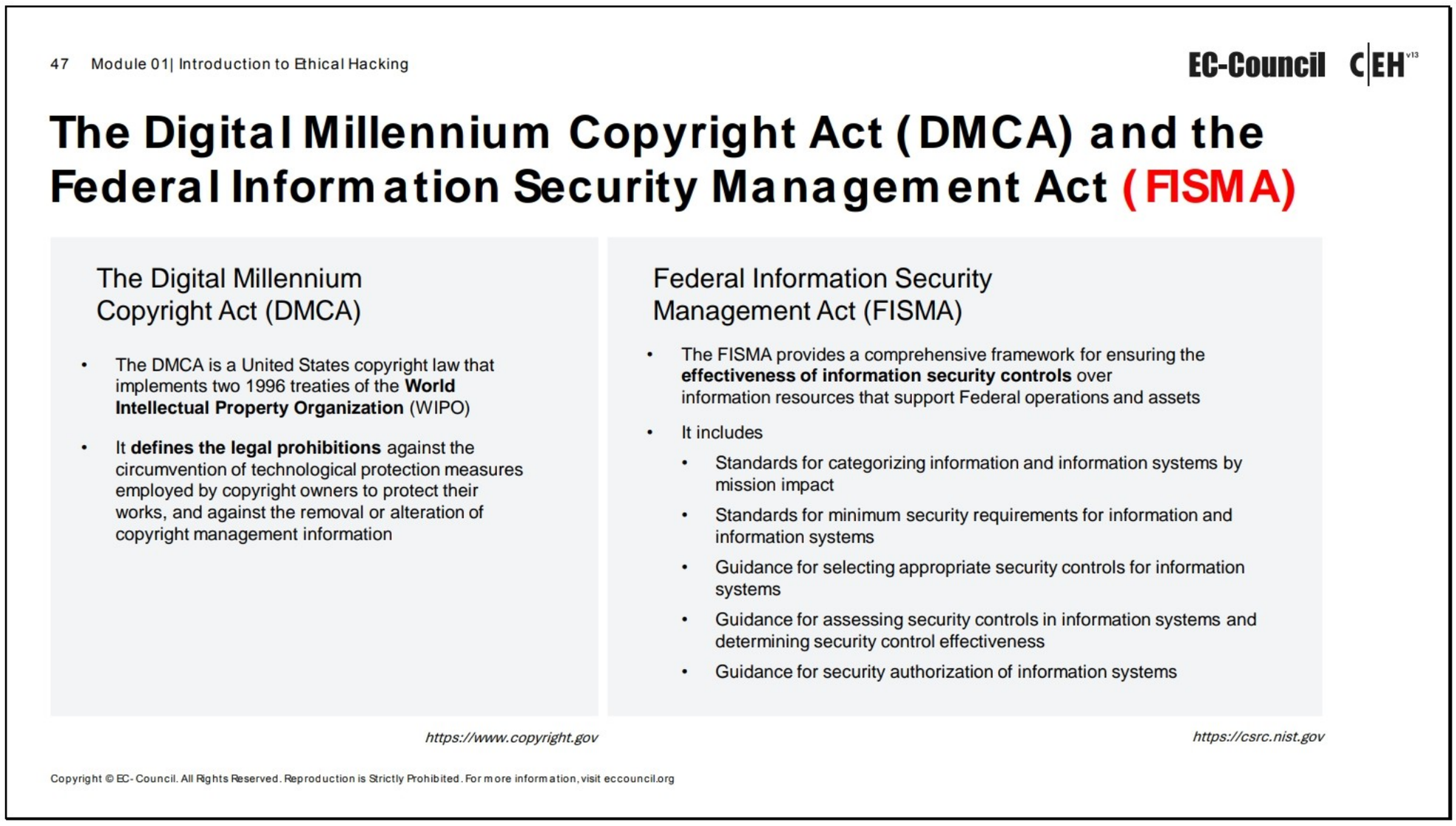
corporate audit committees and specifies the corporate officers' responsibility for the accuracy and validity of corporate financial reports. It enumerates specific limits on the behaviors of corporate officers and describes specific forfeitures of benefits and civil penalties for non-compliance.

- **Title IV: Enhanced Financial Disclosures:** Title IV consists of nine sections. It describes enhanced reporting requirements for financial transactions, including off-balance-sheet transactions, pro-forma figures, and the stock transactions of corporate officers. It requires internal controls to ensure the accuracy of financial reports and disclosures and mandates both audits and reports on those controls. It also requires timely reporting of material changes in financial conditions and specific enhanced reviews of corporate reports by the SEC or its agents.
- **Title V: Analyst Conflicts of Interest:** Title V consists of only one section that discusses the measures designed to help restore investor confidence in the reporting of securities analysts. It defines the code of conduct for securities analysts and requires that they disclose any knowable conflicts of interest.
- **Title VI: Commission Resources and Authority:** Title VI consists of four sections and defines practices to restore investor confidence in securities analysts. It also defines the SEC's authority to censure or bar securities professionals from practice and defines the conditions to bar a person from practicing as a broker, advisor, or dealer.
- **Title VII: Studies and Reports:** Title VII consists of five sections and requires the Comptroller General and the Securities and Exchange Commission (SEC) to perform various studies and to report their findings. The required studies and reports include the effects of the consolidation of public accounting firms, the role of credit rating agencies in the operation of securities markets, securities violations, enforcement actions, and whether investment banks assisted Enron, Global Crossing, and others to manipulate earnings and obfuscate true financial conditions.
- **Title VIII: Corporate and Criminal Fraud Accountability:** Title VIII, also known as the "Corporate and Criminal Fraud Accountability Act of 2002," consists of seven sections. It describes specific criminal penalties for the manipulation, destruction, or alteration of financial records or interference with investigations, while also providing certain protections for whistle-blowers.
- **Title IX: White-Collar-Crime Penalty Enhancement:** Title IX, also known as the "White Collar Crime Penalty Enhancement Act of 2002," consists of six sections. This title increases the criminal penalties associated with white-collar crimes and conspiracies. It recommends stronger sentencing guidelines and specifically adds failure to certify corporate financial reports as a criminal offense.
- **Title X: Corporate Tax Returns:** Title X consists of one section that states that the Chief Executive Officer should sign the company tax return.
- **Title XI: Corporate Fraud Accountability:** Title XI consists of seven sections. Section 1101 recommends the following name for the title: "Corporate Fraud Accountability Act

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

of 2002." It identifies corporate fraud and records tampering as criminal offenses and joins those offenses to specific penalties. It also revises sentencing guidelines and strengthens penalties. Doing so enables the SEC to temporarily freeze "large" or "unusual" transactions or payments.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



The Digital Millennium Copyright Act (DMCA)

Source: *https://www.copyright.gov*

The DMCA is an American copyright law that implements two 1996 treaties from the World Intellectual Property Organization (WIPO): the WIPO Copyright Treaty and the WIPO Performances and Phonograms Treaty. In order to implement US treaty obligations, the DMCA defines legal prohibitions against circumvention of the technological protection measures employed by copyright owners to protect their works, and against the removal or alteration of copyright management information. The DMCA contains five titles:

- **Title I**: **WIPO TREATY IMPLEMENTATION:** Title I implements the WIPO treaties. First, it makes certain technical amendments to US law in order to provide the appropriate references and links to the treaties. Second, it creates two new prohibitions in Title 17 of the U.S. Code—one on circumvention of the technological measures used by copyright owners to protect their works and one on tampering with copyright management information—and adds civil remedies and criminal penalties for violating the prohibitions.
- **Title II: ONLINE COPYRIGHT INFRINGEMENT LIABILITY LIMITATION:** Title II of the DMCA adds a new section 512 to the Copyright Act to create four new limitations on liability for copyright infringement by online service providers. A service provider bases these limitations on the following four categories of conduct:
  - Transitory communications
  - System caching
  - The user-directed storage of information on systems or networks
  - Information location tools

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

New section 512 also includes special rules concerning the application of these limitations to nonprofit educational institutions.

- **Title III: COMPUTER MAINTENANCE OR REPAIR:** Title III of the DMCA allows the owner of a copy of a program to make reproductions or adaptations when necessary to use the program in conjunction with a computer. The amendment permits the owner or lessee of a computer to make or to authorize the making of a copy of a computer program in the course of maintaining or repairing that computer.
- **Title IV: MISCELLANEOUS PROVISIONS:** Title IV contains six miscellaneous provisions. The first provision announces the Clarification of the Authority of the Copyright Office; the second grants exemption for the making of "ephemeral recordings"; the third promotes study by distance education; the fourth provides an exemption for Nonprofit Libraries and Archives; the fifth allows Webcasting Amendments to the Digital Performance Right in Sound Recordings, and, finally, the sixth provision addresses concerns about the ability of writers, directors and screen actors to obtain residual payments for the exploitation of motion pictures in situations where the producer is no longer able to make these payments.
- **Title V: PROTECTION OF CERTAIN ORIGINAL DESIGNS:** Title V of the DMCA, entitles the Vessel Hull Design Protection Act (VHDPA). This act creates a new system for protecting the original designs of certain useful articles that make the article attractive or distinctive in appearance. For purposes of the VHDPA, "useful articles" are limited to the hulls (including the decks) of vessels no longer than 200 feet.

The Federal Information Security Management Act (FISMA)

Source: *https://csrc.nist.gov*

The Federal Information Security Management Act of 2002 was enacted to produce several key security standards and guidelines required by Congressional legislation. The FISMA provides a comprehensive framework for ensuring the effectiveness of information security controls over information resources that support federal operations and assets. It requires each federal agency to develop, document, and implement an agency-wide program to provide information security for the information and information systems that support the operations and assets of the agency, including those provided or managed by another agency, contractor, or another source. The FISMA framework includes:

- Standards for categorizing information and information systems by mission impact
- Standards for the minimum security requirements for information and information systems
- Guidance for selecting appropriate security controls for information systems
- Guidance for assessing security controls in information systems and determining their effectiveness
- Guidance for the security authorization of information systems

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

General Data Protection Regulation (GDPR)

- GDPR regulation was put into effect on May 25, 2018 and one of the **most stringent privacy and security laws globally**
- The GDPR will **levy harsh fines** against those who violate its privacy and security standards, with penalties reaching tens of millions of euros

GDPR Data Protection Principles

- **Lawfulness, fairness, and transparency**: Processing must be lawful, fair, and transparent to the data subject
- **Purpose limitation**: You must process data for the legitimate purposes specified explicitly to the data subject when you collected it
- **Data minimization**: You should collect and process only as much data as necessary for the purposes specified
- **Accuracy**: You must keep personal data accurate and up to date
- **Storage limitation**: You may only store personally identifying data for as long as necessary for the specified purpose
- **Integrity and confidentiality**: Processing must be done in such a way as to ensure appropriate security, integrity, and confidentiality (e.g., by using encryption)
- **Accountability**: The data controller is responsible for demonstrating GDPR compliance with all these principles

https://gdpr.eu

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

General Data Protection Regulation (GDPR)

Source: *https://gdpr.eu*

The General Data Protection Regulation (GDPR) is one of the most stringent privacy and security laws globally. Though it was drafted and passed by the European Union (EU), it imposes obligations onto organizations anywhere, so long as they target or collect data related to people in the EU. The regulation was put into effect on May 25, 2018. The GDPR will levy harsh fines against those who violate its privacy and security standards, with penalties reaching tens of millions of euros.

With the GDPR, Europe signifies its firm stance on data privacy and security when more people are entrusting their data with cloud services, and breaches are a daily occurrence. The regulation itself is extensive, far-reaching, and relatively light on specifics, making GDPR compliance a daunting prospect, particularly for small and medium-sized enterprises (SMEs).

GDPR Data Protection Principles

The GDPR includes seven protection and accountability principles outlined in Article 5.1-2:

- **Lawfulness, fairness, and transparency**: Processing must be lawful, fair, and transparent to the data subject.
- **Purpose limitation:** You must process data for the legitimate purposes specified explicitly to the data subject when you collected it.
- **Data minimization:** You should collect and process only as much data as necessary for the purposes specified.
- **Accuracy:** You must keep personal data accurate and up to date.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Storage limitation:** You may only store personally identifying data for as long as necessary for the specified purpose.
- **Integrity and confidentiality:** Processing must be done in such a way as to ensure appropriate security, integrity, and confidentiality (e.g., by using encryption).
- **Accountability:** The data controller is responsible for demonstrating GDPR compliance with all of these principles.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Data Protection Act 2018 (DPA)

- The **DPA 2018** sets out the framework for data protection law in the **UK**
- It **updates** and **replaces** the Data Protection Act 1998 and came into effect on 25 May, 2018
- The DPA is an act to make provision for the regulation of the processing of information relating to **individuals**; to make provision in connection with the **Information Commissioner's functions** under specific regulations relating to information; to make provision for a direct **marketing code** of practice, and connected purposes

- The DPA **protects individuals** concerning the processing of personal data, in particular by:
  - Requiring **personal data to be processed lawfully** and fairly, based on the data subject's consent or another specified basis,
  - **Conferring rights** on the data subject to obtain information about the processing of personal data and to require inaccurate personal data to be rectified, and
  - **Conferring functions** on the Commissioner, giving the holder of that office responsibility to monitor and enforce their provisions

https://www.legislation.gov.uk

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Data Protection Act 2018 (DPA)

Source: *https://www.legislation.gov.uk*

The DPA 2018 sets out the framework for data protection law in the UK. It updates and replaces the Data Protection Act 1998 and came into effect on 25 May, 2018. It was amended on 01 January, 2021 by regulations under the European Union (Withdrawal) Act 2018 to reflect the UK's status outside the EU.

The DPA is an act to make provision for the regulation of the processing of information relating to individuals; to make provision in connection with the Information Commissioner's functions under specific regulations relating to information; to make provision for a direct marketing code of practice, and connected purposes.

The DPA also sets out separate data protection rules for law enforcement authorities, extends data protection to some other areas such as national security and defense, and sets out the Information Commissioner's functions and powers.

Protection of personal data

1. The DPA protects individuals concerning the processing of personal data, in particular by:
   a. Requiring personal data to be processed lawfully and fairly, based on the data subject's consent or another specified basis,
   b. Conferring rights on the data subject to obtain information about the processing of personal data and to require inaccurate personal data to be rectified, and
   c. Conferring functions on the Commissioner, giving the holder of that office responsibility to monitor and enforce their provisions.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

2. When carrying out functions under the GDPR, the applied GDPR, and this Act, the Commissioner must regard the importance of securing an appropriate level of protection for personal data, taking account of the interests of data subjects, controllers, and others, and matters of general public interest.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Cyber Law in Different Countries

Country Name	Laws/Acts	Website
United States	Section 107 of the Copyright Law mentions the doctrine of "fair use"	https://www.copyright.gov
	Online Copyright Infringement Liability Limitation Act	
	The Lanham (Trademark) Act (15 USC §§ 1051 - 1127)	https://www.bitlaw.com
	The Electronic Communications Privacy Act	https://bja.ojp.gov
	Foreign Intelligence Surveillance Act	https://bja.ojp.gov
	Protect America Act of 2007	https://www.justice.gov
	Privacy Act of 1974	https://www.justice.gov
	National Information Infrastructure Protection Act of 1996	https://www.congress.gov
	Computer Security Act of 1987	https://csrc.nist.gov
	Freedom of Information Act (FOIA)	https://www.foia.gov
	Computer Fraud and Abuse Act	https://www.energy.gov
	Identity Theft and Assumption Deterrence Act	https://www.ftc.gov
	California Consumer Privacy Act (CCPA)	https://oag.ca.gov
	California Privacy Rights Act	https://thecpra.org

Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Cyber Law in Different Countries (Cont'd)

Country Name	Laws/Acts	Website
Australia	Trade Marks Act 1995	https://www.legislation.gov.au
	The Patents Act 1990	
	The Copyright Act 1968	
	Cybercrime Act 2001	https://www.cybercrimelaw.net
United Kingdom	The Copyright, Etc. and Trademarks (Offenses And Enforcement) Act 2002	https://www.legislation.gov.uk
	Trademarks Act 1994	
	Computer Misuse Act 1990	
	The Network and Information Systems Regulations 2018	
	Communications Act 2003	
	The Privacy and Electronic Communications (EC Directive) Regulations 2003	
	Investigatory Powers Act 2016	
	Regulation of Investigatory Powers Act 2000	
China	Copyright Law of the People's Republic of China (Amendments on October 27, 2001)	http://www.npc.gov.cn
	Trademark Law of the People's Republic of China (Amendments on October 27, 2001)	
India	The Patents (Amendment) Act, 1999, Trade Marks Act, 1999, The Copyright Act, 1957	https://www.ipindia.gov.in
	Information Technology Act	https://www.meity.gov.in
Germany	Section 202a. Data Espionage, Section 303a. Alteration of Data, Section 303b. Computer Sabotage	https://www.cybercrimelaw.net

Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Cyber Law in Different Countries (Cont'd)

Country Name	Laws/Acts	Website
Italy	Penal Code Article 615 ter	https://www.cybercrimelaw.net
Japan	The Trademark Law (Law No. 127 of 1959)	https://www.iip.or.jp
Canada	Copyright Act (R.S.C., 1985, c. C-42), Trademarks Act (R.S.C., 1985, c. T-13), Canadian Criminal Code Section 342.1	https://laws-lois.justice.gc.ca
	Personal Information Protection and Electronic Documents Act (PIPEDA)	https://www.priv.gc.ca
Singapore	Computer Misuse Act	https://sso.agc.gov.sg
South Africa	Trademarks Act 194 of 1993	http://www.cipc.co.za
	Copyright Act of 1978	https://www.wipo.int
South Korea	Copyright Act (amended up to Act No. 19597 of August 8, 2023)	https://www.wipo.int
	Industrial Design Protection Act	https://www.kipo.go.kr
Belgium	Copyright Law, 30/06/1994	https://www.wipo.int
	Computer Hacking	https://www.cybercrimelaw.net
Brazil	Brazilian General Data Protection Law (LGPD)	https://iapp.org
Hong Kong	Article 139 of the Basic Law	https://www.basiclaw.gov.hk
Philippines	Republic Act No. 10175	https://lawphil.net

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Cyber Law in Different Countries

Cyberlaw or Internet law refers to any laws that deal with protecting the Internet and other online communication technologies. Cyberlaw covers topics such as Internet access and usage, privacy, freedom of expression, and jurisdiction. Cyber laws provide an assurance of the integrity, security, privacy, and confidentiality of information in both governmental and private organizations. These laws have become prominent due to the increase in Internet usage around the world. Cyber laws vary by jurisdiction and country, so implementing them is quite challenging. Violating these laws results in punishments ranging from fines to imprisonment.

Country Name	Laws/Acts	Website
United States	Section 107 of the Copyright Law mentions the doctrine of "fair use"	https://www.copyright.gov
	Online Copyright Infringement Liability Limitation Act	
	The Lanham (Trademark) Act (15 USC §§ 1051 - 1127)	https://www.bitlaw.com
	The Electronic Communications Privacy Act	https://bja.ojp.gov
	Foreign Intelligence Surveillance Act	https://bja.ojp.gov
	Protect America Act of 2007	https://www.justice.gov
	Privacy Act of 1974	https://www.justice.gov
	National Information Infrastructure Protection Act of 1996	https://www.congress.gov
	Computer Security Act of 1987	https://csrc.nist.gov
	Freedom of Information Act (FOIA)	https://www.foia.gov
	Computer Fraud and Abuse Act	https://www.energy.gov

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

	Identity Theft and Assumption Deterrence Act	https://www.ftc.gov
	California Consumer Privacy Act (CCPA)	https://oag.ca.gov
	California Privacy Rights Act of 2020	https://thecpra.org
Australia	Trademarks Act 1995	https://www.legislation.gov.au
	The Patents Act 1990	
	The Copyright Act 1968	
	Cybercrime Act 2001	https://www.cybercrimelaw.net
United Kingdom	The Copyright, Etc. and Trademarks (Offenses and Enforcement) Act 2002	https://www.legislation.gov.uk
	Trademarks Act 1994	
	Computer Misuse Act 1990	
	The Network and Information Systems Regulations 2018	
	Communications Act 2003	
	The Privacy and Electronic Communications (EC Directive) Regulations 2003	
	Investigatory Powers Act 2016	
	Regulation of Investigatory Powers Act 2000	
China	Copyright Law of the People's Republic of China (Amendments on October 27, 2001)	http://www.npc.gov.cn
	Trademark Law of the People's Republic of China (Amendments on October 27, 2001)	
India	The Patents (Amendment) Act, 1999, Trade Marks Act, 1999, The Copyright Act, 1957	https://www.ipindia.gov.in
	Information Technology Act	https://www.meity.gov.in
Germany	Section 202a. Data Espionage, Section 303a. Alteration of Data, Section 303b. Computer Sabotage	https://www.cybercrimelaw.net
Italy	Penal Code Article 615 ter	https://www.cybercrimelaw.net
Japan	The Trademark Law (Law No. 127 of 1959)	https://www.iip.or.jp
Canada	Copyright Act (R.S.C., 1985, c. C-42), Trademarks Act (R.S.C., 1985, c. T-13), Canadian Criminal Code Section 342.1	https://laws-lois.justice.gc.ca
	Personal Information Protection and Electronic Documents Act (PIPEDA)	https://www.priv.gc.ca
Singapore	Computer Misuse Act	https://sso.agc.gov.sg
South Africa	Trademarks Act 194 of 1993	http://www.cipc.co.za
	Copyright Act of 1978	https://www.wipo.int
South Korea	Copyright Act (amended up to Act No. 19597 of August 8, 2023)	https://www.wipo.int
	Industrial Design Protection Act	https://www.kipo.go.kr

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Belgium	Copyright Law, 30/06/1994	https://www.wipo.int
	Computer Hacking	https://www.cybercrimelaw.net
Brazil	Brazilian General Data Protection Law (LGPD)	https://iapp.org
Hong Kong	Article 139 of the Basic Law	https://www.basiclaw.gov.hk
Philippines	Republic Act No. 10175	https://lawphil.net

Table 1.7: Cyber Law in Different Countries

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Module Summary

- This module discussed elements of information security, information security attacks, and information warfare
- It also discussed hacking concepts and hacker classes
- This module also covered ethical hacking concepts such as the scope and limitations of ethical hacking, skills, and along with AI-driven ethical hacking in detail
- It discussed various hacking methodologies and frameworks including CEH ethical hacking framework, cyber kill chain methodology, MITRE ATT&CK framework, and diamond model for intrusion analysis
- It discussed information security controls such as defense-in-depth, risk management, cyber threat intelligence, threat modeling, incident management process, and AI and ML
- This module ended with a detailed discussion of various information security acts and laws
- The next module will go into detail about how attackers, as well as ethical hackers and pen testers, perform footprinting to collect information about the target of an evaluation before an attack or audit

Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Module Summary

This module has discussed elements of information security, information security attacks, and information warfare. It also discussed hacking concepts and hacker classes. This module closely examined ethical hacking concepts such as its scope and limitations and the skills of an ethical hacker along with AI-driven ethical hacking. It has covered various hacking methodologies and frameworks including CEH ethical hacking framework, cyber kill chain methodology, MITRE ATT&CK framework, and diamond model for intrusion analysis. It also covered information security controls such as defense-in-depth, risk management, cyber threat intelligence, threat modeling, incident management process, and AI and ML. Finally, this module ended with a detailed discussion of various information security acts and laws.

The next module will examine how attackers, as well as ethical hackers and pen testers, perform footprinting to collect information about their target before an attack or audit.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

This page is intentionally left blank.